INF1416
Segurança da Informação

Prof. Anderson Oliveira da Silva
D. Sc. Ciências em Informática
Engenheiro de Computação
anderson@inf.puc-rio.br

Departamento de Informática
PUC-Rio

DEPARTAMENTO DE INFORMÁTICA PUC·RIO

PUC RIO

Ementa

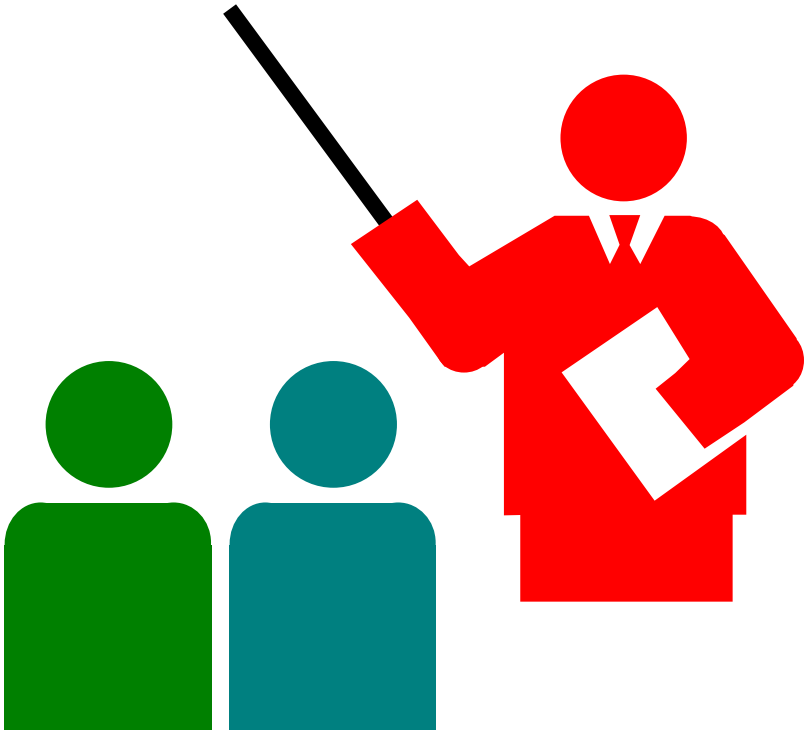
- Segurança da Informação
  Prof. Anderson O. da Silva

Comunicação Segura:

- Ameaças Comuns
- Temporalidade
- Integridade
- Integridade e Autenticidade
- Certificado Digital
- Infraestrutura de Chaves Públicas (ICP)
- Autoridade Certificadora (AC)
- Processo de Comunicação Segura
- SSL (Secure Socket Layer)
- TLS (Transport Layer Security)
- SET (Secure Eletronic Transaction)

Comunicação Segura

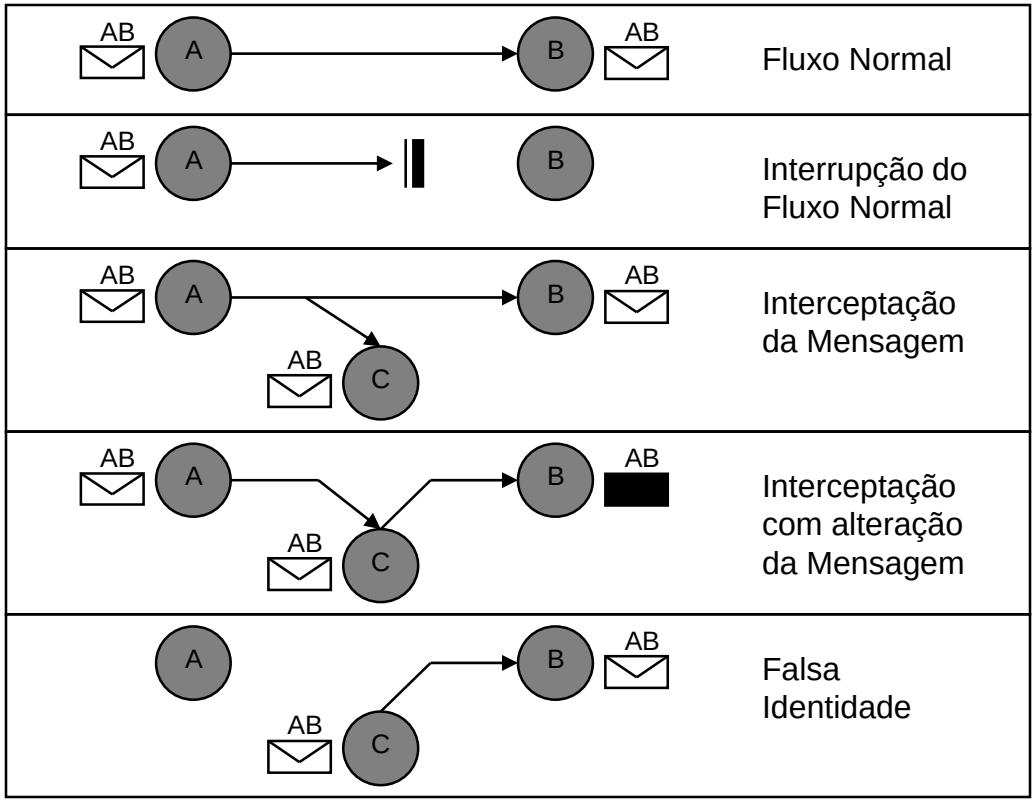
- Segurança da Informação
  Prof. Anderson O. da Silva



Comunicação Segura

- **Segurança da Informação**
  Prof. Anderson O. da Silva

Ameaças Comuns:



Comunicação Segura

Objetivos:

- Controle de Temporalidade
  - Detectar a recepção de mensagens retransmitidas ou com o conteúdo antigo.
- Controle de Integridade
  - Detectar se mensagens não foram modificadas durante a transmissão.
- Controle de Autenticidade
  - Verificar a identidade do usuário que alega ter sido o gerador da mensagem.
- Controle de Confidencialidade
  - Proteger o conteúdo de mensagens de exposição a terceiros.

Comunicação Segura

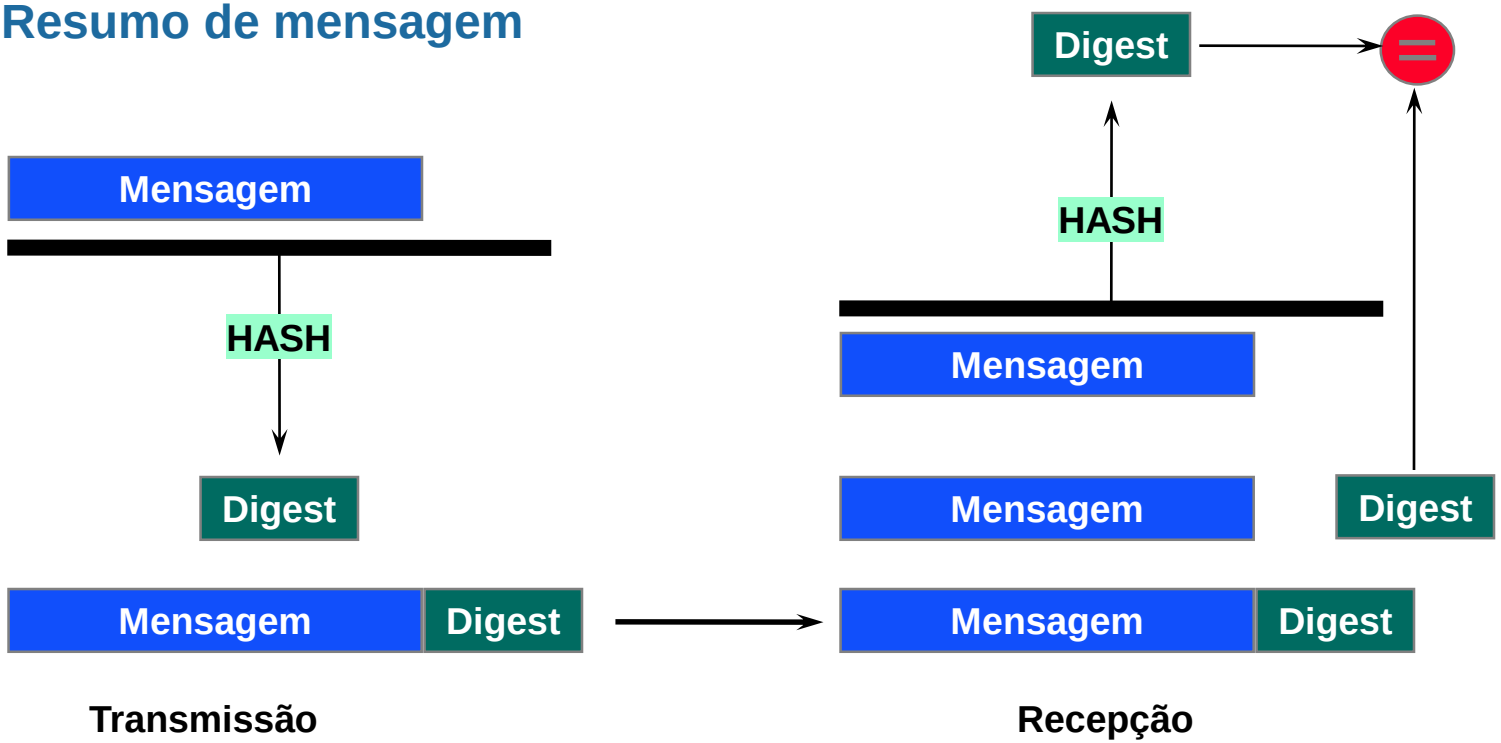
Controle de Temporalidade:

- **Envelope digital em conjunto com janela de tempo:**
  - **Chave secreta gerada e válida dentro de uma janela de tempo determinada pelo protocolo de comunicação ou pelas partes envolvidas (*chave de sessão*).**
  - **Transmitida com segurança entre emissor e receptor (*envelope digita*l).**
  - **Mensagens recebidas fora da janela de tempo devem ser descartadas.**
  - **Renegociação da chave secreta (*chave de sessão*) após um período de tempo pré-estabelecido pelo protocolo de comunicação ou pelas partes envolvidas.**
  - **Controle de sequenciamento de mensagens com contadores incrementais iniciados com valores aleatórios.**

Comunicação Segura

Controle de Integridade:

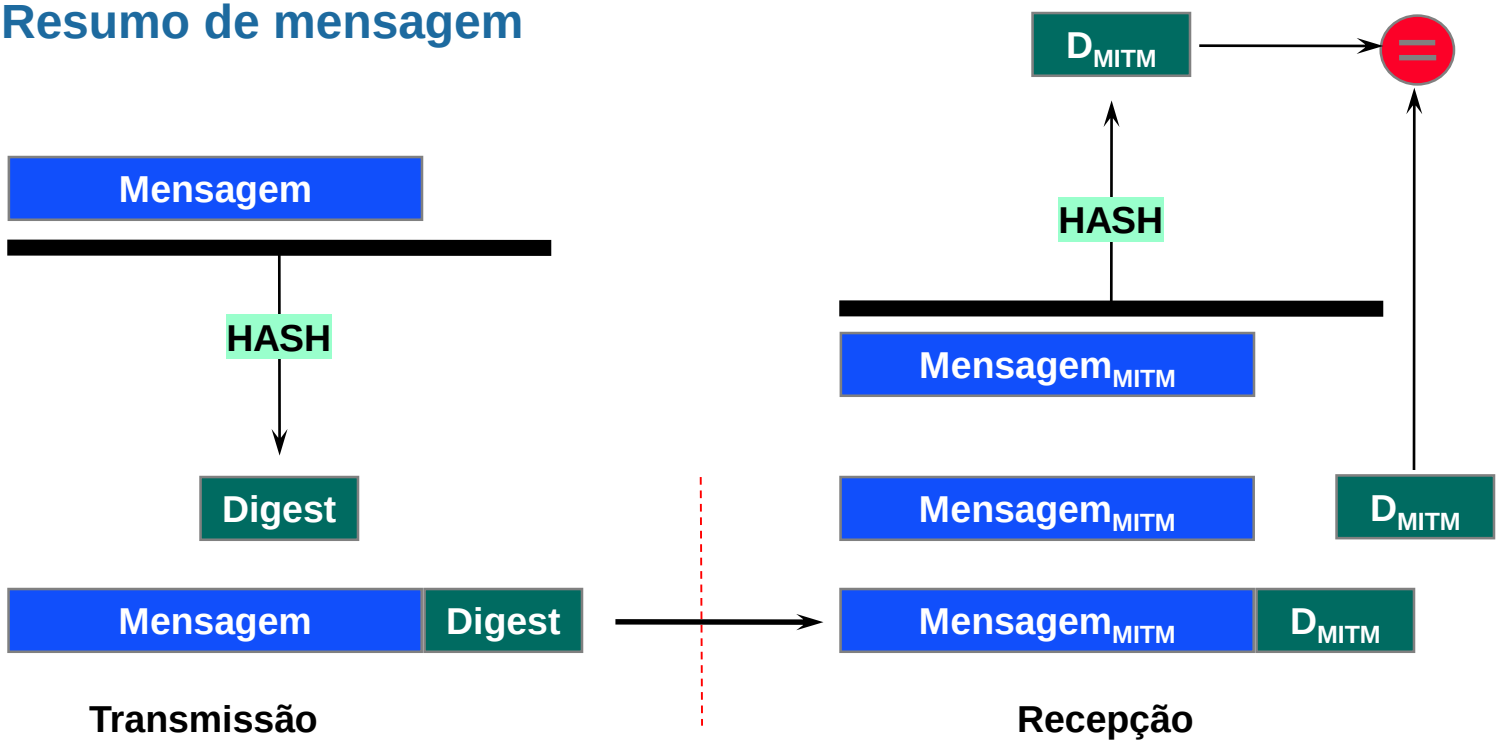
- **Resumo de mensagem**



Comunicação Segura

Controle de Integridade:

- **Resumo de mensagem**



Comunicação Segura

Controle de Integridade: Resumo de mensagem

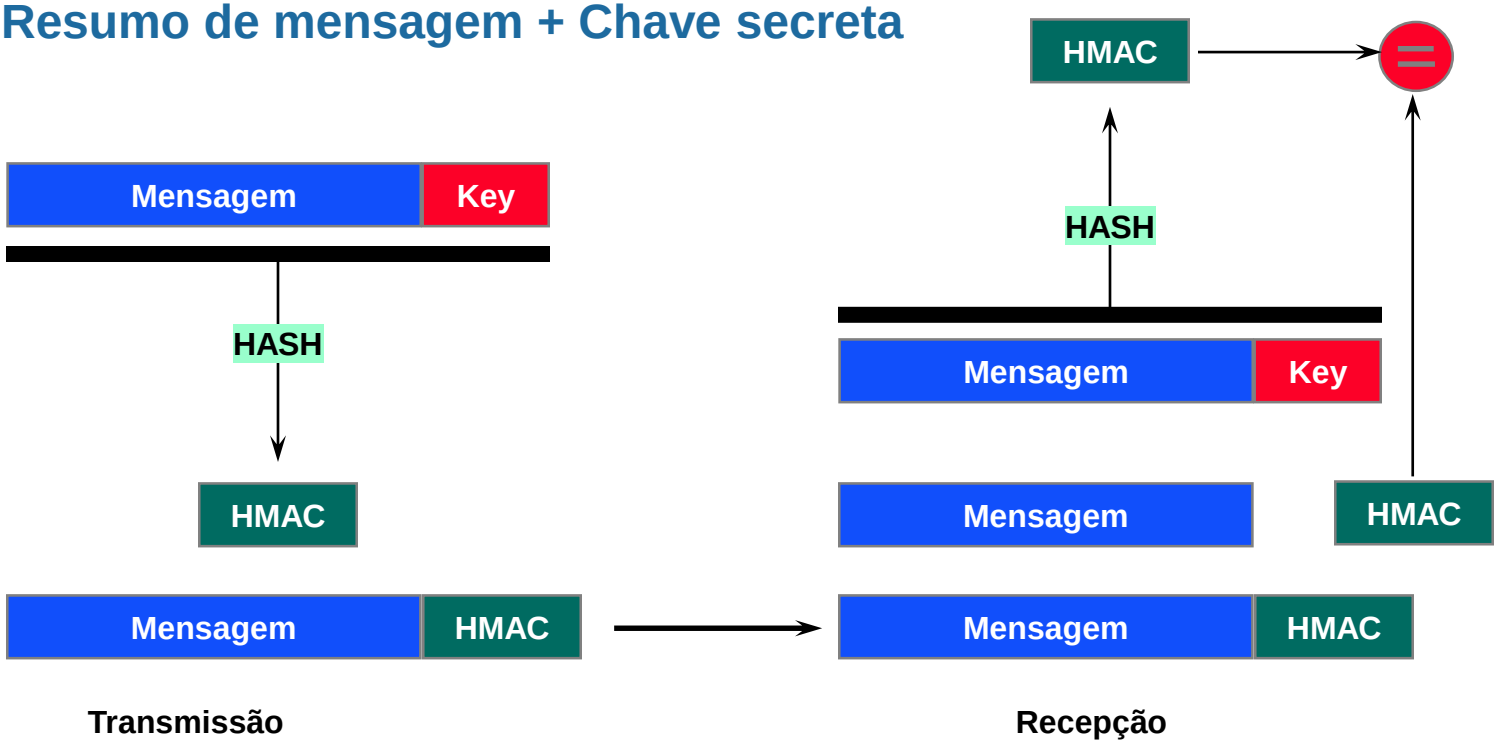
- **Ameaça:**
  - **Quando o algoritmo de HASH é conhecido, só o digest não garante integridade fim a fim.**
  - **Mensagem pode ser interceptada, alterada, digest recalculado, e passada adiante pelo *man-in-the-middle* junto com o novo digest.**

- **Alternativa para garantia de integridade e autenticidade:**
  - **Acrescentar uma chave secreta no cálculo do digest:**
    - **Geração do HMAC (HASH Message Authentication Code).**
  - **Transmitir a mensagem e o digest.**
  - **Chave secreta não é enviada.**

Comunicação Segura

Controle de Integridade e Autenticidade:

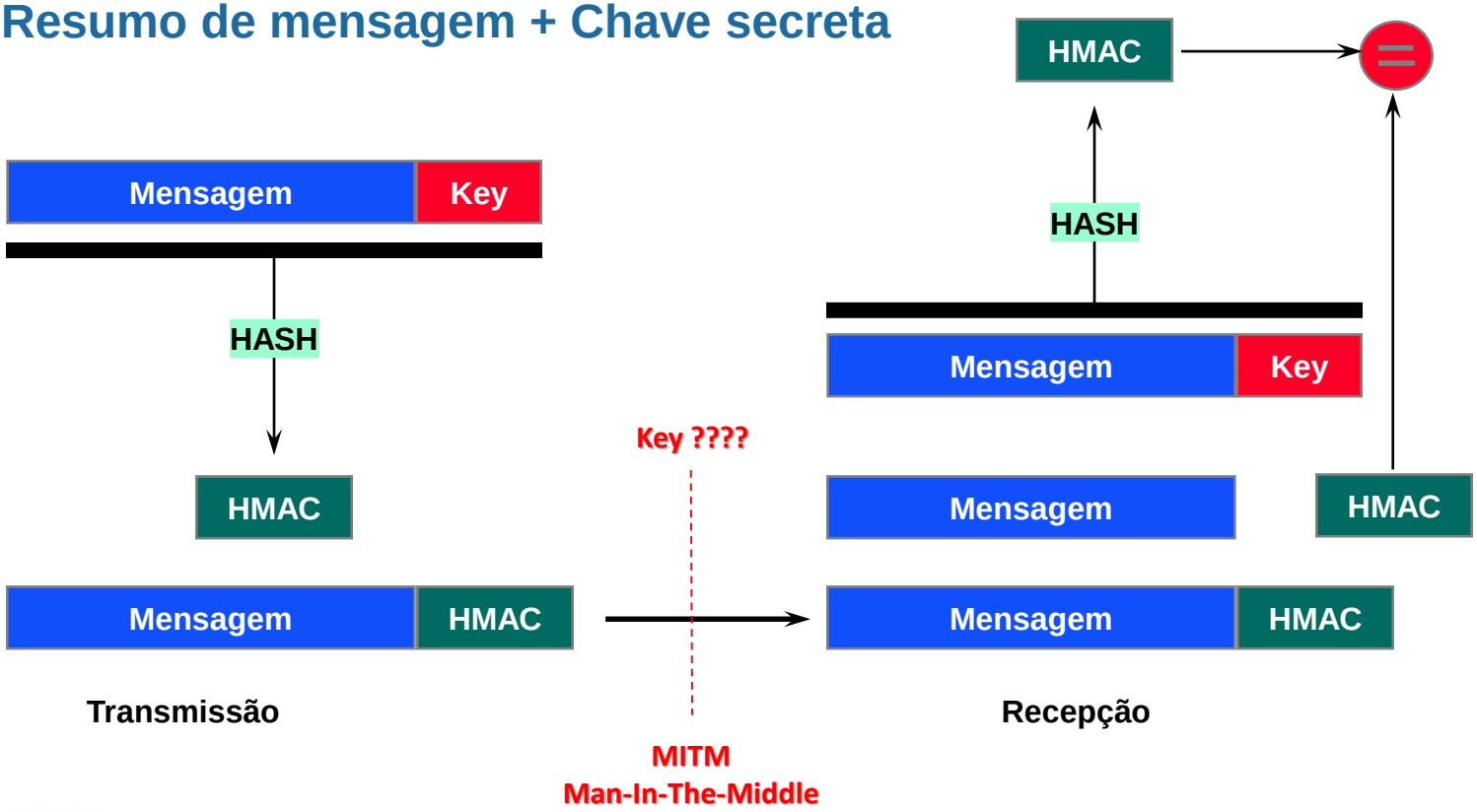
- **Resumo de mensagem + Chave secreta**



Comunicação Segura

Controle de Integridade e Autenticidade:

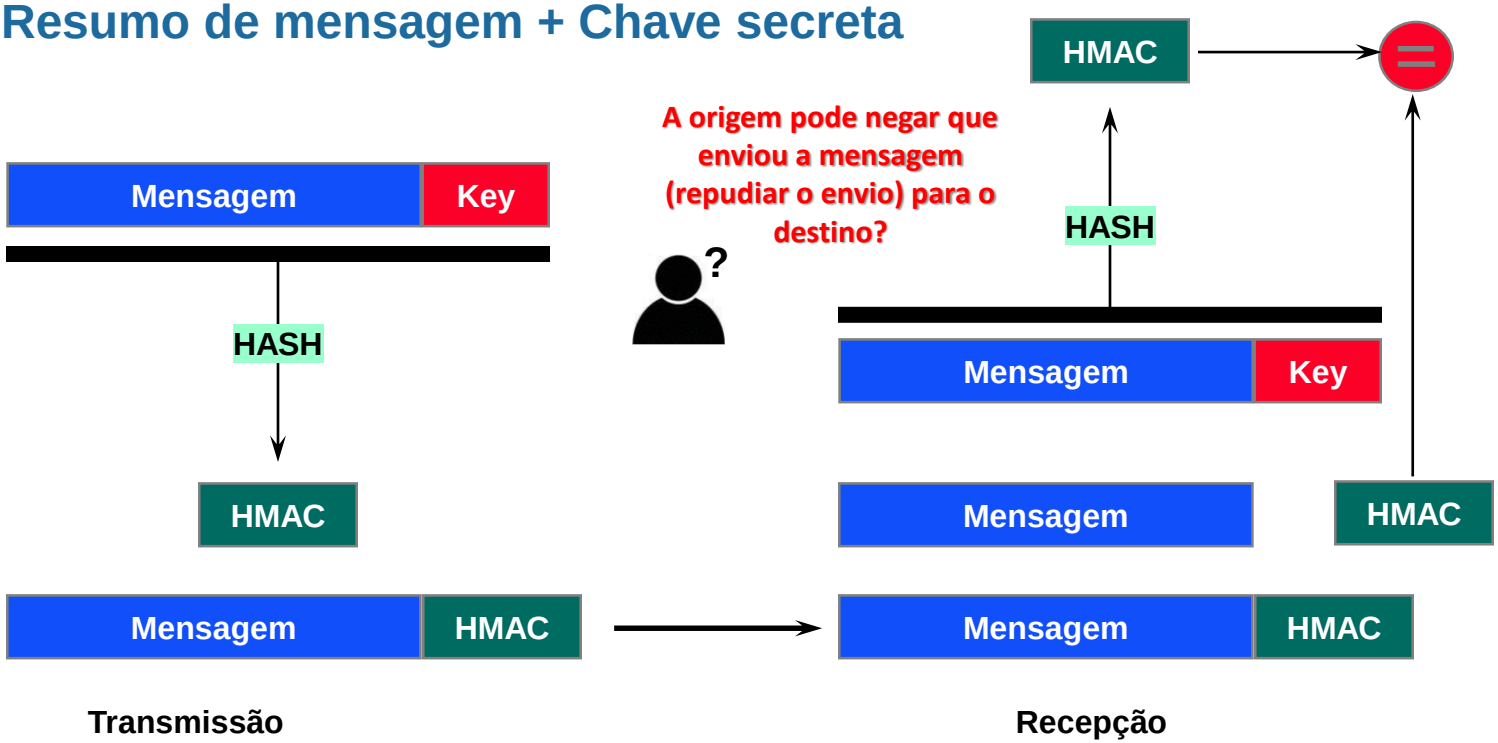
- **Resumo de mensagem + Chave secreta**



Comunicação Segura

Controle de Integridade e Autenticidade:

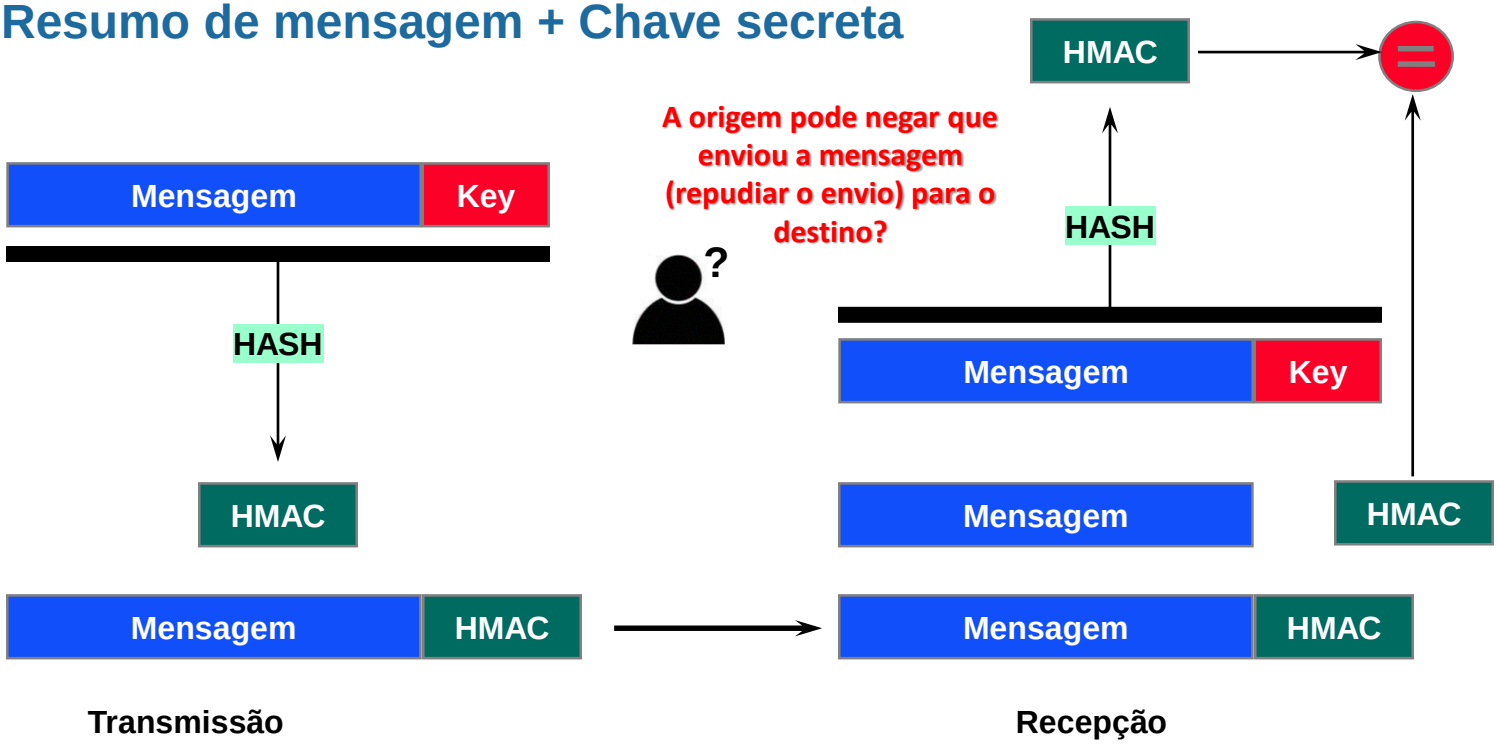
- **Resumo de mensagem + Chave secreta**



Comunicação Segura

Controle de Integridade e Autenticidade:

- **Resumo de mensagem + Chave secreta**



Sim !!!
Tanto a origem quanto o destino conhecem a chave que produz o HMAC da mensagem !!!

Comunicação Segura

Controle de Integridade e Autenticidade: Resumo de mensagem + Chave secreta

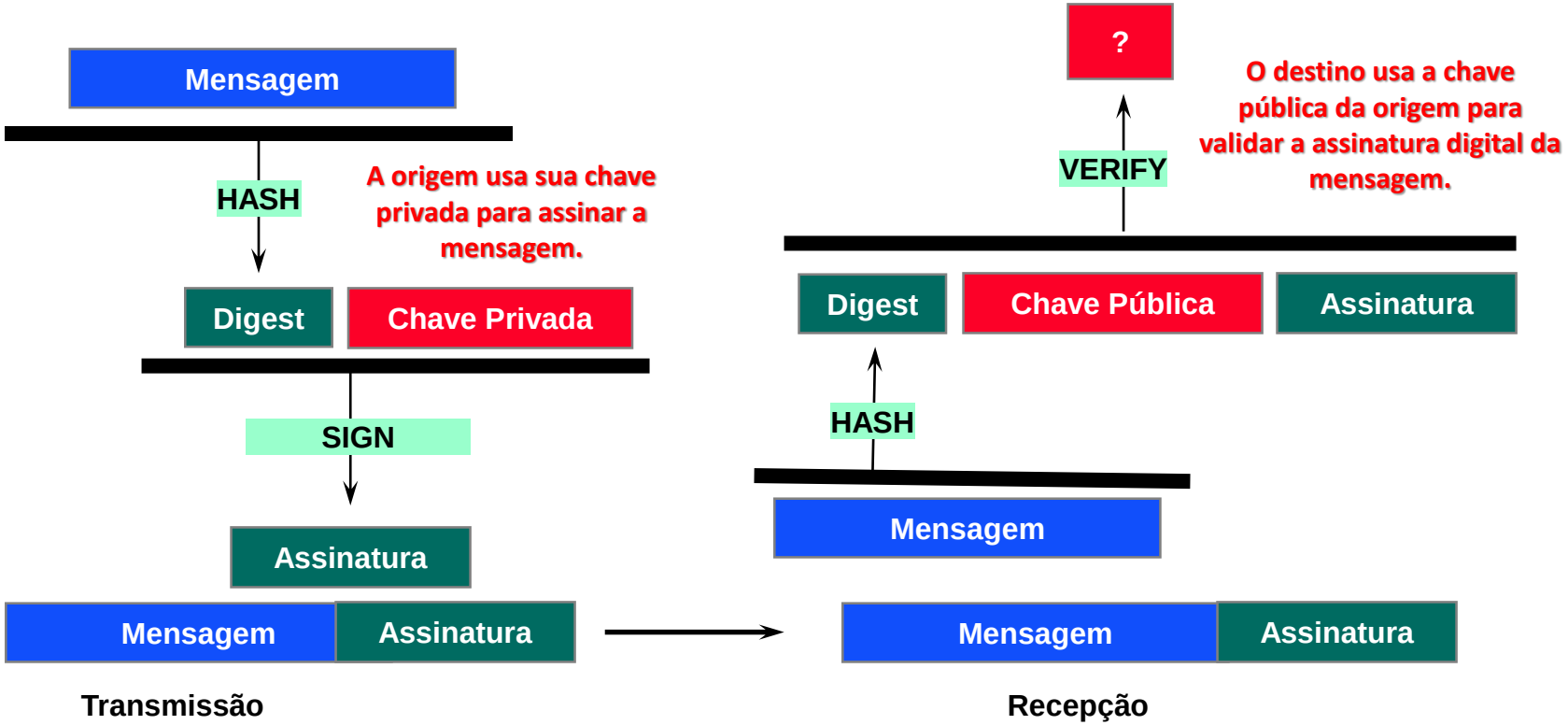
- **Ameaças:**
  - **Autenticidade fraca**
    - **Origem e destino podem gerar mensagens em nome do usuário.**
    - **Não serve para relação de compra e venda pois o comprador pode *repudiar* uma compra feita alegando que o pedido foi gerado pelo próprio vendedor, conhecedor da chave secreta.**
    - **Alguns autores argumentam que a partir de várias amostras de mensagens e resumos de mensagens, o man-in-the-middle pode tentar deduzir a chave utilizada por força bruta.**

- **Alternativa de Solução:**
  - **Assinatura Digital**
    - **Provê o controle de irretratabilidade (garantia de não-repúdio).**

Comunicação Segura

- Segurança da Informação
  Prof. Anderson O. da Silva

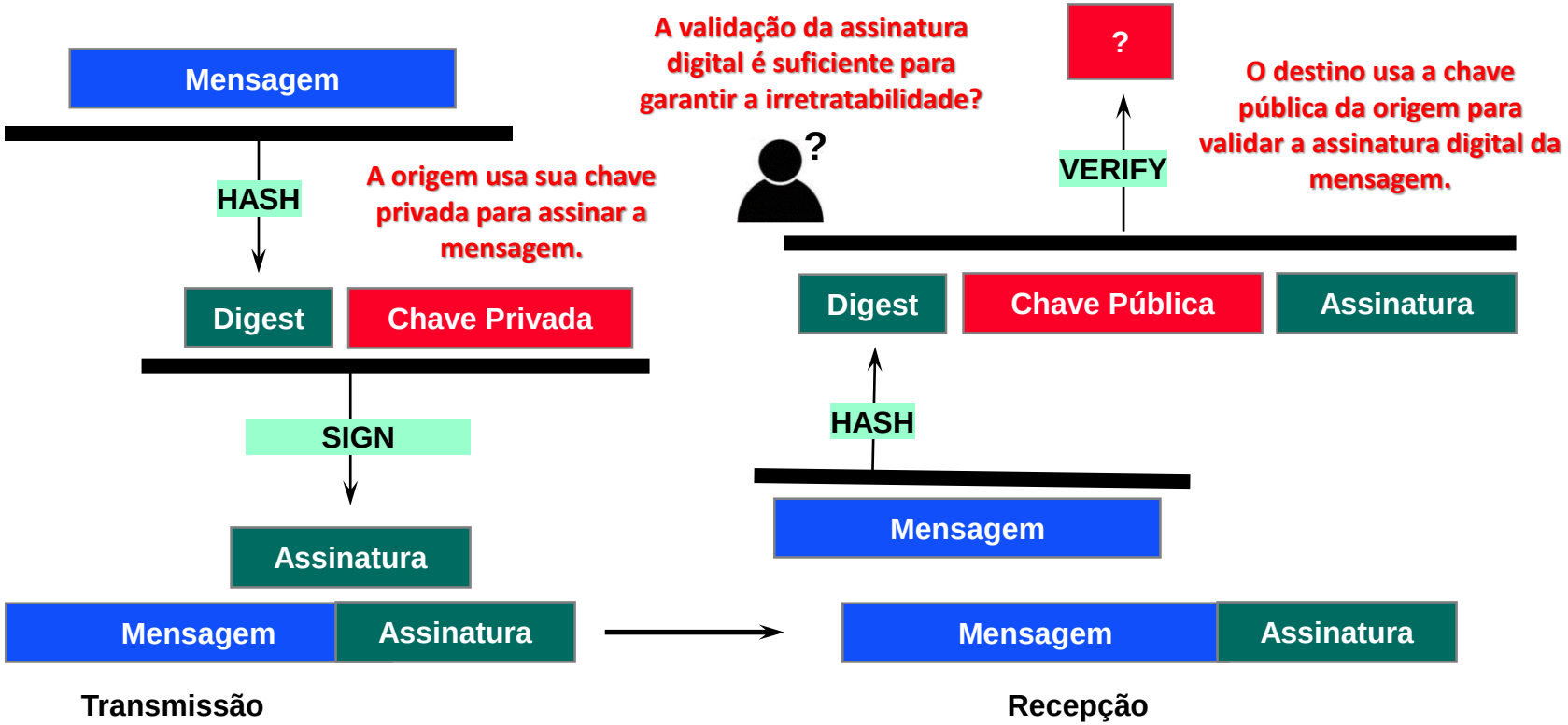
Controle de Integridade e Autenticidade: Assinatura digital (irretratabilidade)



Comunicação Segura

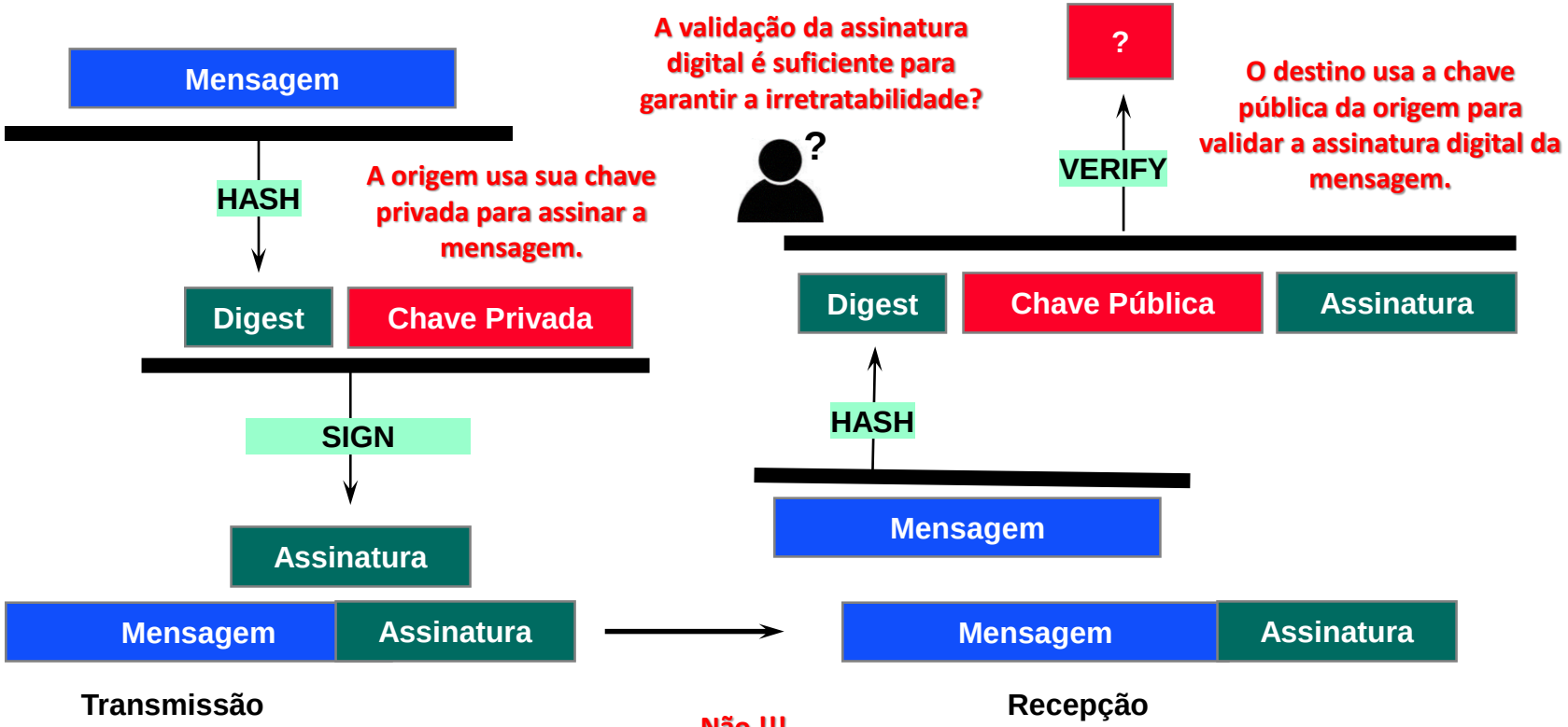
- Segurança da Informação
  Prof. Anderson O. da Silva

Controle de Integridade e Autenticidade: Assinatura digital (irretratabilidade)



Comunicação Segura

Controle de Integridade e Autenticidade: Assinatura digital (irretratabilidade)



Não !!!

A irretratabilidade é garantida apenas quando (i) a chave pública valida a assinatura digital da mensagem com sucesso; e (ii) quando podemos provar que a chave pública pertence ao signatário da mensagem !!!

Comunicação Segura

Controle de Integridade e Autenticidade: Assinatura digital (irretratabilidade)

- **Ameaça:**
  - **O man-in-the-middle pode tentar forjar a chave pública em nome de um usuário legítimo.**
- **Necessidade de garantir a integridade e a posse de uma chave pública.**
- **Alternativa de solução:**
  - **Certificado de Chave Pública ou Certificado Digital**

Comunicação Segura

Certificado Digital:

- **Conjunto de dados à prova de falsificação que atesta a associação de uma chave pública a um usuário final.**

- **Expedido e assinado por um *terceiro confiável* que confirma a identidade do usuário ou host.**
  - **Autoridade Certificadora (CA – Certification Authority).**

- **Necessidade de conhecer o certificado da CA que expediu o certificado do usuário ou host para se obter a chave pública da CA e verificar a integridade e a autenticidade do certificado do usuário ou host.**

Comunicação Segura

Certificado Digital:

- O formato do certificado mais amplamente aceito é o X.509 Versão 3 do ITU.
- Padrão X.509 foi publicado em 1988 como parte das recomendações sobre o diretório X.500.
- Revisado duas vezes: 1993 e 1995.
- RFC2459, perfil para o padrão X.509, publicado em 1999 pelo IETF.

Comunicação Segura

Certificado Digital:

- **Campos do certificado X.509 comuns a todas as versões:**
  - **Version**
    - Identifica a versão: 1, 2 ou 3.
  - **Certificate Serial Number**
    - Valor inteiro único gerado pela CA.
  - **Signature Algorithm Identifier**
    - Identificador do algoritmo utilizado para assinar o certificado.
  - **Issuer Name**
    - Identifica o nome distinto com o qual a CA cria e assina o certificado.

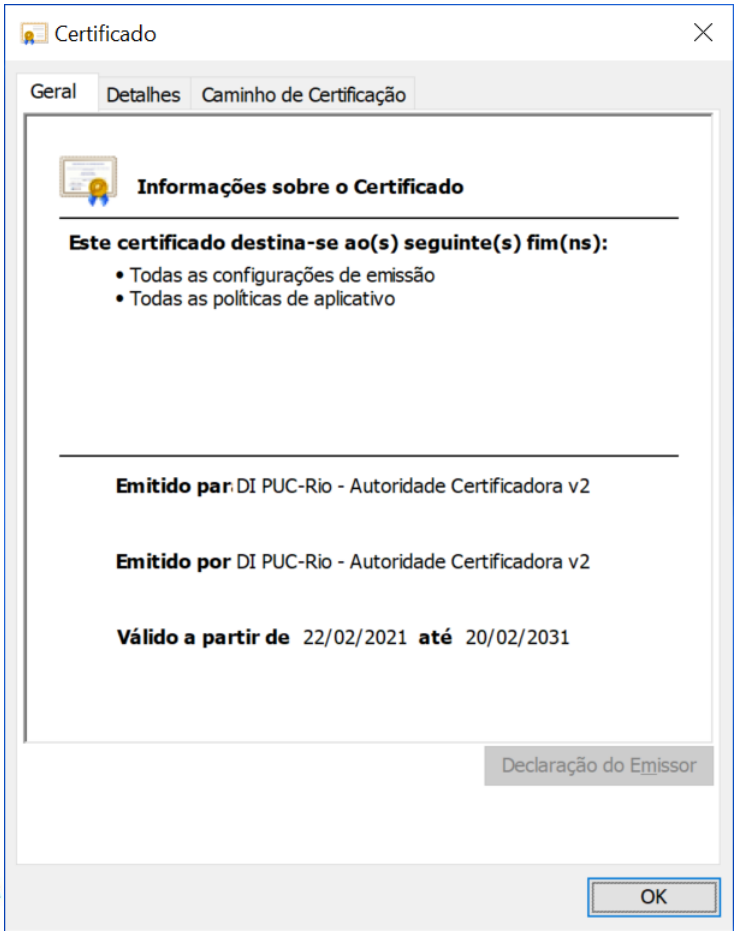
Comunicação Segura

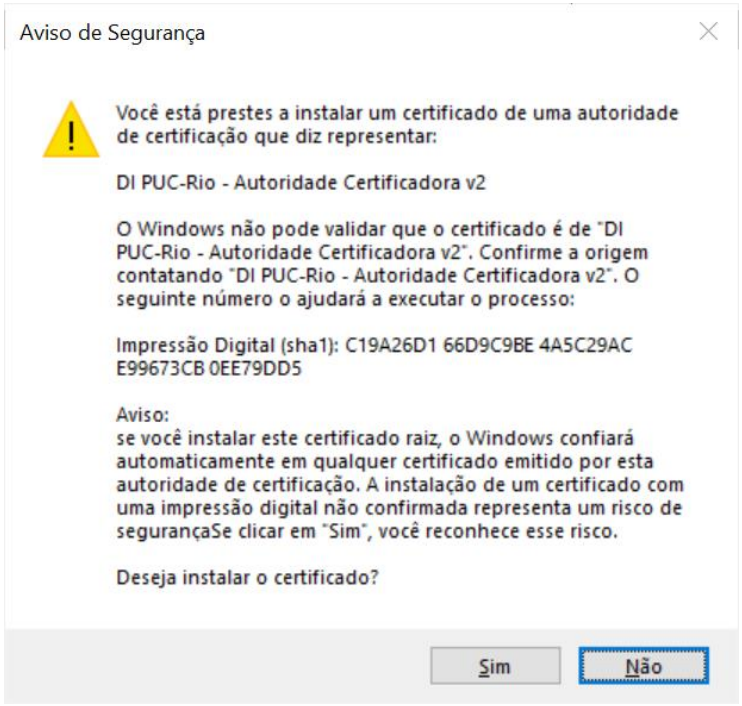
Certificado Digital:

- **Campos do certificado X.509 comuns a todas as versões:**
  - **Validity (Not before/ After)**
    - **Contém dois valores de data/hora que definem o período de validade do certificado.**
  - **Subject Name**
    - **Nome distinto da entidade final a que o certificado se refere.**
  - **Subject Public Key Information**
    - **Valor da chave pública do sujeito e o identificador do algoritmo pela qual a chave deve ser utilizada.**

Criptografia

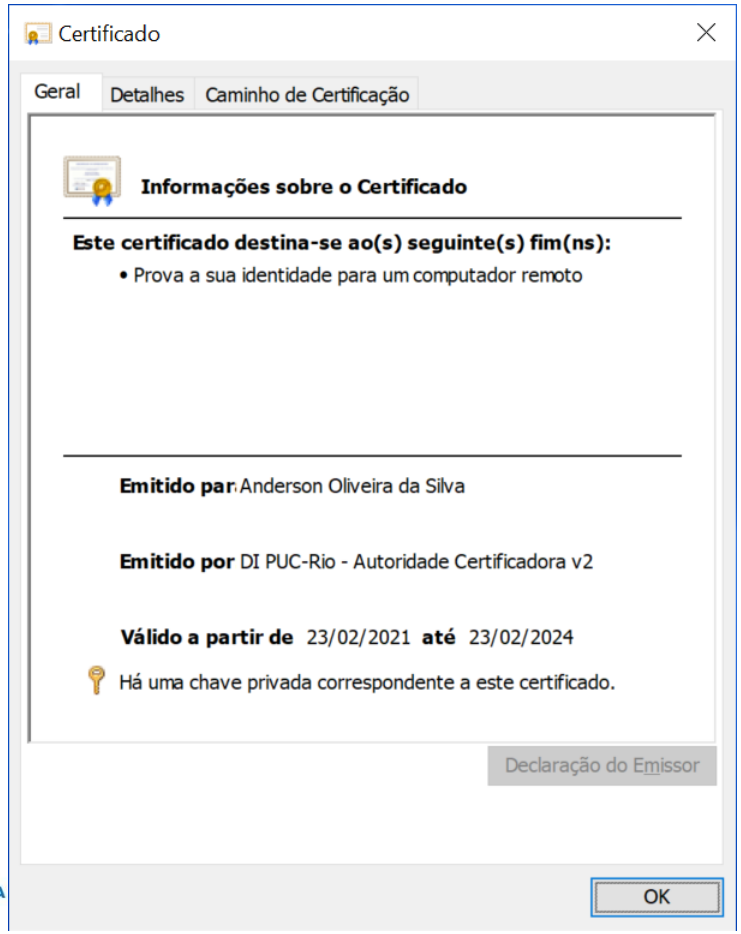
Certificado Digital: AC Privada

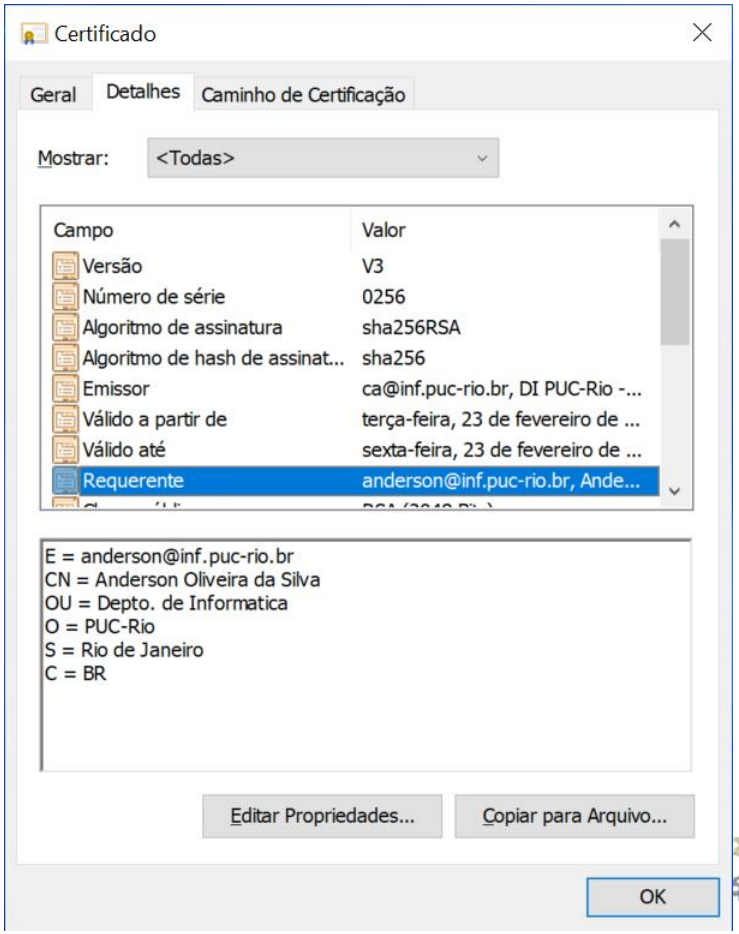




Criptografia

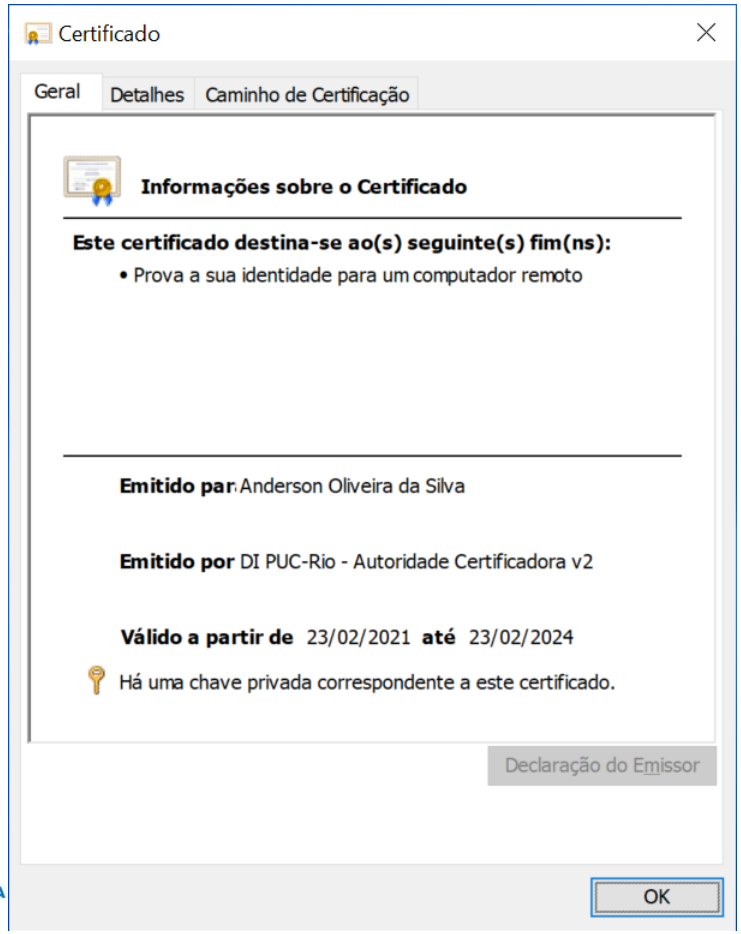
Certificado Digital: AC Privada

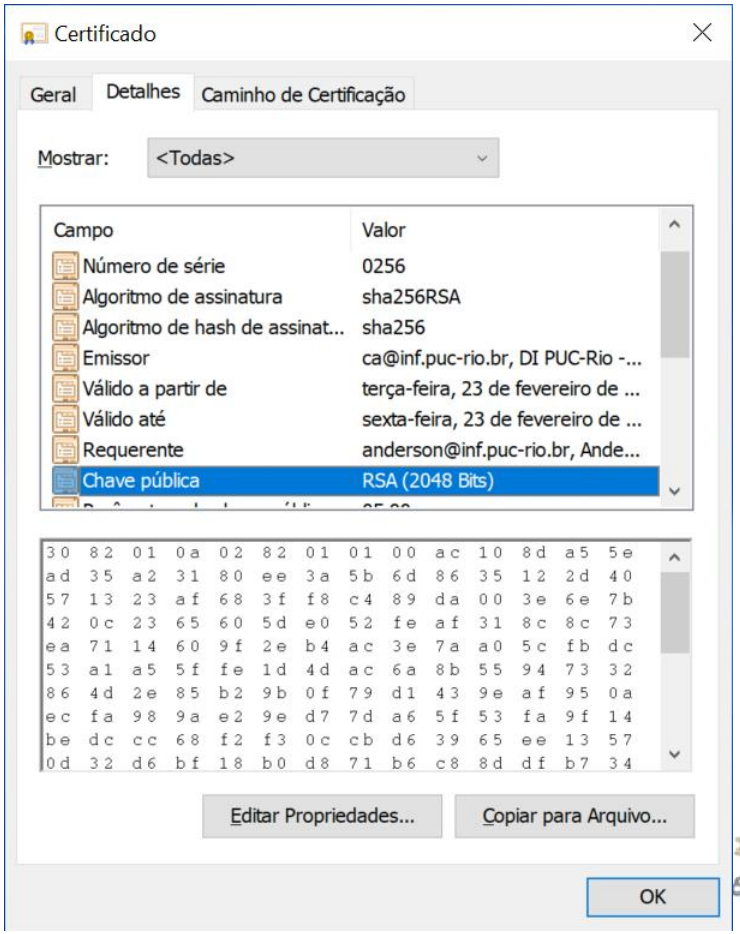




Criptografia

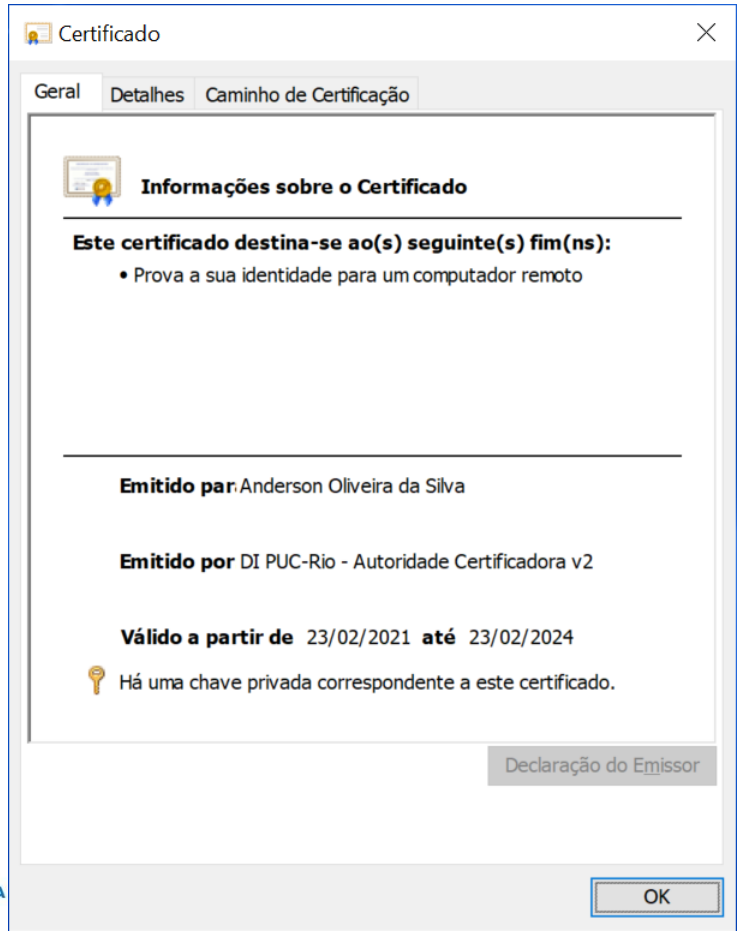
Certificado Digital: AC Privada

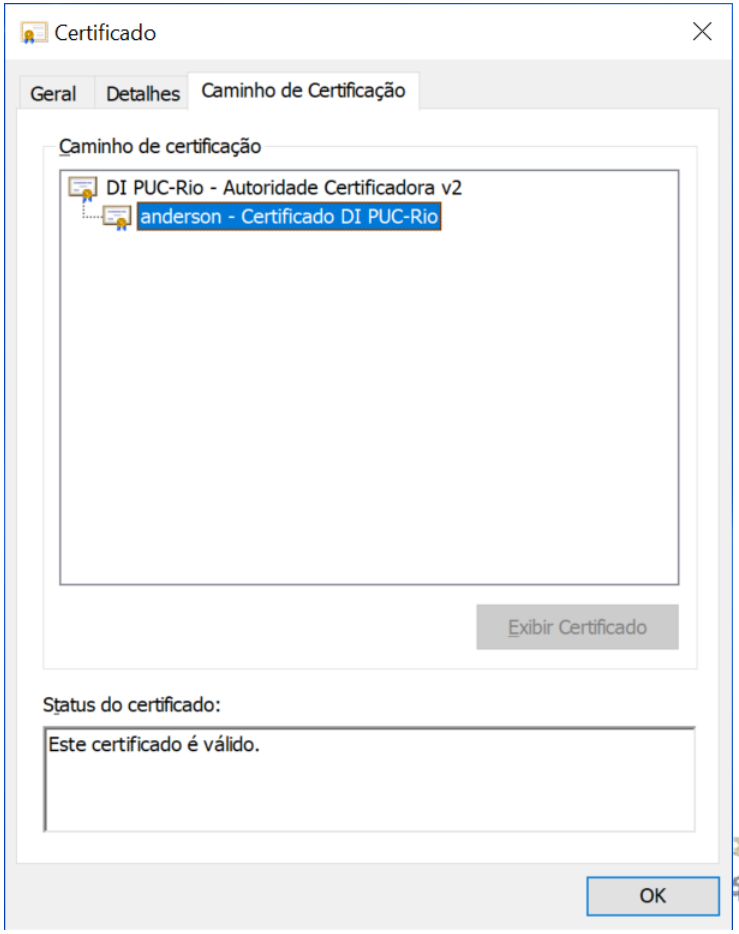




Criptografia

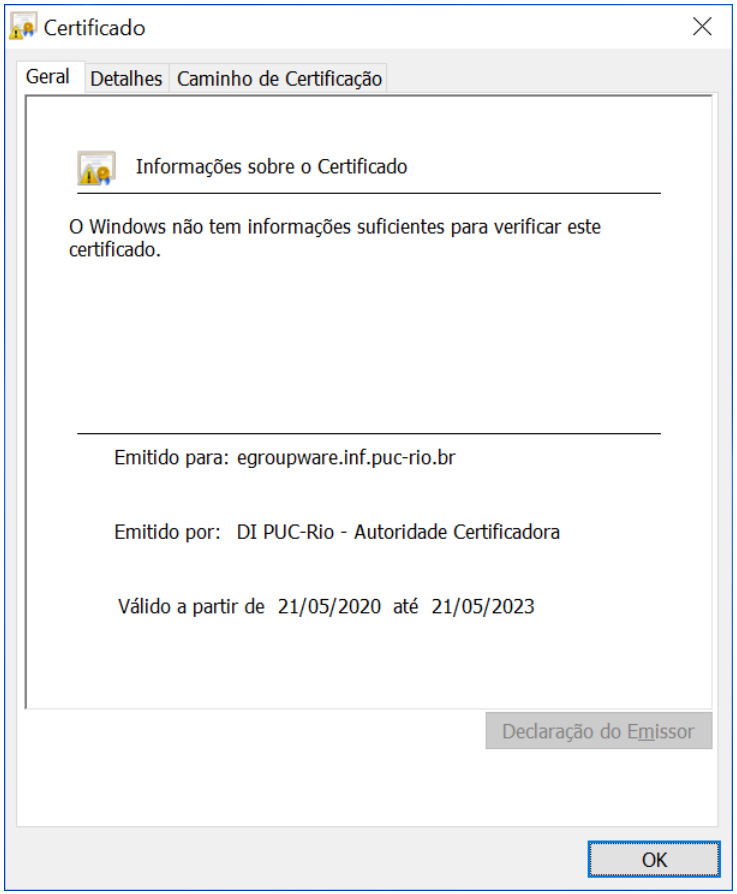
Certificado Digital: AC Privada

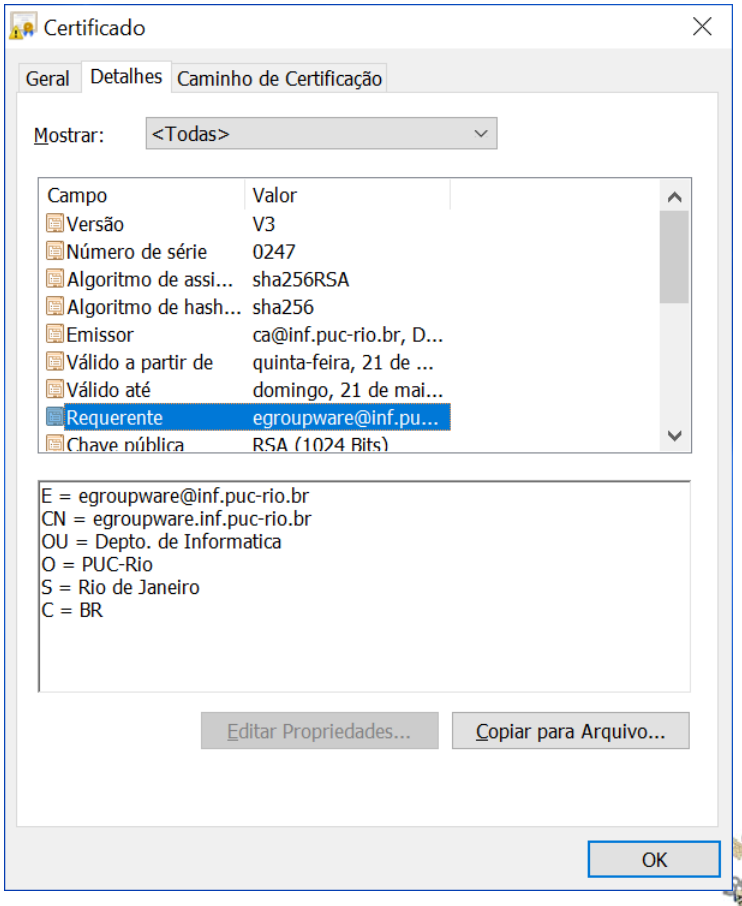




Criptografia

Certificado Digital: AC Privada





DEPARTAMENTO DE INFORMÁTICA PUC·RIO

PUC RIO

Comunicação Segura

Certificado Digital:

- **Lista de Certificados Revogados (LCR)**
  - Lista de certificados que foram revogados, normalmente pelo comprometimento da chave privada.
  - Essa lista é assinada pela autoridade certificadora que a emitiu.
  - Disponível para download nos sites da autoridades certificadoras.
  - Verificação Online do Status do Certificado
    - OCSP – Online Certificate Status Protocol – RFC 2560

Comunicação Segura

Certificado Digital:

- **Lista de Certificados Revogados (LCR)**

```
Certificate Revocation List (CRL):
        Version 2 (0x1)
        Issuer: /C=BR/ST=Rio de Janeiro/L=Rio de Janeiro/O=PUC-Rio/OU=Depto. de Informatica
                /CN=DI PUC-Rio - Autoridade Certificadora/emailAddress=ca@inf.puc-rio.br
        Last Update: Apr 11 14:42:51 2017 GMT
        Next Update: Apr 11 14:42:51 2018 GMT
        CRL extensions:
            X509v3 CRL Number: 21
Revoked Certificates:
    Serial Number: 01
        Revocation Date: Jan 21 21:44:34 2008 GMT
    Serial Number: 02
        Revocation Date: Jun 10 17:49:01 2008 GMT
.............................................
    Serial Number: 01F0
        Revocation Date: Oct 13 12:43:26 2016 GMT
    Serial Number: 01F8
        Revocation Date: Feb 14 20:03:30 2017 GMT
    Signature Algorithm: sha1WithRSAEncryption
        8c:08:e8:ff:67:b4:d7:bb:98:66:5d:3b:31:38:f8:17:f1:82:
        f3:4f:e3:ea:f6:5b:53:8d:b4:4a:df:94:55:62:9a:69:38:67:
        ..................................................
```

Comunicação Segura

Certificado Digital: Processo de Validação

- 1ª Etapa: ???
  - Cert $_{A/AC}$ {
    - número_série,
    - prazo_validade,
    - nome_emissor,
    - subject_name,
    - chave_pública,
    - URL_LCR,
    - assinatura

    }





Após receber um certificado digital, qual é a 1ª etapa de validação?

Comunicação Segura

Certificado Digital: Processo de Validação

- 1ª Etapa: Validação da Integridade e Autenticidade
  - Cert $_{A/AC}$ {
    - número_série,
    - prazo_validade,
    - nome_emissor,
    - subject_name,
    - chave_pública,
    - URL_LCR,
    - assinatura

    }



Após receber um certificado digital, qual é a 1ª etapa de validação?



Comunicação Segura

Certificado Digital: Processo de Validação

- 1ª Etapa: Validação da Integridade e Autenticidade
  - Cert $_{A/AC}$ {
    - número_série,
    - prazo_validade,
    - nome_emissor,
    - subject_name,
    - chave_pública,
    - URL_LCR,
    - assinatura

    }
  - Processo: ???



Como fazer a validação da integridade e autenticidade do certificado digital?



Comunicação Segura

Certificado Digital: Processo de Validação

- 1ª Etapa: Validação da Integridade e Autenticidade
  - Cert $_{A/AC}$ {
    - número_série,
    - prazo_validade,
    - nome_emissor,
    - subject_name,
    - chave_pública,
    - URL_LCR,
    - assinatura

    }



- Processo:
  - Obter o certificado da AC (Cert $_{AC/AC}$).

Como fazer a validação da integridade e autenticidade do certificado digital?



Comunicação Segura

Certificado Digital: Processo de Validação

- 1ª Etapa: Validação da Integridade e Autenticidade
  - Cert $_{A/AC}$ {
    - número_série,
    - prazo_validade,
    - nome_emissor,
    - subject_name,
    - chave_pública,
    - URL_LCR,
    - assinatura

    }



- Processo:
  - Obter o certificado da AC (Cert $_{AC/AC}$).
  - Usar a chave pública da AC (Kpub$_{AC}$) para validar a assinatura digital do certificado.

Como fazer a validação da integridade e autenticidade do certificado digital?



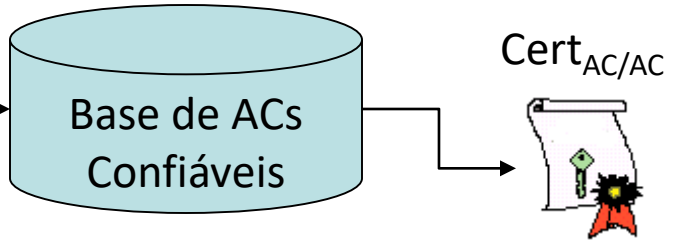
Comunicação Segura

Certificado Digital: Processo de Validação

- 1ª Etapa: Validação da Integridade e Autenticidade
  - Cert $_{A/AC}$ {
    - número_série,
    - prazo_validade,
    - nome_emissor,
    - subject_name,
    - chave_pública,
    - URL_LCR,
    - assinatura

    }
  - Processo:
    - Obter o certificado da AC (Cert $_{AC/AC}$).
      - Base Local de Autoridades Certificadoras Confiáveis





Comunicação Segura

Certificado Digital: Processo de Validação

- 1ª Etapa: Validação da Integridade e Autenticidade
  - Cert $_{A/AC}$ {
    - número_série,
    - prazo_validade,
    - nome_emissor,
    - subject_name,
    - chave_pública,
    - URL_LCR,
    - assinatura

    }



- Processo:
  - Usar a chave pública da AC ($Kpub_{AC}$) para validar a assinatura digital do certificado.
    - Comparar o digest atual (D_{atual}) do certificado digital com o digest original ($D_{original}$), resultado da decriptação da assinatura digital do certificado com a chave pública da AC ($Kpub_{AC}$).

Comunicação Segura

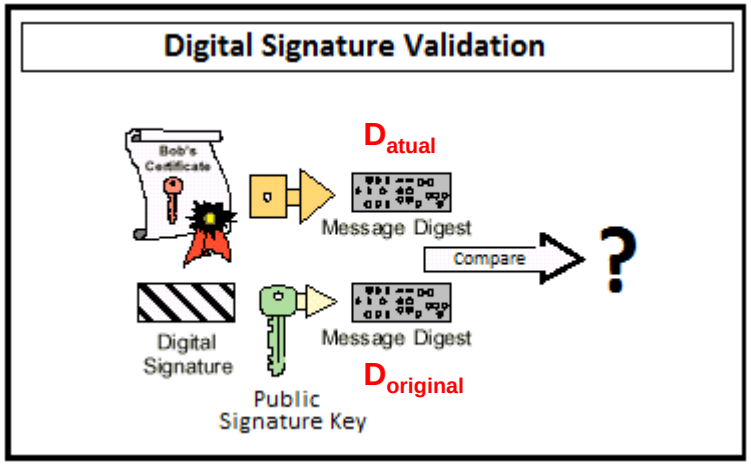
Certificado Digital: Processo de Validação

- 1ª Etapa: Validação da Integridade e Autenticidade
  - Cert $_{A/AC}$ {
    - número_série,
    - prazo_validade,
    - nome_emissor,
    - subject_name,
    - chave_pública,
    - URL_LCR,
    - assinatura

    }



- Processo:
  - Usar a chave pública da AC ($Kpub_{AC}$) para validar a assinatura digital do certificado.



Comunicação Segura

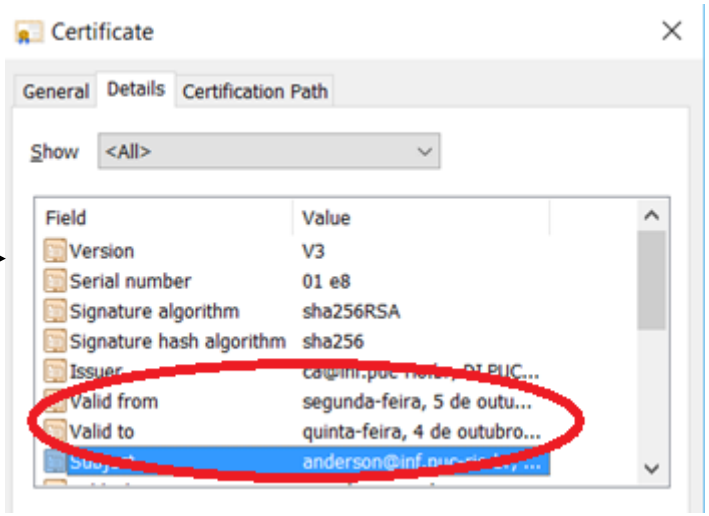
Certificado Digital: Processo de Validação

- 2ª Etapa: Validação do prazo de validade
  - Cert $_{A/AC}$ {
    - número_série,
    - prazo_validade,
    - nome_emissor,
    - subject_name,
    - chave_pública,
    - URL_LCR,
    - assinatura

    }



- Processo:
  - Verificar se a data corrente está dentro do período de validade do certificado digital.



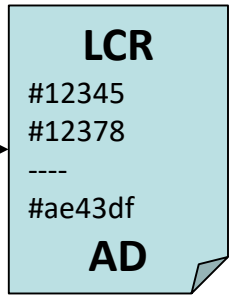
Comunicação Segura

Certificado Digital: Processo de Validação

- 3ª Etapa: Validação do estado do certificado (Válido/Revogado)
  - Cert $_{A/AC}$ {
    - número_série,
    - prazo_validade,
    - nome_emissor,
    - subject_name,
    - chave_pública,
    - URL_LCR,
    - assinatura

    }





- Processo:
  - Verificação local:
    - Baixar a LCR do site da AC.
    - Verificar a assinatura digital (AD) da LCR.
    - Verificar se o número de série do certificado consta na LCR.
  - Verificação Remota:
    - Fornecer o número de série do certificado para a AC via OCSP.
    - Verificar a resposta da AC:
      - V = Válido
      - R = Revogado

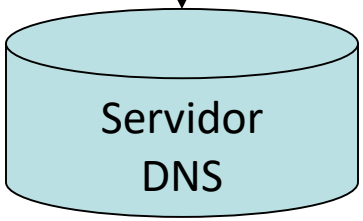
Comunicação Segura

Certificado Digital: Processo de Validação

- 4ª Etapa: Validação do Subject Name
  - Cert $_{A/AC}$ {
    - número_série,
    - prazo_validade,
    - nome_emissor,
    - subject_name,
    - chave_pública,
    - URL_LCR,
    - assinatura

    }





- Processo:
  - Verificar se os dados do subject name conferem com o fornecedor do certificado.
    - Resolução reversa do endereço IP da entidade confere com o FQDN (Fully Qualified Domain Name) que consta no certificado digital?
  - Nome e endereço eletrônico do remetente do e-mail conferem com os dados que constam no certificado digital?

Comunicação Segura

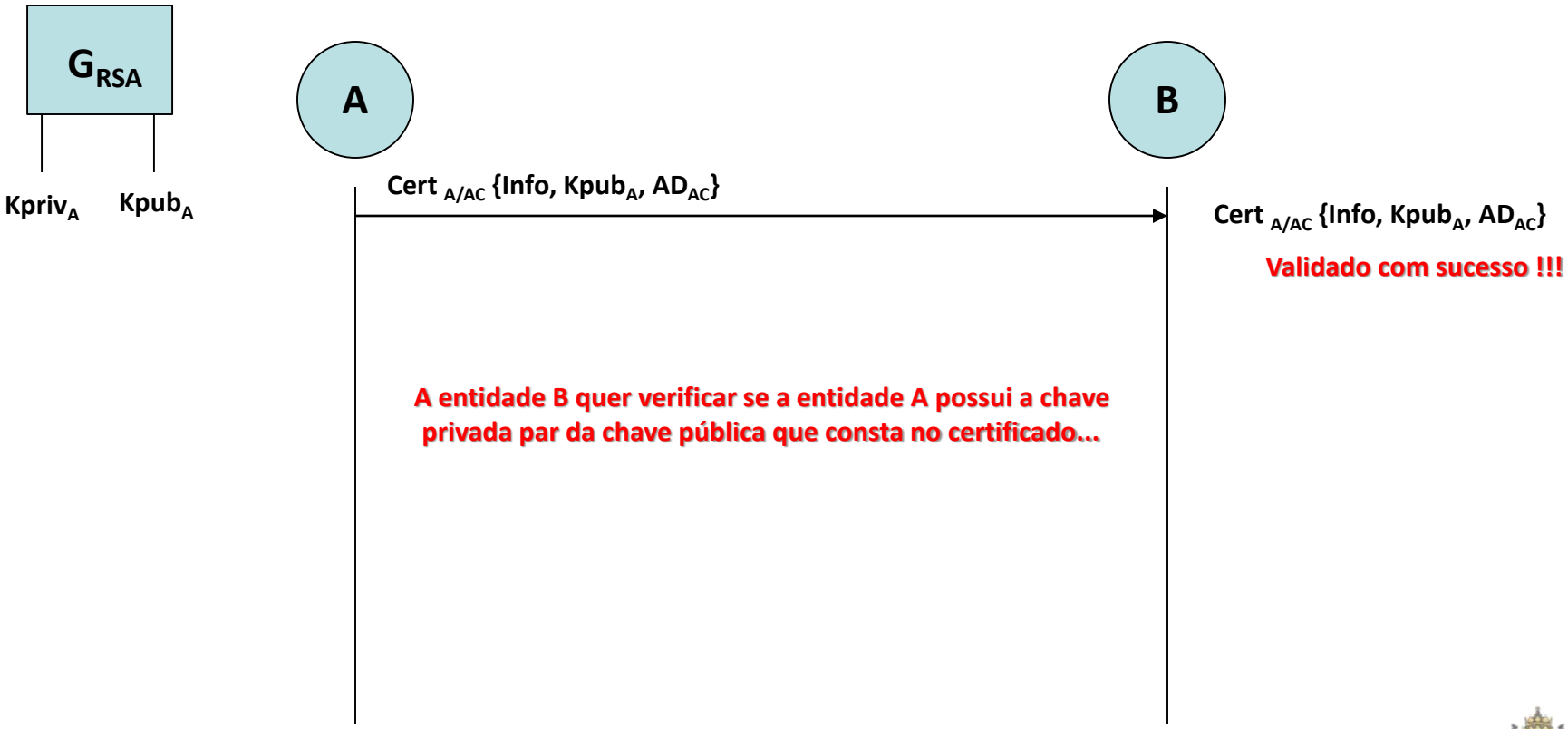
Certificado Digital: Processo de Validação da Chave Pública

- A entidade (A) que enviou o certificado digital deve provar que possui a chave privada par da chave pública que consta no certificado digital.

- A entidade (B) que recebeu o certificado digital deve fazer um desafio a entidade (A) que enviou o certificado digital.
  - A entidade (B) produz um array de bytes aleatório e envia para a entidade (A).
  - A entidade (A) assina o array de bytes e envia a sua assinatura digital para a entidade (B).
  - A entidade (B) verifica a assinatura digital com a chave pública da entidade (A) que consta no certificado digital.

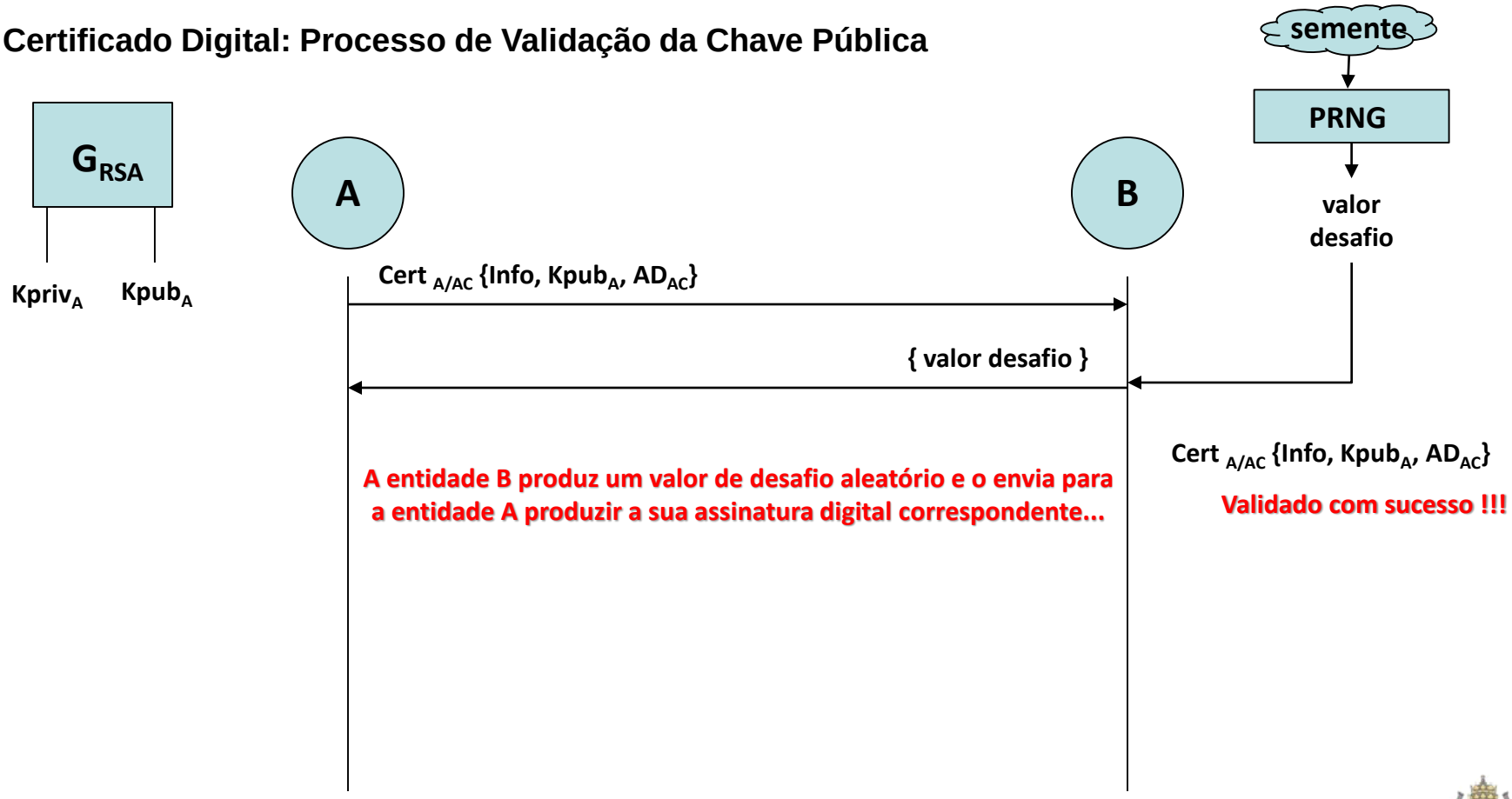
Comunicação Segura

Certificado Digital: Processo de Validação da Chave Pública



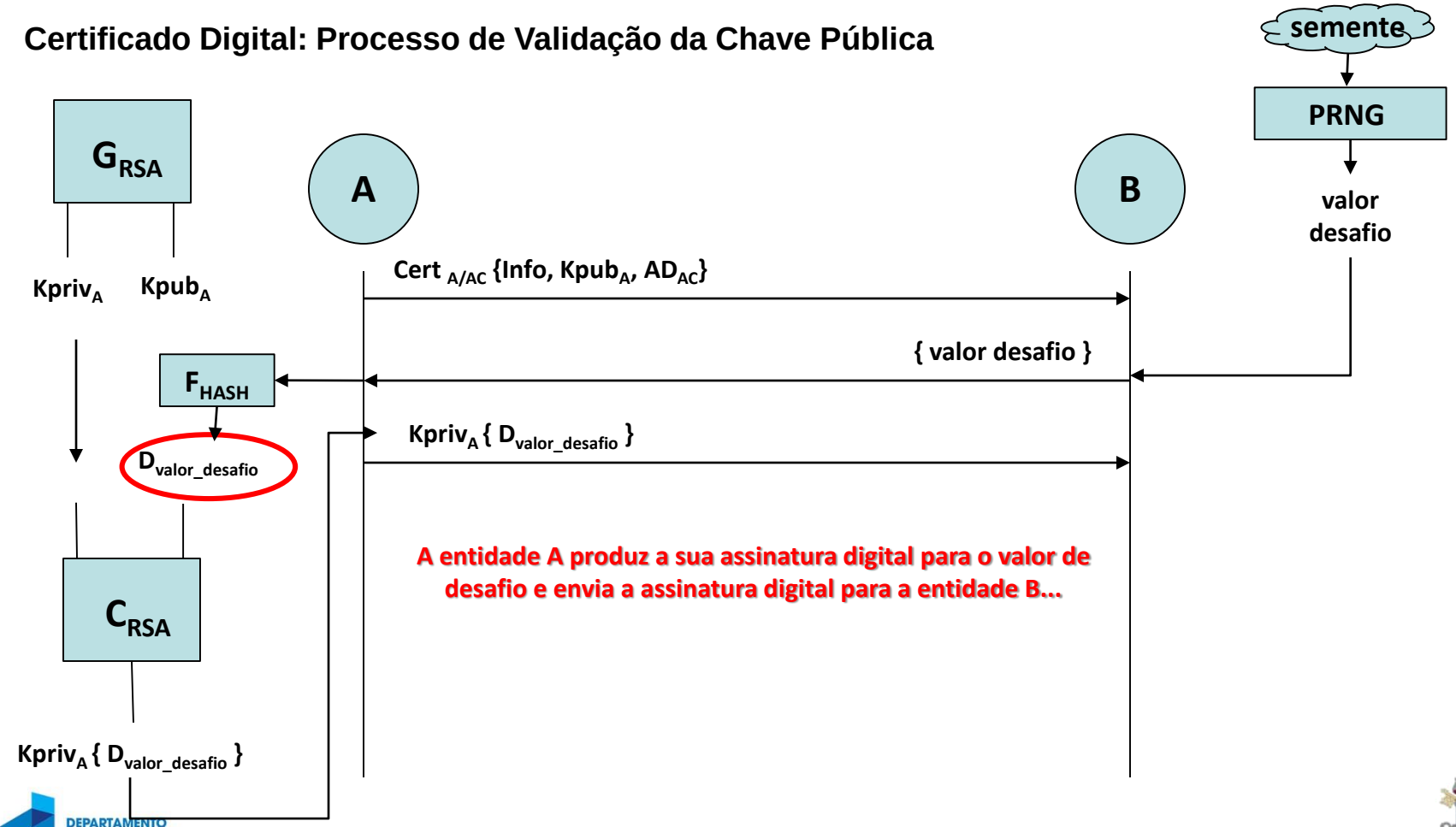
Comunicação Segura

Certificado Digital: Processo de Validação da Chave Pública



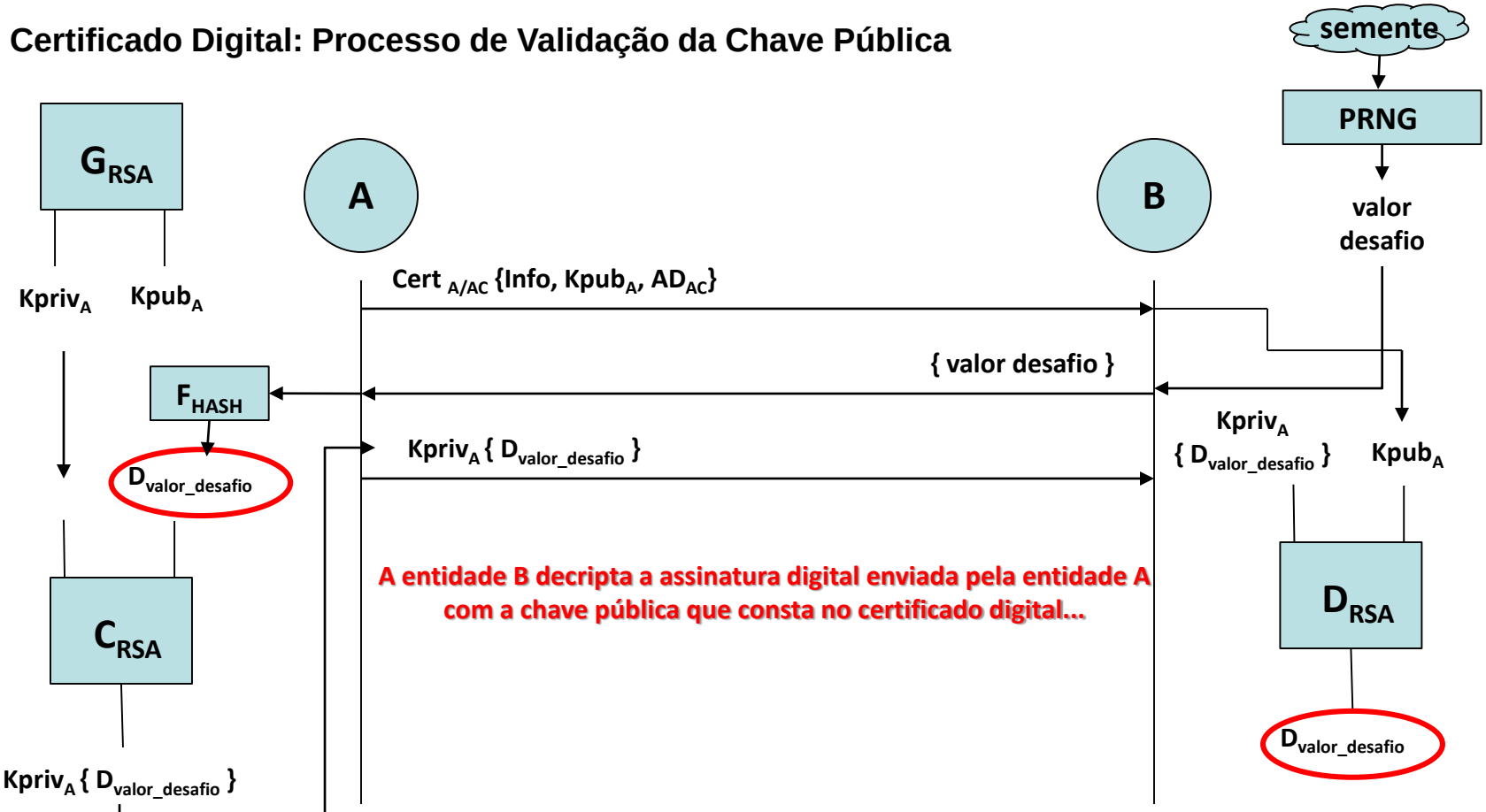
Comunicação Segura

Certificado Digital: Processo de Validação da Chave Pública



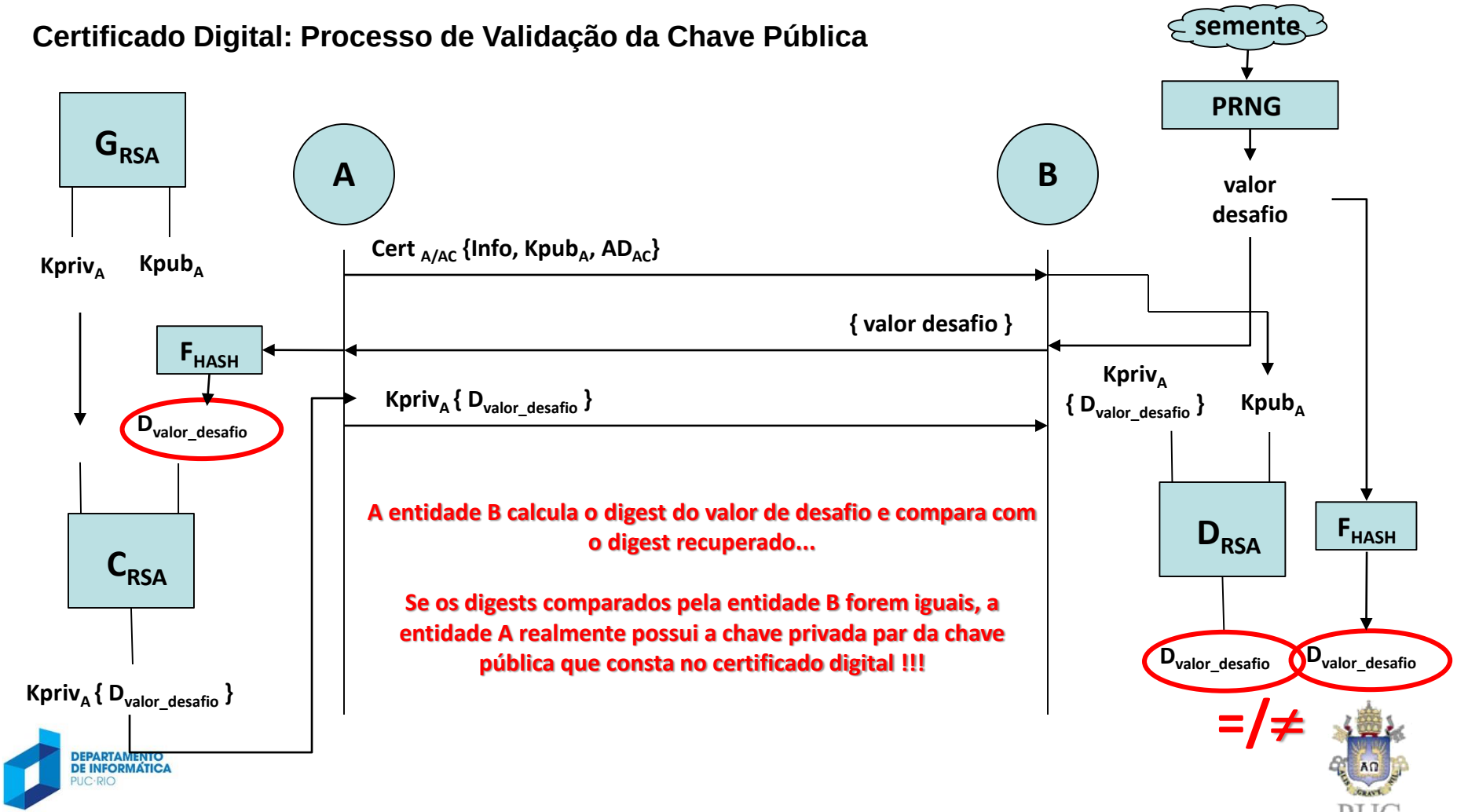
Comunicação Segura

Certificado Digital: Processo de Validação da Chave Pública



Comunicação Segura

Certificado Digital: Processo de Validação da Chave Pública



DEPARTAMENTO DE INFORMÁTICA PUC-RIO

PUC RIO

Comunicação Segura

Infraestrutura de Chaves Públicas – ICP

- Em inglês: Public Key Infrastructure – PKI
- Implementa a infraestrutura necessária para garantir a autenticidade, a integridade e a validade jurídica dos certificados digitais e das operações eletrônicas que envolvem os mesmos.
- Formada por uma Cadeia de Autoridades Certificadoras.

Comunicação Segura

ICP - Brasil:

- **Instituída pela MP 2.200-2, de 24/08/2001, criando:**
  - **Autoridade Gestora de Políticas**
  - **Cadeia de Autoridades Certificadoras**
    - **Autoridade Certificadora Raiz (AC-Raiz)**
    - **Autoridades Certificadoras**
    - **Autoridades de Registro**

ICP Brasil
O Brasil na era da certificação digital

ITI
Instituto Nacional de Tecnologia da Informação

Comunicação Segura

ICP-Brasil:

- **Autoridade Gestora de Políticas:**
  - **As declarações constantes dos documentos em forma eletrônica, produzidos com a utilização de processo de certificação disponibilizado pela ICP-Brasil, presumem-se verdadeiras em relação aos signatários, na forma do art. 131 da Lei no 3.071, de 1º de janeiro de 1916 - Código Civil.**
  - **A utilização de documento eletrônico para fins tributários atenderá, ainda, ao disposto no art. 100 da Lei no 5.172, de 25 de outubro de 1966 - Código Tributário Nacional.**

Comunicação Segura

ICP-Brasil:

- **Autoridade Certificadora Raiz (AC-Raiz)**
  - **Primeira autoridade da cadeia de certificação, executora das Políticas de Certificados e normas técnicas e operacionais aprovadas pelo Comitê Gestor da ICP-Brasil.**
  - **Compete emitir, expedir, distribuir, revogar e gerenciar os certificados das AC de nível imediatamente subseqüente ao seu, gerenciar a lista de certificados emitidos, revogados e vencidos, e executar atividades de fiscalização e auditoria das AC e das AR e dos prestadores de serviço habilitados na ICP, e exercer outras atribuições que lhe forem cometidas pela autoridade gestora de políticas.**

Comunicação Segura

ICP-Brasil:

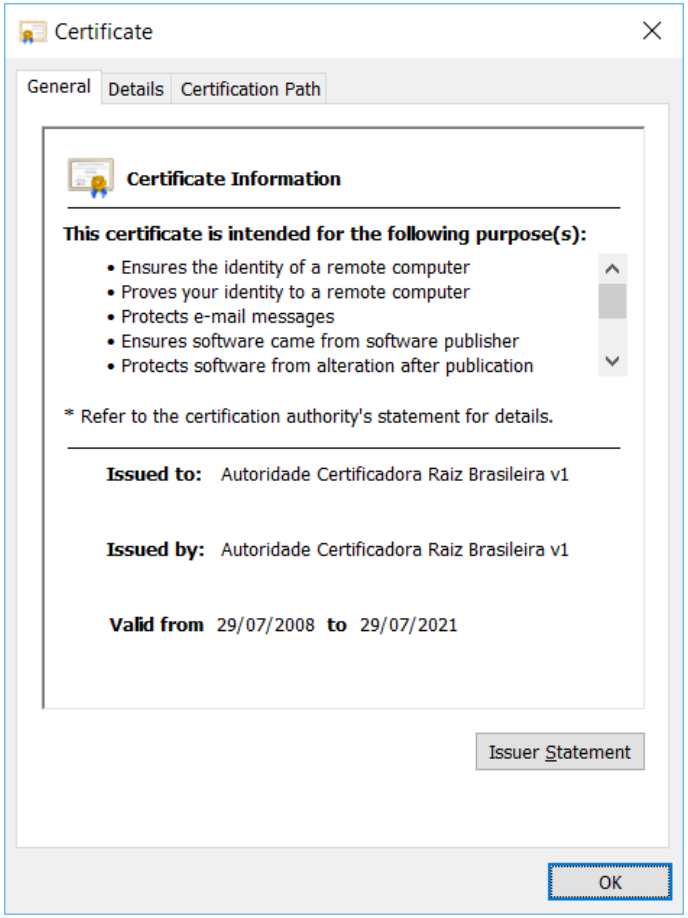
- **Autoridade Certificadora Raiz (AC-Raiz):**
  - **É vedado à AC Raiz emitir certificados para o usuário final.**
  - **Representada pelo Instituto Nacional de Tecnologia da Informação (ITI).**

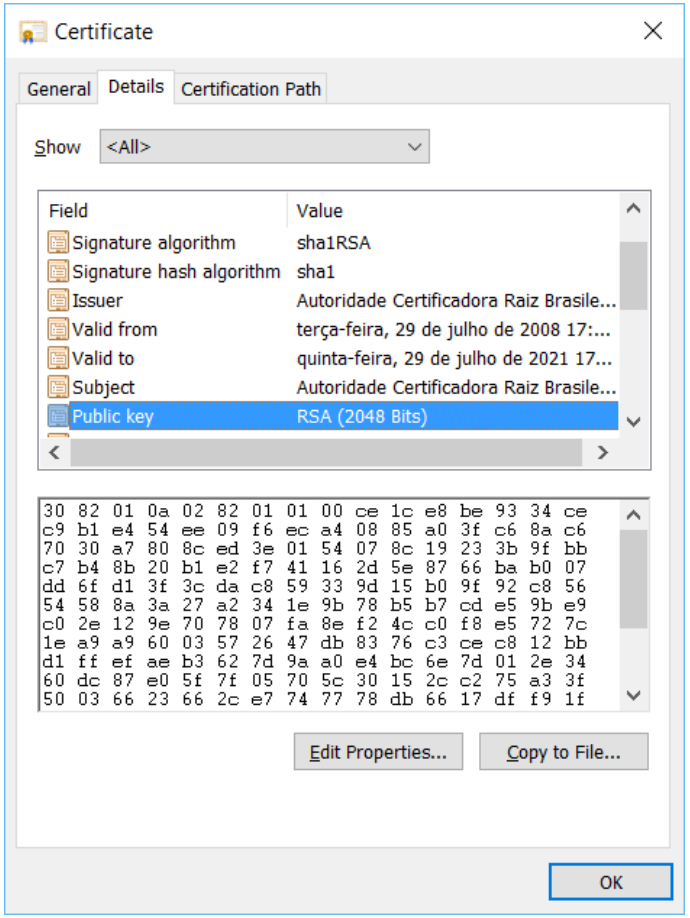
ITI
Instituto Nacional de Tecnologia da Informação

Comunicação Segura

- Segurança da Informação
  Prof. Anderson O. da Silva

ICP-Brasil:





DEPARTAMENTO DE INFORMÁTICA PUC-RIO

PUC RIO

Comunicação Segura

ICP-Brasil:

- **Autoridades Certificadoras**
  - **Entidades credenciadas a emitir certificados digitais vinculando pares de chaves criptográficas ao respectivo titular.**
  - **Compete emitir, expedir, distribuir, revogar e gerenciar os certificados, bem como colocar à disposição dos usuários listas de certificados revogados e outras informações pertinentes e manter registro de suas operações.**

Comunicação Segura

ICP-Brasil:

- **Autoridades Certificadoras Credenciadas (exemplos):**

Produto SERPRO
CAIXA
AC-Jus
serasa experian
Receita Federal
AC SINCOR
CERTISIGN A sua identidade na rede
ACPR
VALID CERTIFICADORA DIGITAL

Comunicação Segura

ICP-Brasil:

- **Autoridades de Registro**
  - **Entidades operacionalmente vinculadas à determinada AC.**
  - **Compete identificar e cadastrar usuários na presença destes, encaminhar solicitações de certificados às AC e manter registros de suas operações.**

Comunicação Segura

ICP-Brasil:

- **Tipos de Certificados:**
  - **Certificados de Assinatura (Tipo A)**
    - **Utilizados em aplicações como confirmação de identidade na Web, correio eletrônico, transações on-line, redes privadas virtuais, transações eletrônicas, informações eletrônicas, cifração de chaves de sessão e assinatura de documentos eletrônicos com verificação da integridade de suas informações.**
  - **Certificados de Sigilo (Tipo S)**
    - **Utilizados em aplicações como cifração de documentos, bases de dados, mensagens e outras informações eletrônicas, com a finalidade de garantir o seu sigilo.**

Comunicação Segura

ICP-Brasil:

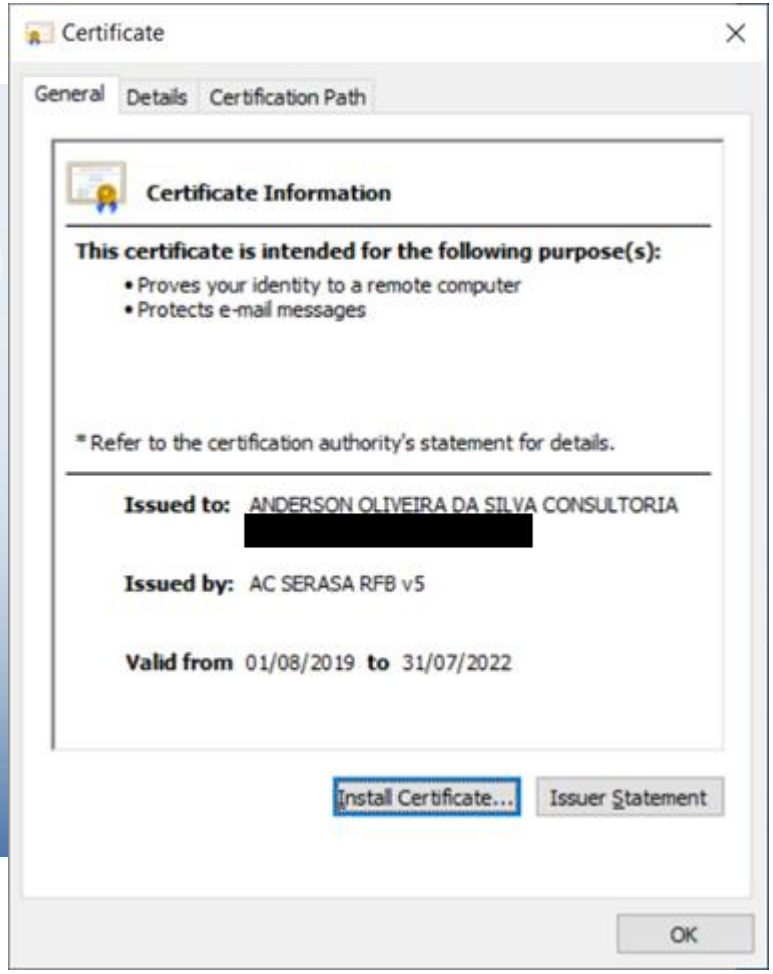
Tipo de Certificado	Chave Criptográfica			Validade máxima do certificado (anos)	Frequência de emissão de LCR (horas)	Tempo limite para revogação (horas)
	Tamanho (bits)	Processo de Geração	Mídia Armazenadora			
A1 e S1	RSA 1024 (V0 e V1), 2048 (V2) ECDSA 256	Software	Repositório protegido por senha e/ou identificação biométrica, cifrado por software na forma do item 6.1.1	1	6	12
A2 e S2	RSA 1024 (V0 e V1), 2048 (V2) ECDSA 256	Software	Cartão Inteligente ou Token, ambos sem capacidade de geração de chave e protegidos por senha e/ou identificação biométrica	2	6	12
A3 e S3	RSA 1024 (V0 e V1), 2048 (V2) ECDSA 256	Hardware	Hardware criptográfico, homologado junto à ICP-Brasil ou com certificação INMETRO.	5	6	12
A4 e S4	RSA 2048 (V0 e V1), 4096 (V2)	Hardware	Hardware criptográfico, homologado junto à ICP-Brasil ou com certificação INMETRO.	6	6	12
	ECDSA 512	Hardware	Hardware criptográfico, homologado junto à ICP-Brasil ou com certificação INMETRO.	11	6	12

Fonte: ITI - RESOLUÇÃO Nº 123, DE 06 DE JULHO DE 2017.

Criptografia

ICP-Brasil: e-CNPJ Serasa Experian

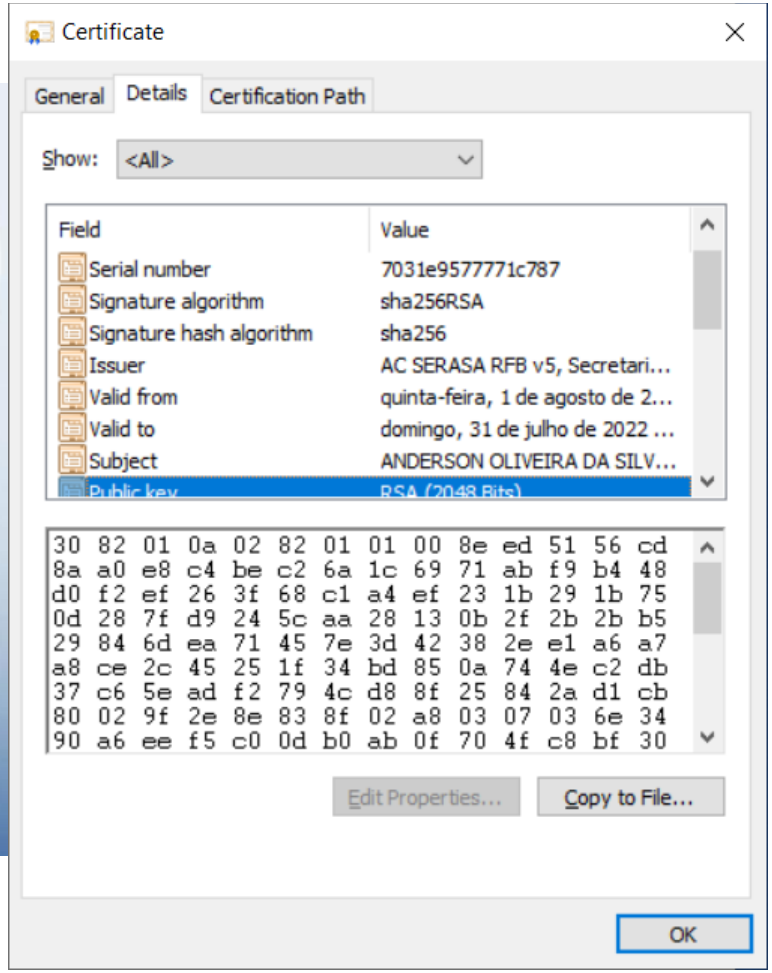




Criptografia

ICP-Brasil: e-CNPJ Serasa Experian

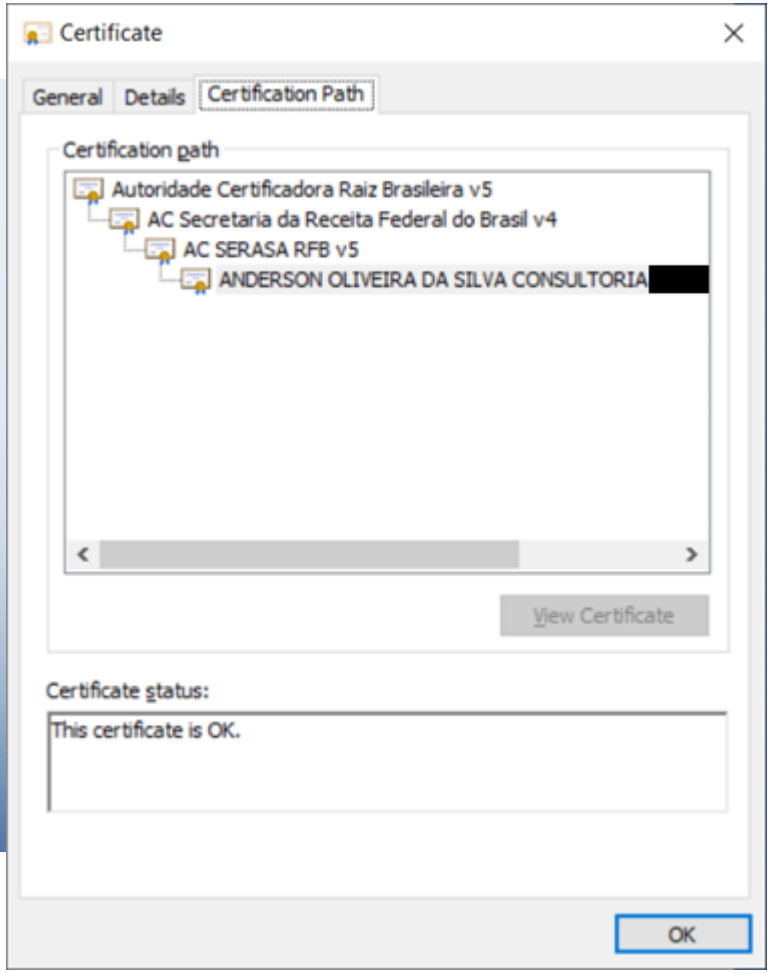




Criptografia

ICP-Brasil: e-CNPJ Serasa Experian





Criptografia

ICP-Brasil: ID OAB-RJ

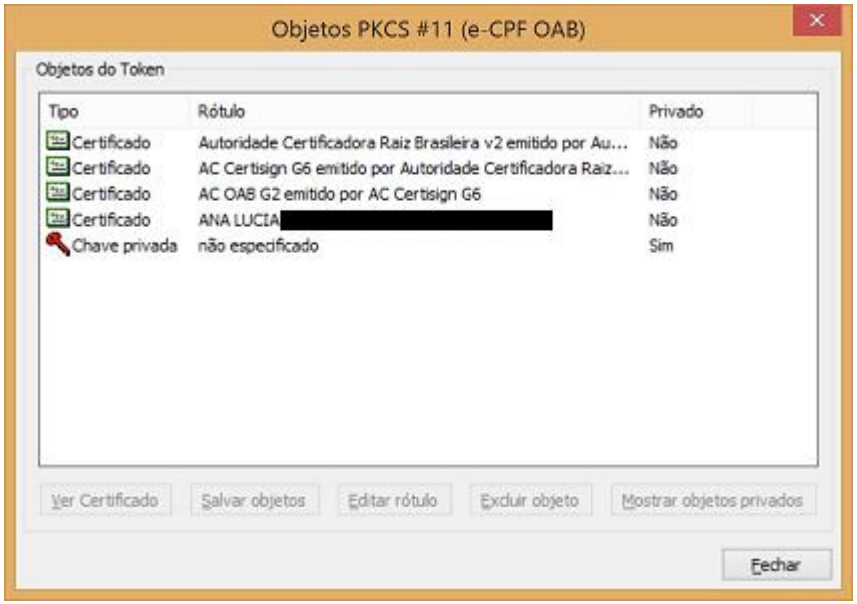


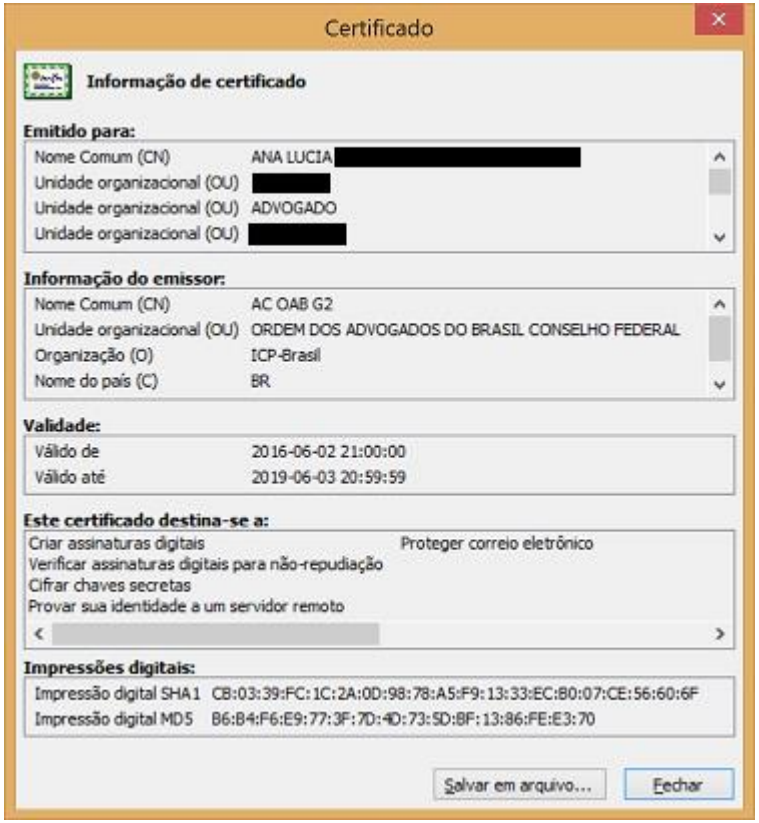




Criptografia

ICP-Brasil: ID OAB-RJ





DEPARTAMENTO DE INFORMÁTICA PUC-RIO

PUC RIO

Comunicação Segura

ICP-Brasil:

- **Tipos de Certificados:**
  - **Certificados para Cupom Fiscal Eletrônico (Tipo CF-e-SAT)**
    - **Esse tipo de certificado digital é utilizado nas assinaturas dos Cupons Fiscais Eletrônicos. O par de chaves que permite a assinatura digital deve ser armazenado em hardware criptográfico.**
  - **Certificados para Objetos Metrológicos (Tipo OM-BR)**
    - **Esse tipo de certificado é utilizado em objetos metrológicos, como os utilizados para conferir a medição em bombas de combustível e relógios medidores de água e energia elétrica, por exemplo. Esses objetos são regulados pelo INMETRO.**
    - **O par de chaves que permite a assinatura digital deve ser armazenado em hardware criptográfico, que deve ser homologado pela ICP-Brasil ou INMETRO.**

Fonte: Certificado Digital – Saiba mais – Gov.BR
URL: https://aquitemcd.iti.gov.br/certificado-digital/

Comunicação Segura

ICP-Brasil:

- **Tipos de Certificados:**
  - **Certificados para Carimbo de Tempo (Tipo T)**
    - **Com o carimbo do tempo é possível garantir a existência de um arquivo em determinada data e hora, conferindo a *irretroatividade* do documento.**
      - **A irretroatividade oferece proteção para que ações presentes não tenham efeito sobre fatos passados e visa a impedir a marcação de uma informação do presente ou a modificação da ordem cronológica de eventos do passado com o uso de um carimbo de tempo do passado criado no presente, como por exemplo, produzir um documento com data retroativa.**
    - **A Autoridade Certificadora de Tempo – ACT emite o carimbo do tempo, que confere os atributos de ano, mês, dia, hora, minuto e segundo, associados a uma assinatura digital.**
    - **As ACTs consomem os certificados digitais T3 e T4, que são instalados nos equipamentos emissores do carimbo do tempo. Esses certificados são emitidos pela ICP-Brasil para chancelar os equipamentos carimbadores das ACTs credenciadas pela infraestrutura.**

Fonte: Certificado Digital – Saiba mais – Gov.BR
URL: https://aquitemcd.iti.gov.br/certificado-digital/

Comunicação Segura

ICP-Brasil:

Tipo de Certificado	Chave Criptográfica			Validade máxima do certificado (anos)	Frequência de emissão de LCR (horas)	Tempo limite para revogação (horas)
	Tamanho (bits)	Processo de Geração	Mídia Armazenadora			
T3	RSA 1024 (V0 e V1), 2048 (V2) ECDSA 256	Hardware	Hardware criptográfico, homologado junto à ICP-Brasil ou com certificação INMETRO.	5	6	12
T4	RSA 2048 (V0 e V1), 4096 (V2)	Hardware	Hardware criptográfico,homologado junto à ICP-Brasil ou com certificação INMETRO.	6	6	12
	ECDSA 512	Hardware	Hardware criptográfico,homologado junto à ICP-Brasil ou com certificação INMETRO.	11	6	12
A CF-e-SAT	RSA 2048	Hardware	Hardware criptográfico	5	6	12

Fonte: ITI - RESOLUÇÃO Nº 123, DE 06 DE JULHO DE 2017.

Comunicação Segura

ICP-Brasil:

- **Autoridade Certificadora de Tempo – ACT:**
  - **No âmbito da ICP-Brasil, as operações ACTs devem ser devidamente documentadas e periodicamente auditadas pela própria AC-Raiz da ICP-Brasil.**
  - **Os relógios dos Servidores de Carimbo de Tempo (SCTs) devem ser auditados e sincronizados por Sistemas de Auditoria e Sincronismo (SASs).**
  - **A utilização de carimbos do tempo no âmbito a ICP-Brasil é facultativa.**
    - **Documentos eletrônicos assinados digitalmente com chave privada correspondente a certificados ICP-Brasil são válidos com ou sem o carimbo do tempo.**

Fonte: ICP-Brasil. Visão Geral do Sistema de Carimbos do Tempo na ICP-Brasil. DOC-ICP-11 – versão 1.0. ICP-Brasil. Dezembro, 2008.

Comunicação Segura

ICP-Brasil:

- **Autoridade Certificadora de Tempo – ACT:**
  - **Como requisitos mínimos para a operação das ACTs, a ICP-Brasil adotou as seguintes especificações técnicas:**
    - **RFC 3628 (Policy Requirements for Time-Stamping Authorities – TSAs), IETF.**
    - **RFC 3161 (Internet X.509 Public Key Infrastructure Time-Stamp Protocol – TSP), IETF.**
    - **TS 101861 (Electronic Signatures and Infrastructures – ESI: Time stamping profile), ETSI.**

Fonte: ICP-Brasil. Visão Geral do Sistema de Carimbos do Tempo na ICP-Brasil. DOC-ICP-11 – versão 1.0. ICP-Brasil. Dezembro, 2008.

Comunicação Segura

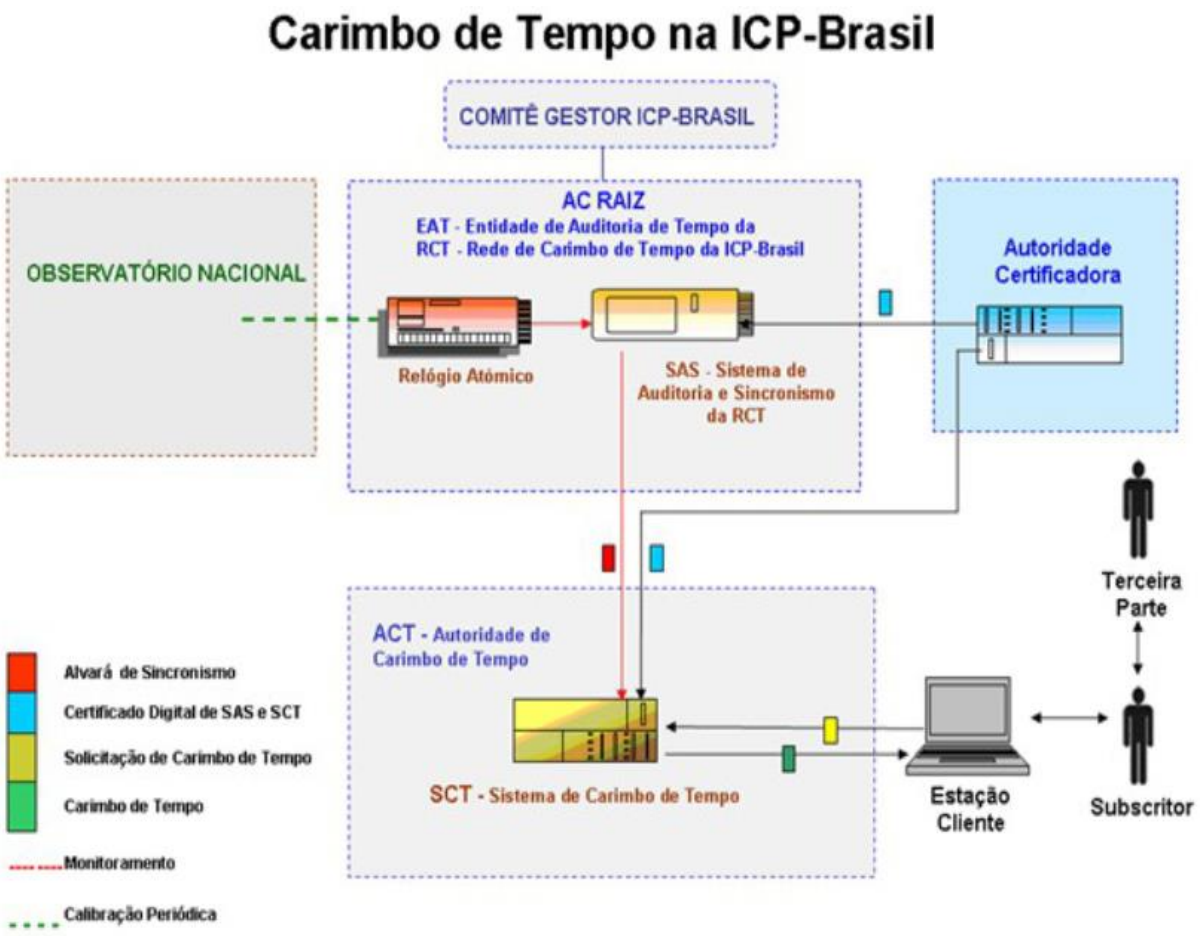
ICP-Brasil:

- **Autoridade Certificadora de Tempo – ACT:**
  - **O *protocolo de carimbo de tempo* (RFC 3161) especifica como um aplicativo cliente solicita e recebe um carimbo de tempo de um servidor de uma ACT para uma unidade de dados do cliente.**
  - **O protocolo descreve os formatos da solicitação enviada a uma autoridade de carimbo do tempo e da resposta que é retornada contendo um carimbo do tempo.**
  - **A autoridade cria o carimbo de tempo concatenando um valor de hash da unidade de dados de entrada com um valor da hora UTC e outros parâmetros (número de série, Nome Distinto (DN) da autoridade, entre outros), e em seguida, assinando esse conjunto de dados com a chave privada da autoridade de acordo com o RFC 5652 (Cryptographic Message Syntax – CMS).**

Fonte: ICP-Brasil. Visão Geral do Sistema de Carimbos do Tempo na ICP-Brasil. DOC-ICP-11 – versão 1.0. ICP-Brasil. Dezembro, 2008.

Comunicação Segura

ICP-Brasil:

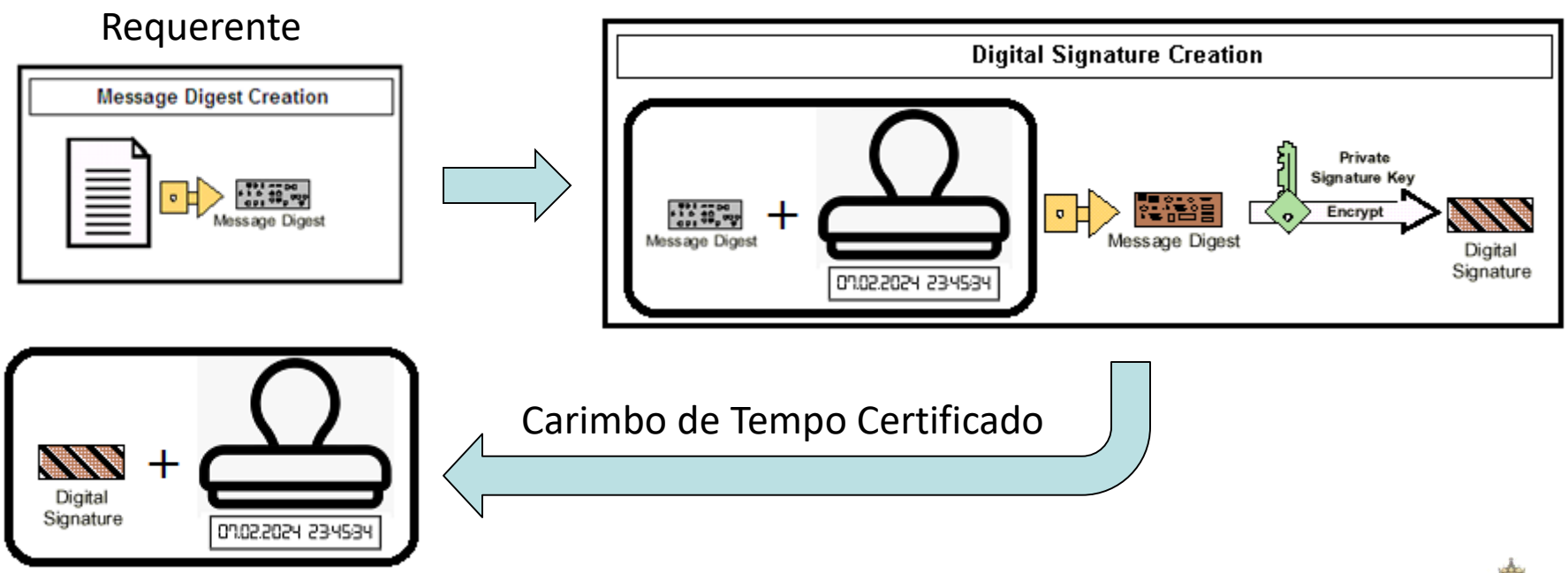


Fonte: ICP-Brasil. Visão Geral do Sistema de Carimbos do Tempo na ICP-Brasil. DOC-ICP-11 – versão 1.0. ICP-Brasil. Dezembro, 2008.

Comunicação Segura

ICP-Brasil:

- **Autoridade Certificadora de Tempo – ACT:**
  - **Geração do carimbo de tempo certificado.**

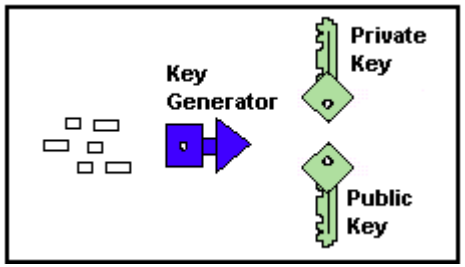


Fonte: ICP-Brasil. Visão Geral do Sistema de Carimbos do Tempo na ICP-Brasil. DOC-ICP-11 – versão 1.0. ICP-Brasil. Dezembro, 2008.

Comunicação Segura

Processo de Comunicação Segura:

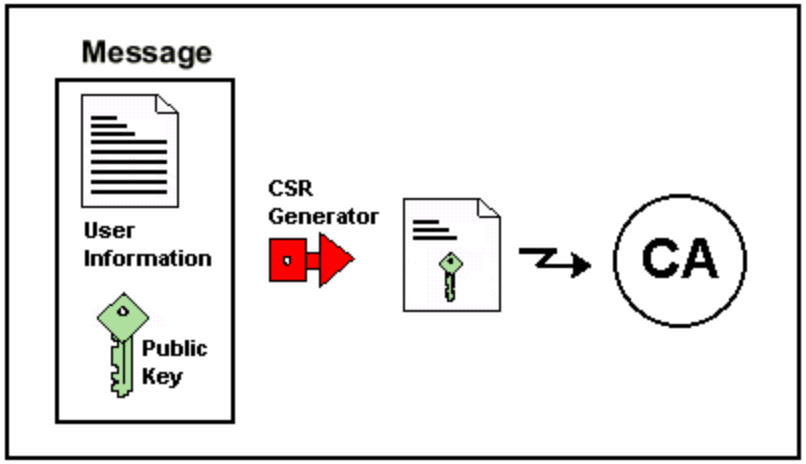
- **Gerar Par de Chaves Assimétricas**



Comunicação Segura

Processo de Comunicação Segura:

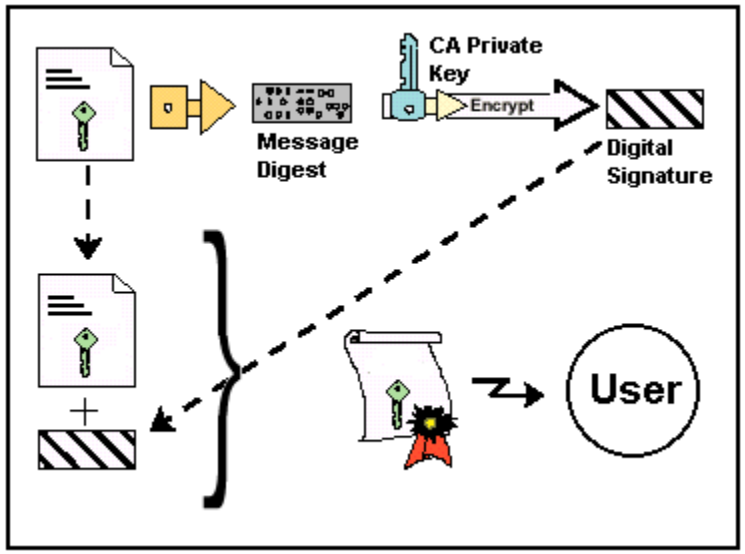
- **Enviar Mensagem de Solicitação de Certificado**



Comunicação Segura

Processo de Comunicação Segura:

- **Gerar Certificado e Enviar para Usuário**



Comunicação Segura

- Segurança da Informação
  Prof. Anderson O. da Silva

Processo de Comunicação Segura:

- **Processo de Envio de Mensagem**

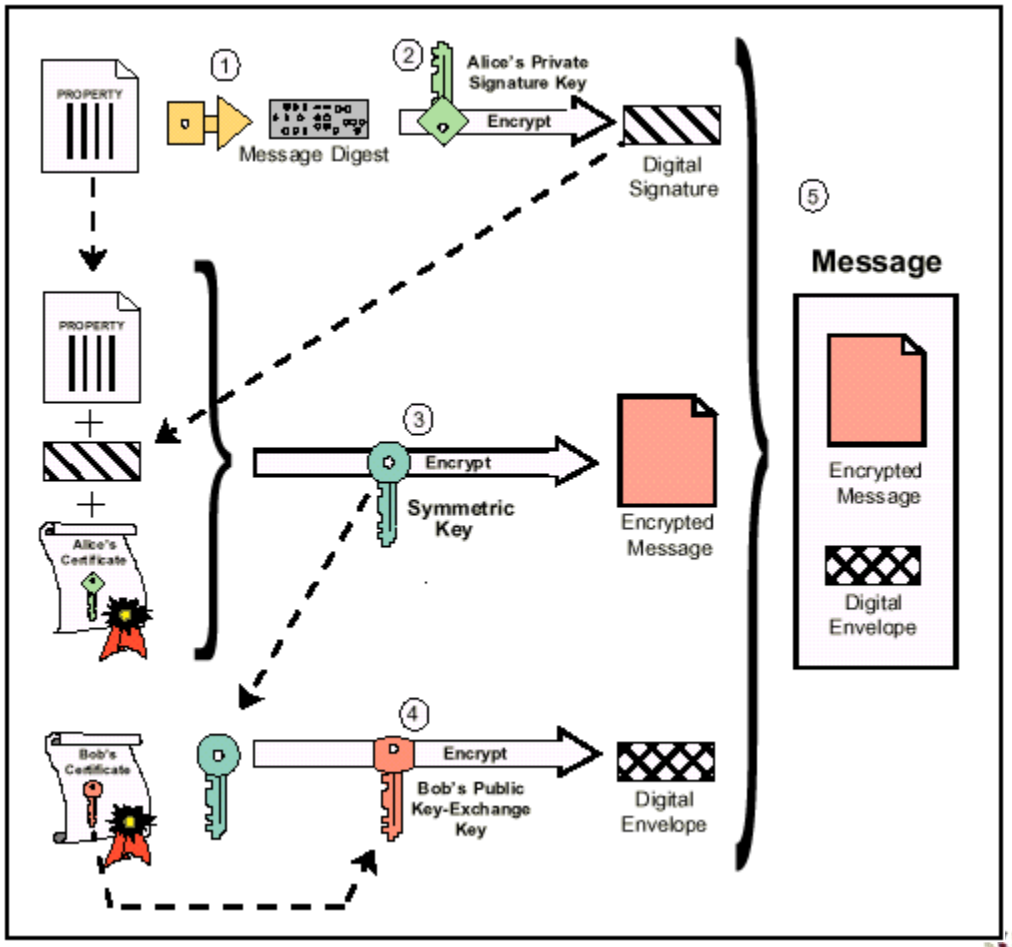
1 – Geração do digest (controle de integridade)

2 – Geração da assinatura digital (controle de autenticidade)

3 – Geração da mensagem cifrada (controle de sigilo)

4 – Geração do envelope digital (compartilhamento seguro)

5 – Transmissão segura



Comunicação Segura

Processo de Comunicação Segura:

- **Processo de Recepção de Mensagem**

5 – Recepção segura

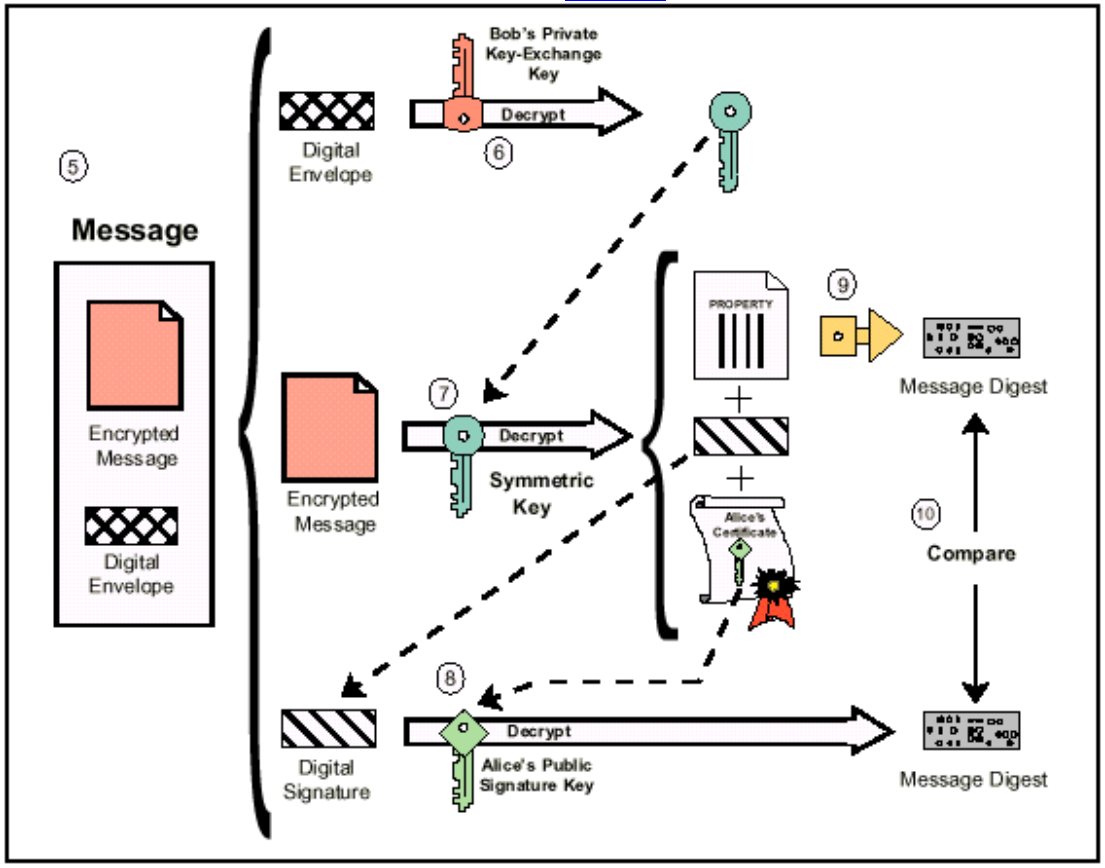
6 – Recuperação do segredo

7 – Recuperação da mensagem

8 – Recuperação do digest original

9 – Geração do digest corrente

10 – Validação da integridade e autenticidade



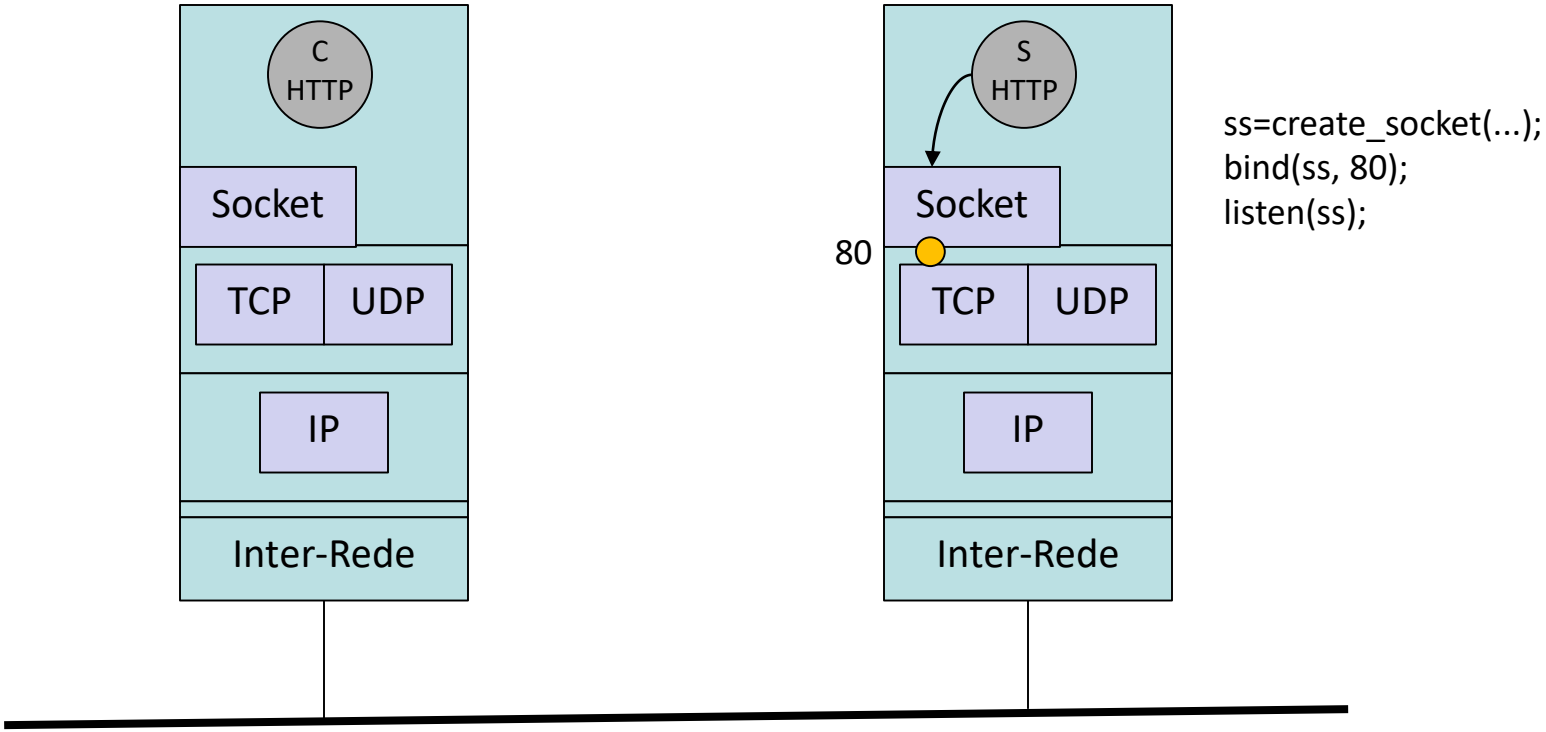
Comunicação Segura

Secure Socket Layer (SSL) e Transport Layer Security (TLS):

- SSL foi desenvolvido pela Netscape em 1994.
- Amplamente aceito, distribuído e suportado em todos os navegadores e servidores mais importantes.
- Versões mais usadas:
  - SSLv2 e SSLv3 (não mais recomendadas).
  - TLSv1.0 (padrão IETF, primeira versão: RFC2246, 1999).
  - TLSv1.1 (RFC4345, 2006), TLSv1.2 (RFC5246, 2008) e TLS1.3 (RFC8446, 2018).
- Características do SSL/TLS:
  - Autenticação do servidor obrigatória e autenticação do cliente pode ser opcional.
  - Permite que ambas as partes (cliente e servidor) renegociem as chaves e as operações de cifragem a qualquer momento.
  - Permite compactação dos dados.

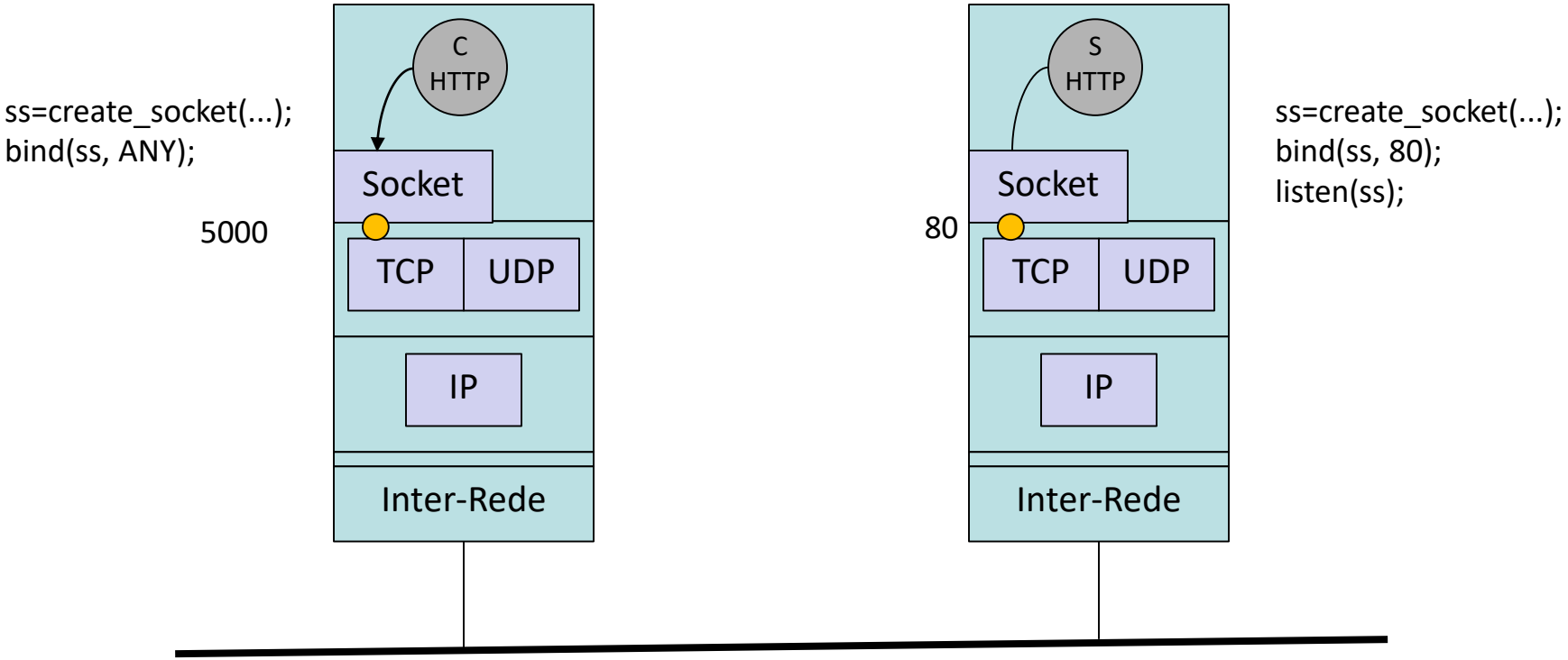
Comunicação Segura

Secure Socket Layer (SSL) e Transport Layer Security (TLS): Exemplo: HTTP em Texto Plano



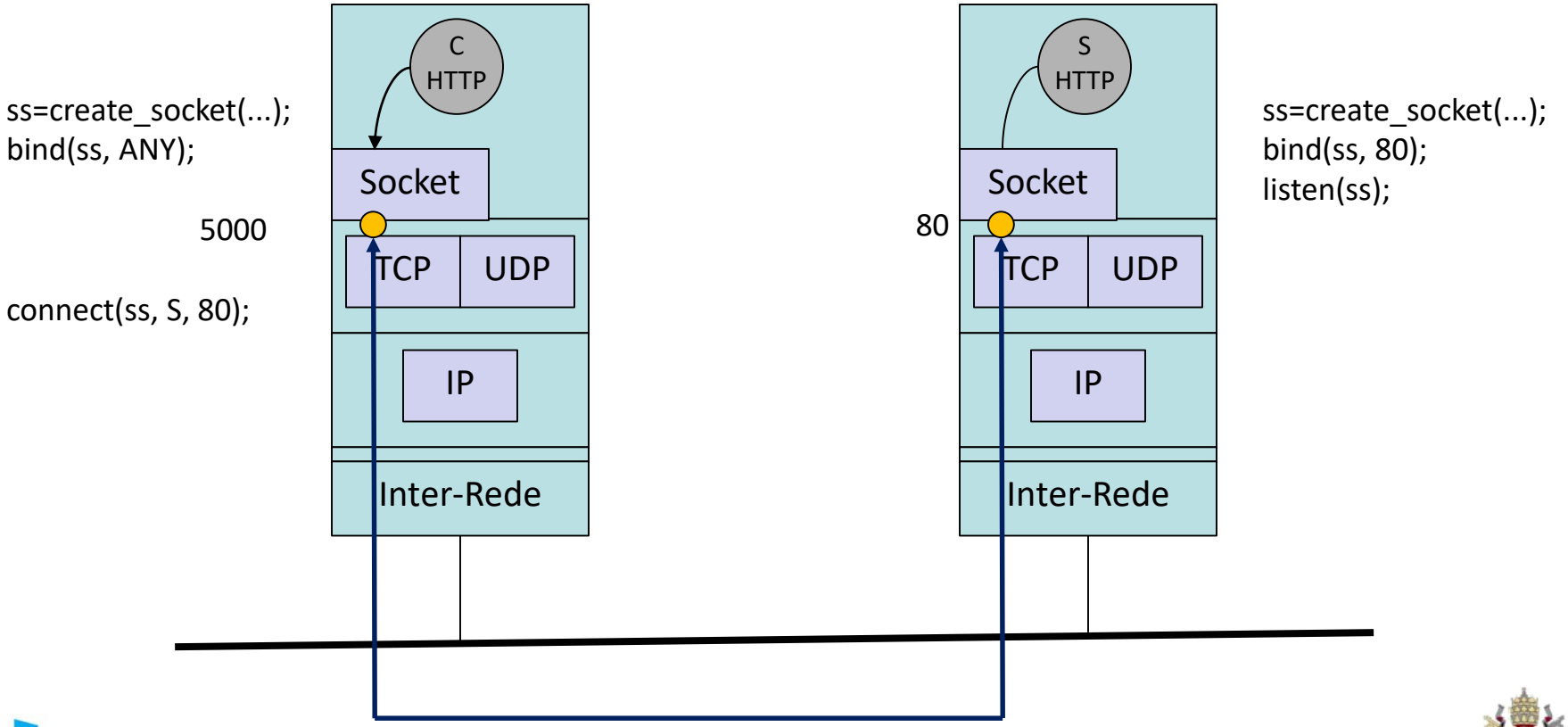
Comunicação Segura

Secure Socket Layer (SSL) e Transport Layer Security (TLS): Exemplo: HTTP em Texto Plano



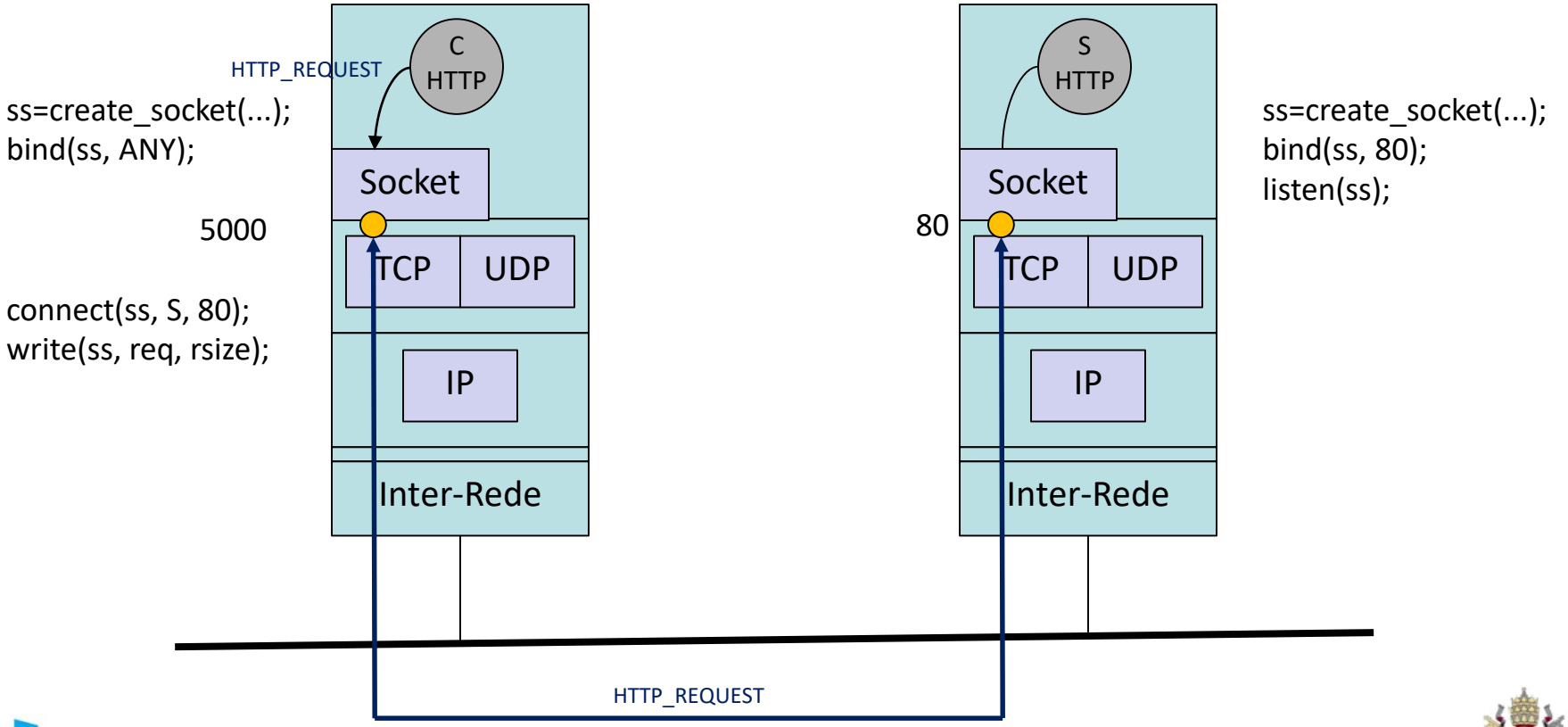
Comunicação Segura

Secure Socket Layer (SSL) e Transport Layer Security (TLS): Exemplo: HTTP em Texto Plano



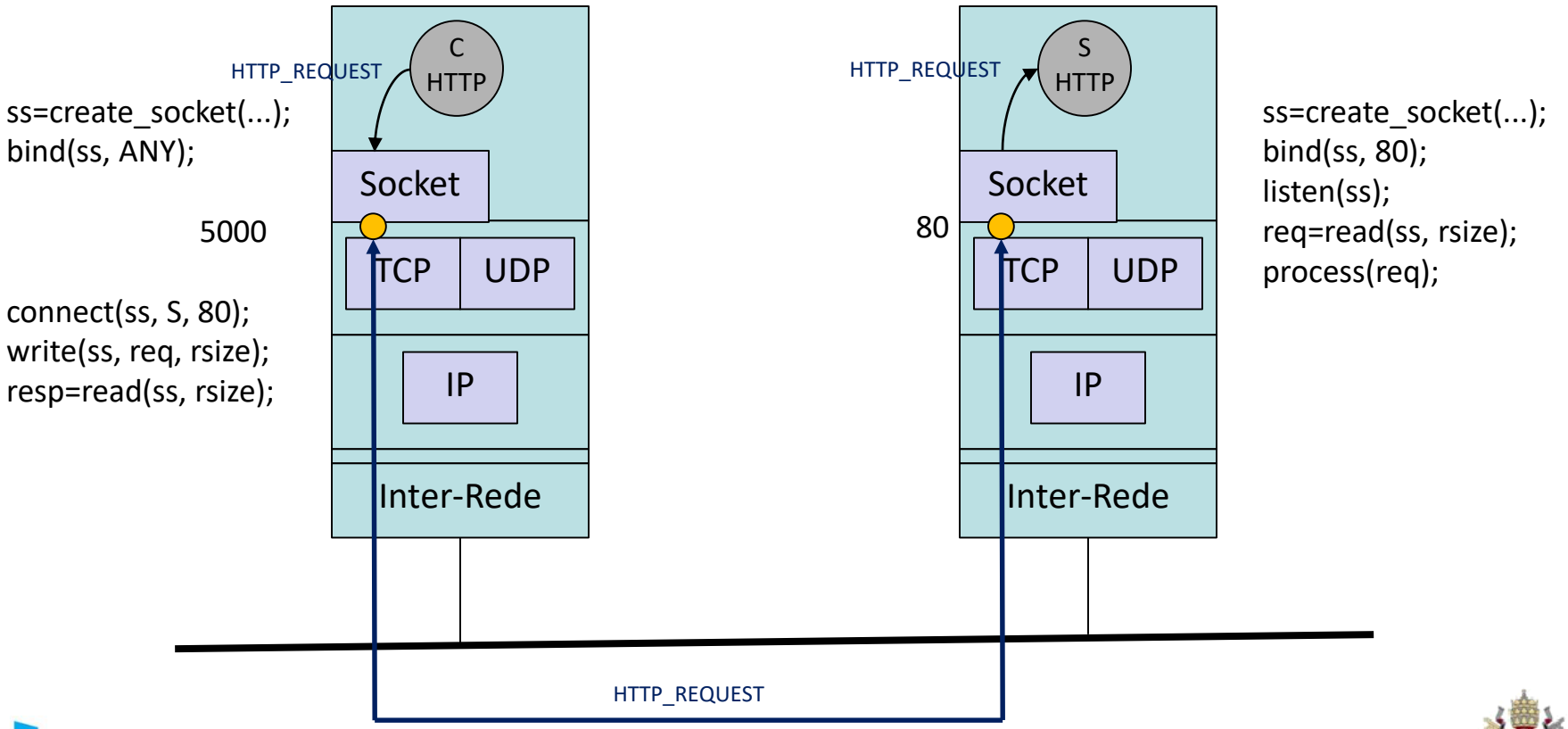
Comunicação Segura

Secure Socket Layer (SSL) e Transport Layer Security (TLS): Exemplo: HTTP em Texto Plano



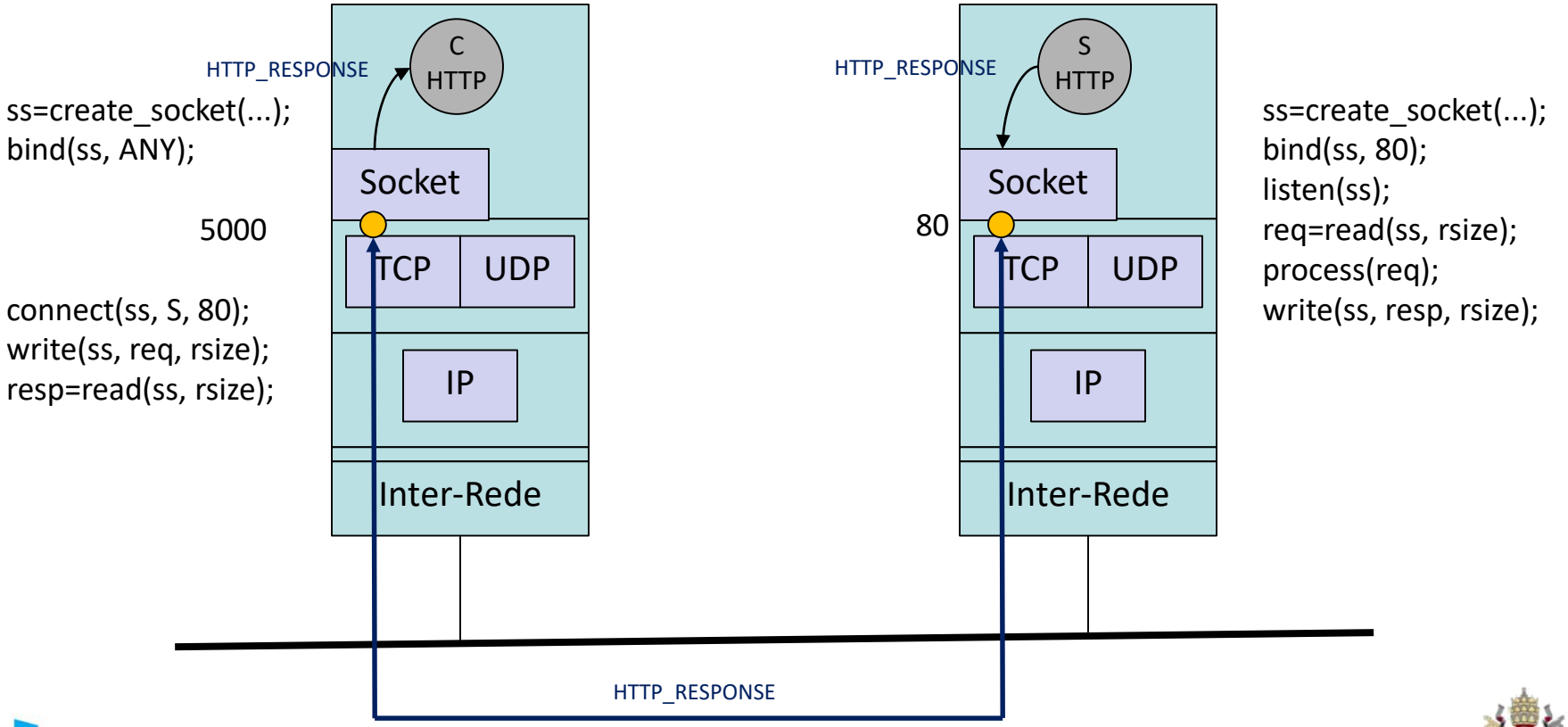
Comunicação Segura

Secure Socket Layer (SSL) e Transport Layer Security (TLS): Exemplo: HTTP em Texto Plano



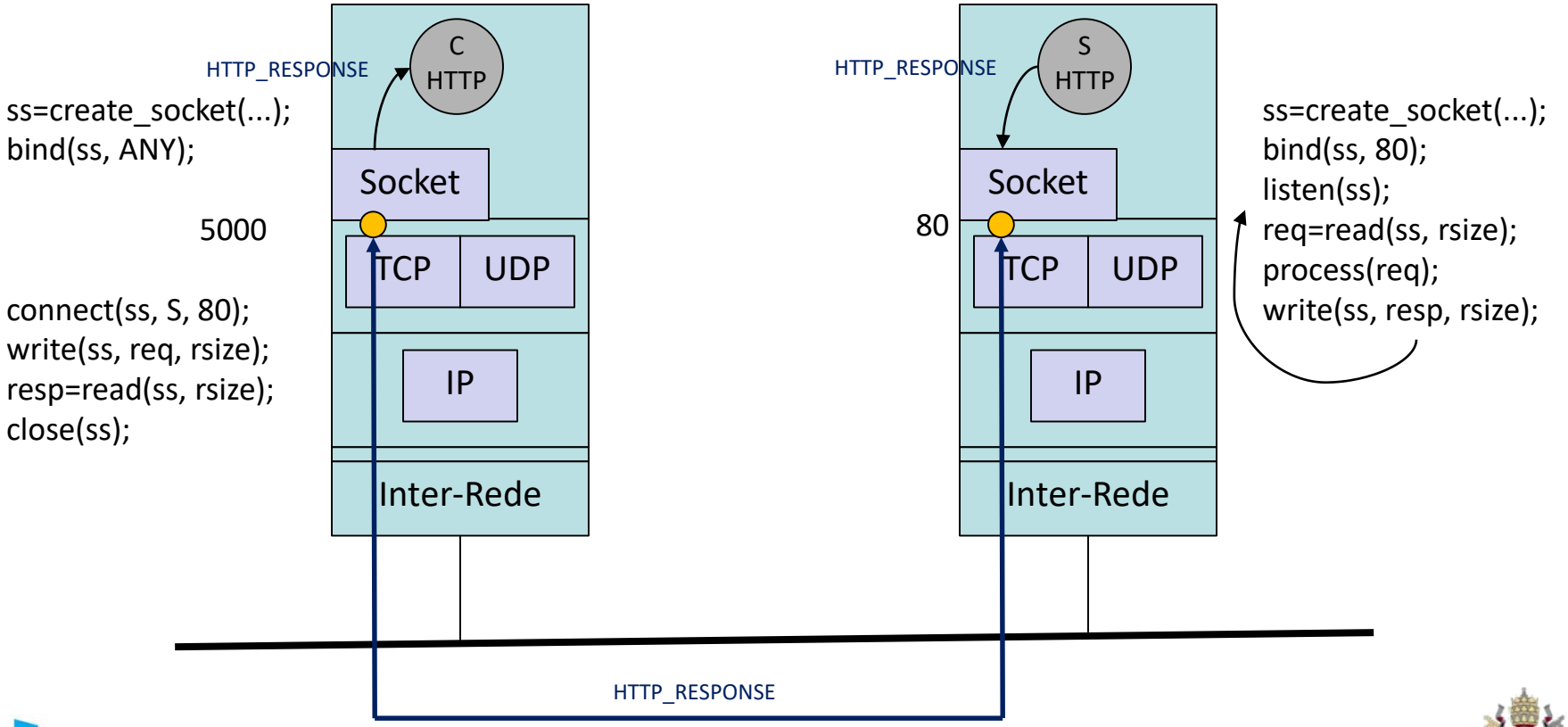
Comunicação Segura

Secure Socket Layer (SSL) e Transport Layer Security (TLS): Exemplo: HTTP em Texto Plano



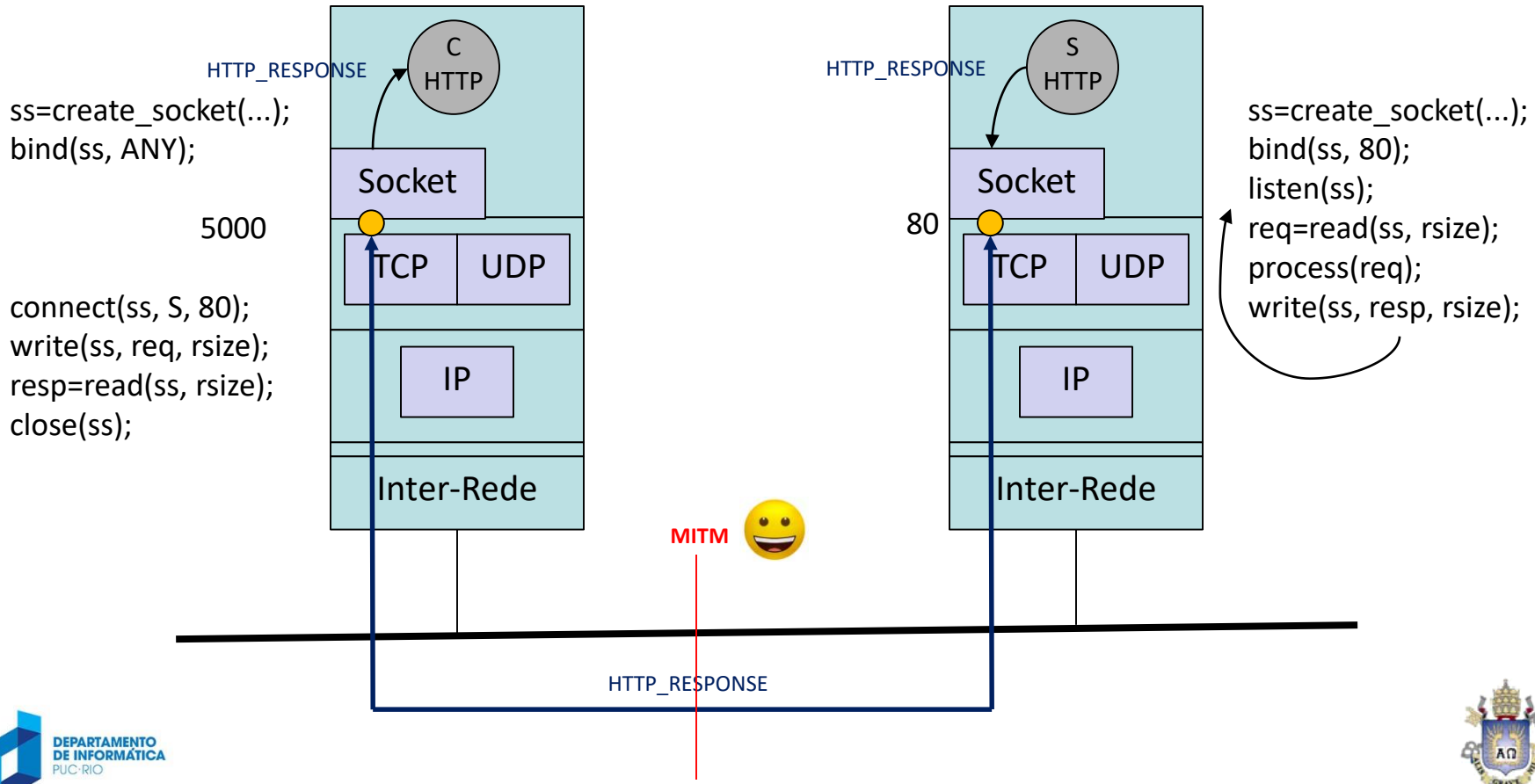
Comunicação Segura

Secure Socket Layer (SSL) e Transport Layer Security (TLS): Exemplo: HTTP em Texto Plano



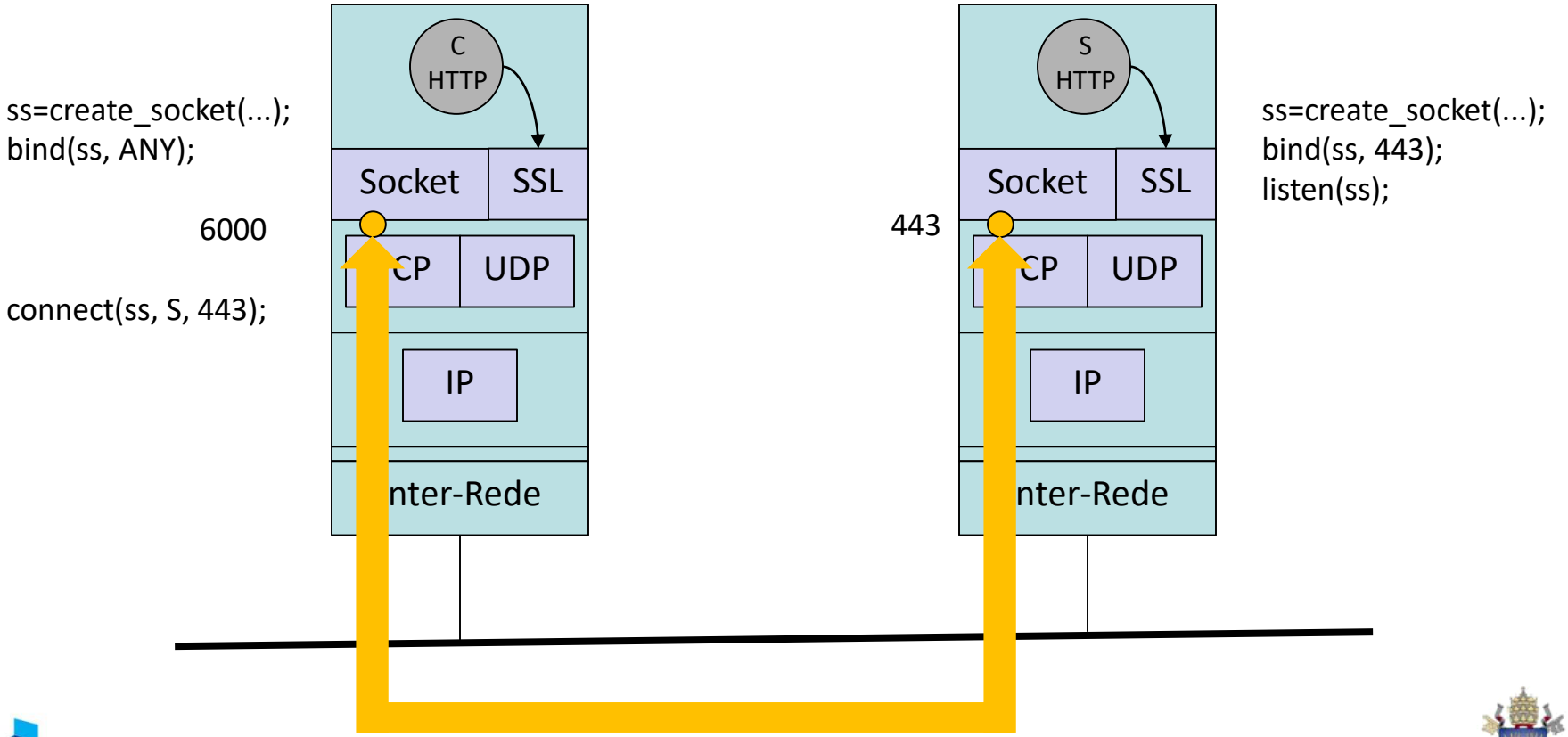
Comunicação Segura

Secure Socket Layer (SSL) e Transport Layer Security (TLS): Exemplo: HTTP em Texto Plano



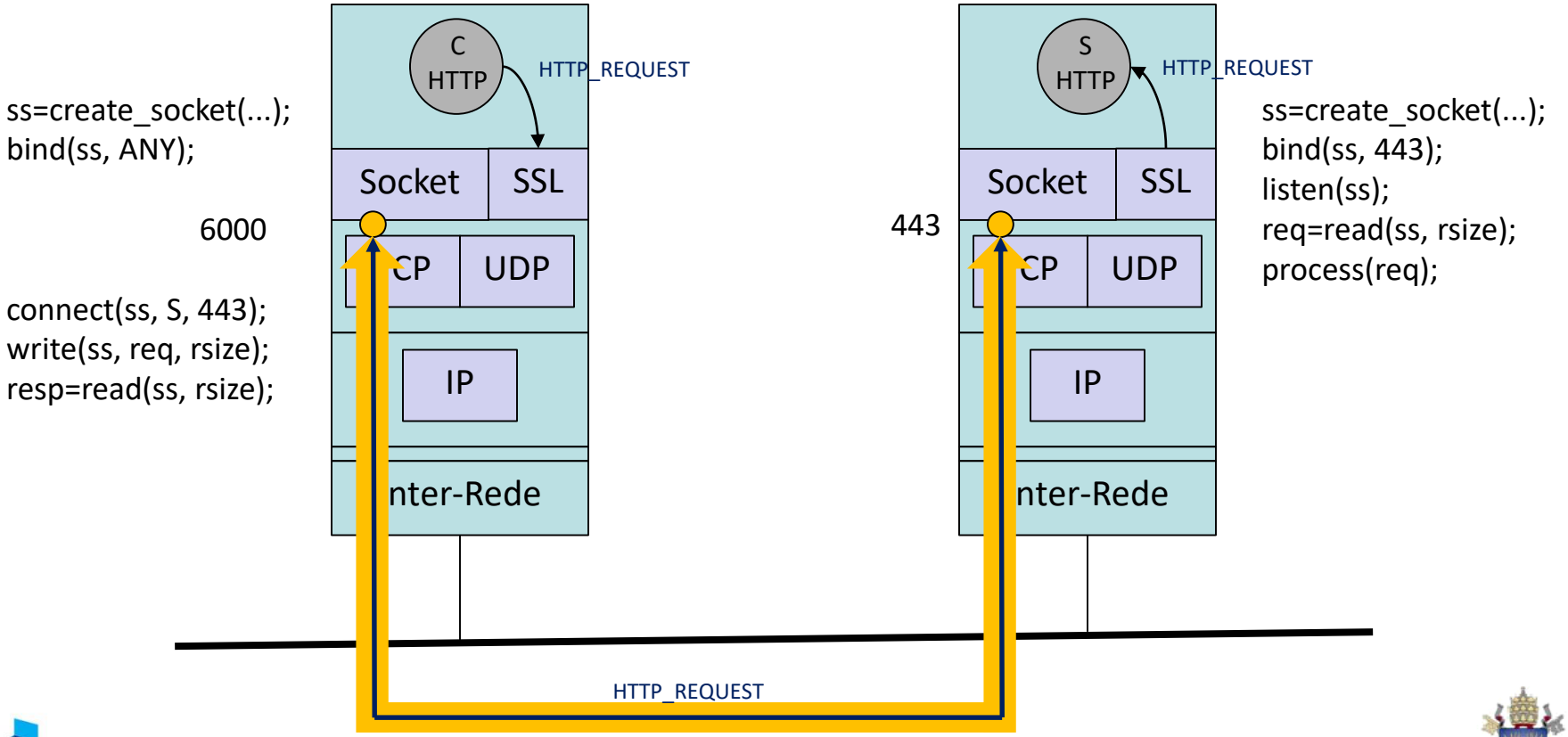
Comunicação Segura

Secure Socket Layer (SSL) e Transport Layer Security (TLS): Exemplo: HTTP over TLS/SSL



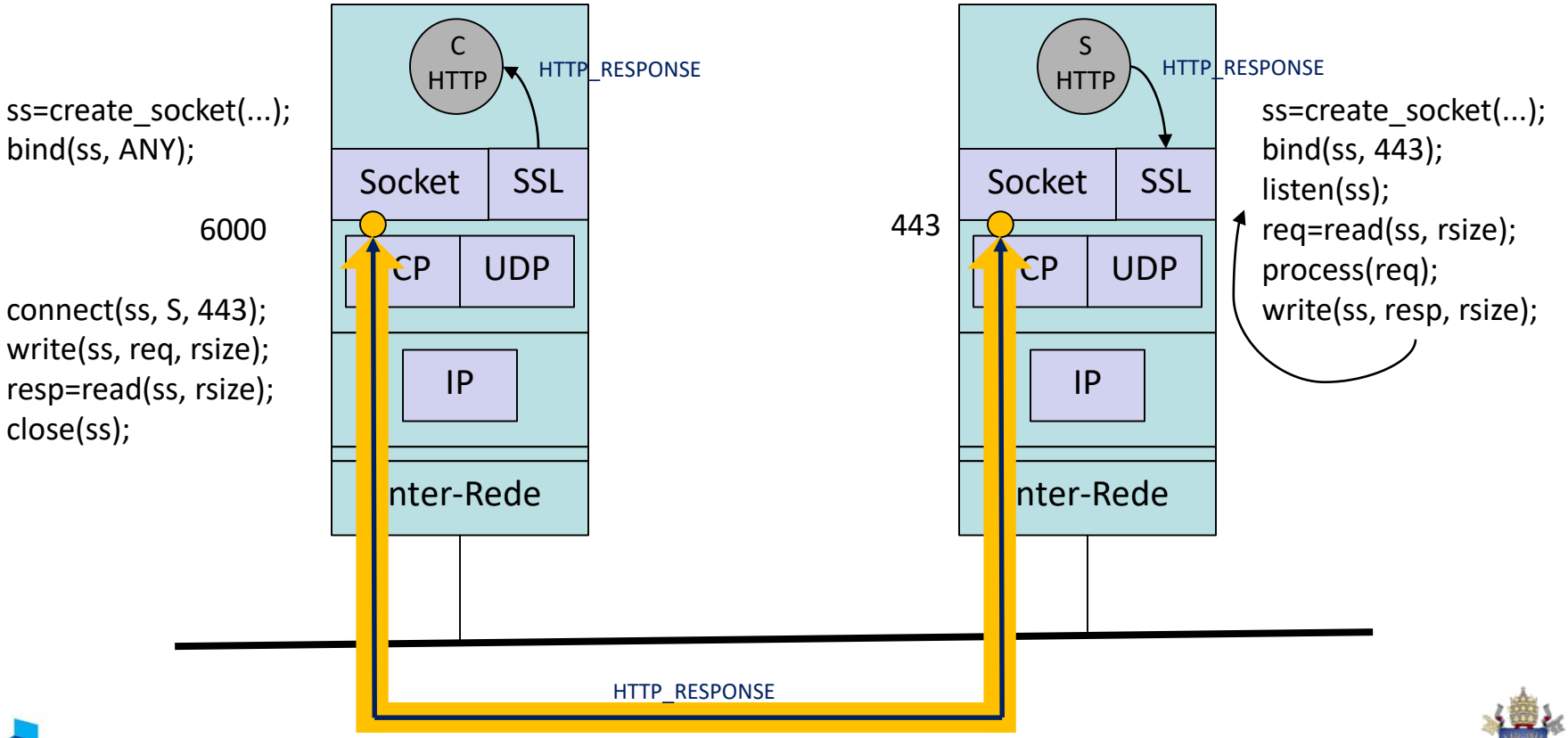
Comunicação Segura

Secure Socket Layer (SSL) e Transport Layer Security (TLS): Exemplo: HTTP over TLS/SSL



Comunicação Segura

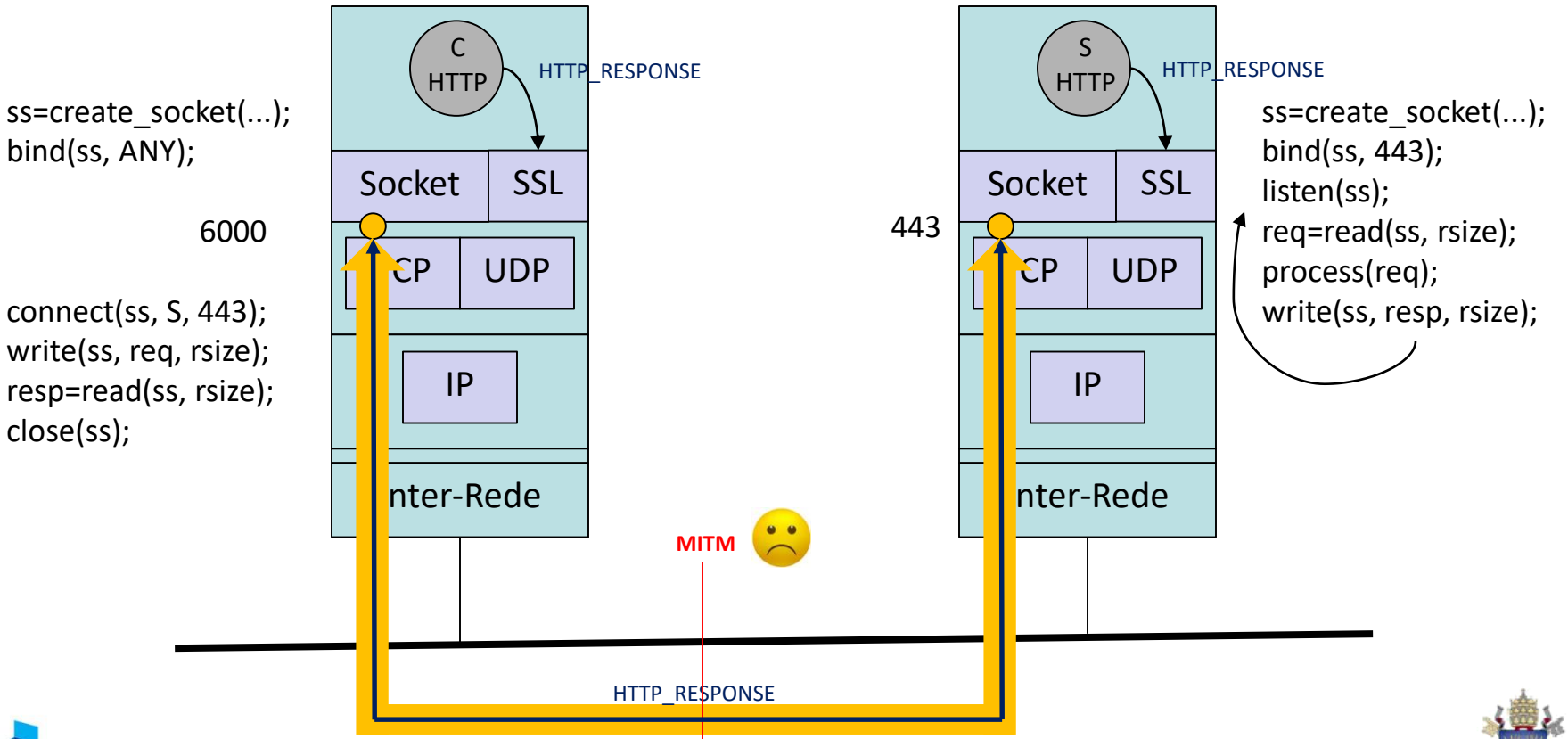
Secure Socket Layer (SSL) e Transport Layer Security (TLS): Exemplo: HTTP over TLS/SSL



HTTPS – HTTP over TLS/SSL
Comunicação segura através de um túnel criptografado !!!

Comunicação Segura

Secure Socket Layer (SSL) e Transport Layer Security (TLS): Exemplo: HTTP over TLS/SSL



Comunicação Segura

Secure Socket Layer (SSL) e Transport Layer Security (TLS):

- **Elementos de um estado de sessão:**
  - **Session Identifier**
    - Identificação da sessão como ativa ou de resumo.
  - **Peer Certificate**
    - Certificado X.509v3 do peer (pode ser nulo).
  - **Compression Method**
    - Algoritmo de compactação a ser utilizado antes da criptografia.
  - **Cipher Spec**
    - Algoritmo de criptografia e resumo de mensagem.
  - **Master Secret**
    - Segredo compartilhado de 48 bytes.
  - **Is Resumable**
    - Flag que indica se a sessão pode ser utilizada para iniciar novas conexões.

Comunicação Segura

Secure Socket Layer (SSL) e Transport Layer Security (TLS):

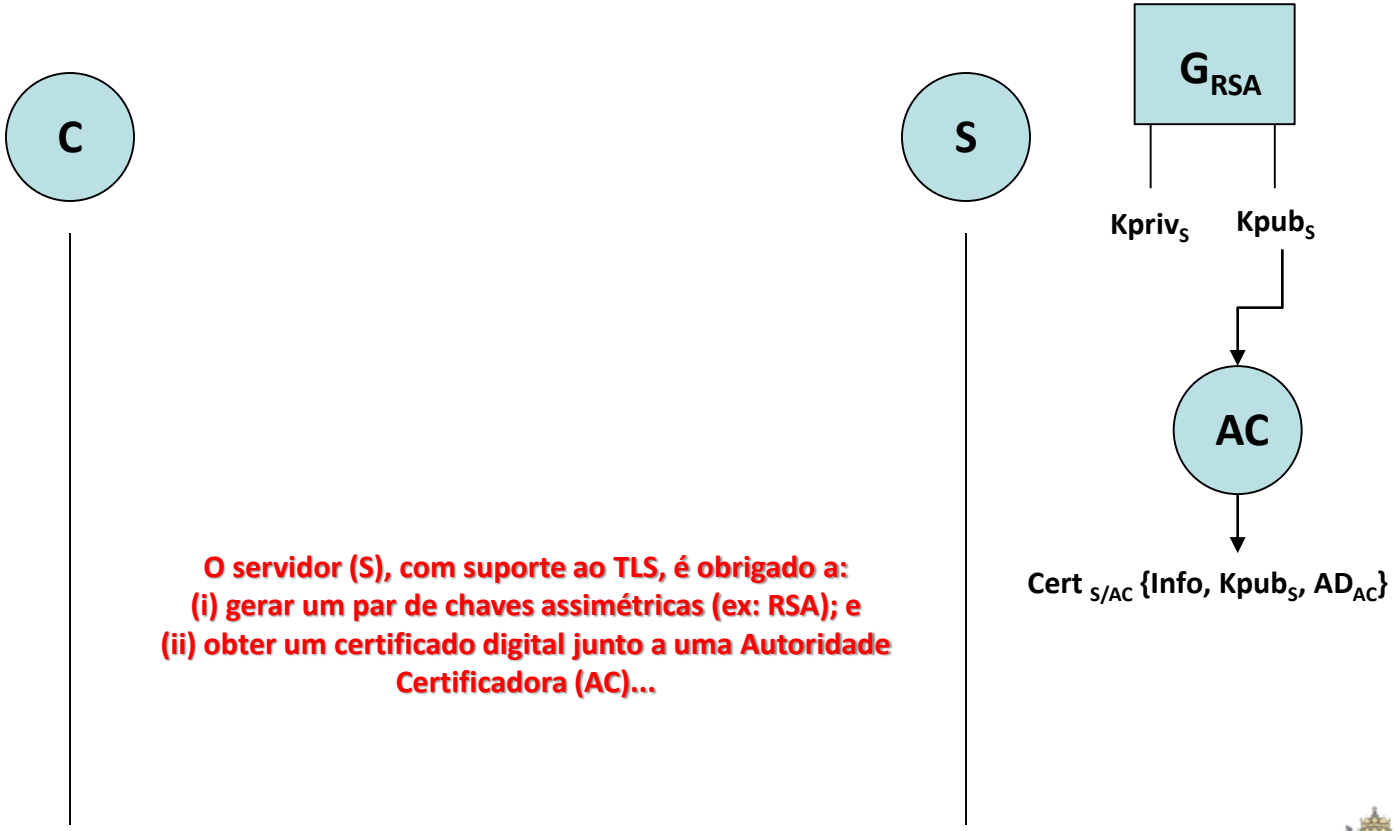
- **Protocolo de Handshake**
  - Negociação que estabelece os parâmetros do estado de sessão.

- **Dividido em duas fases:**
  - Autenticação do Servidor (obrigatória)
  - Autenticação do Cliente (opcional)

Comunicação Segura

- Segurança da Informação
  Prof. Anderson O. da Silva

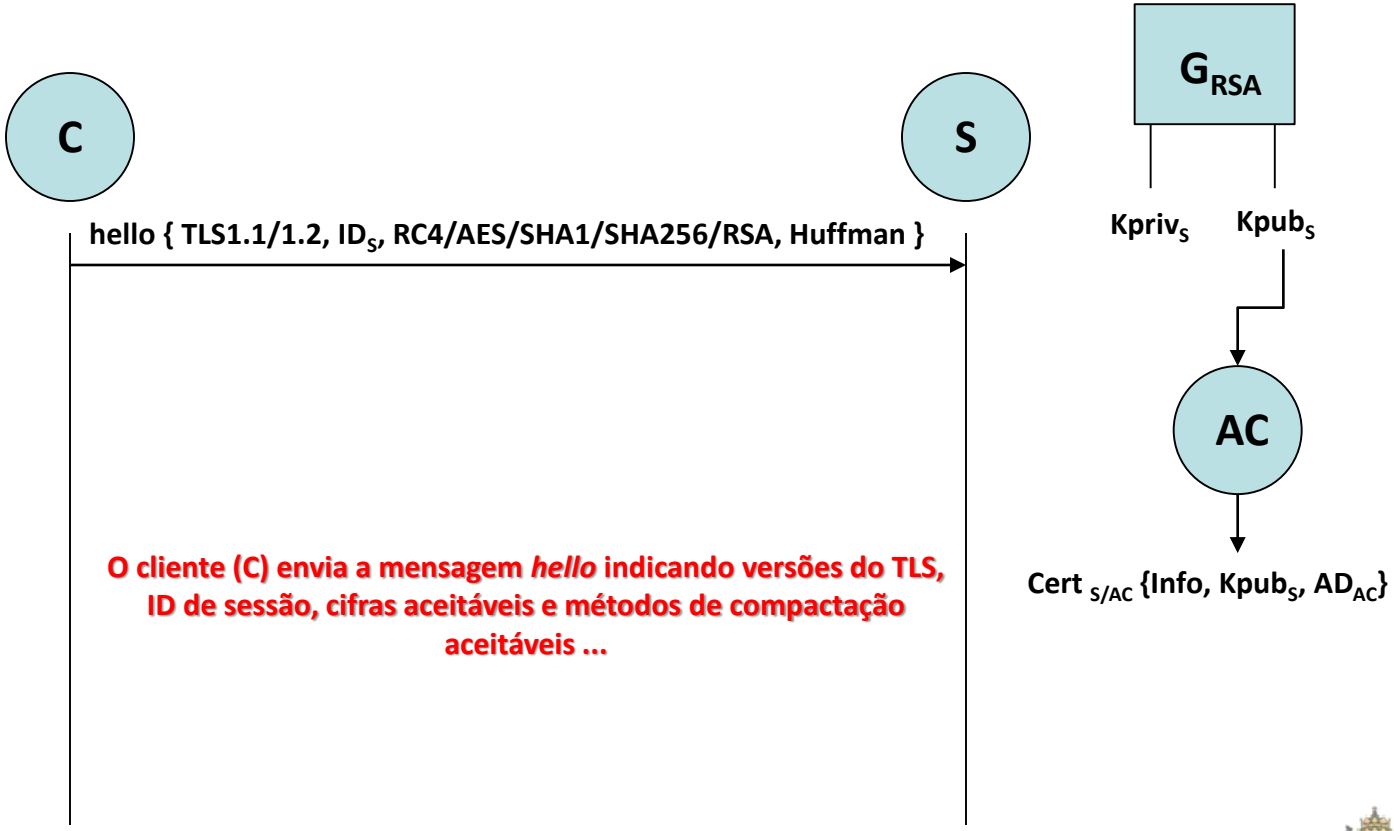
Secure Socket Layer (SSL) e Transport Layer Security (TLS): Operação – Fase Obrigatória



Comunicação Segura

- Segurança da Informação
  Prof. Anderson O. da Silva

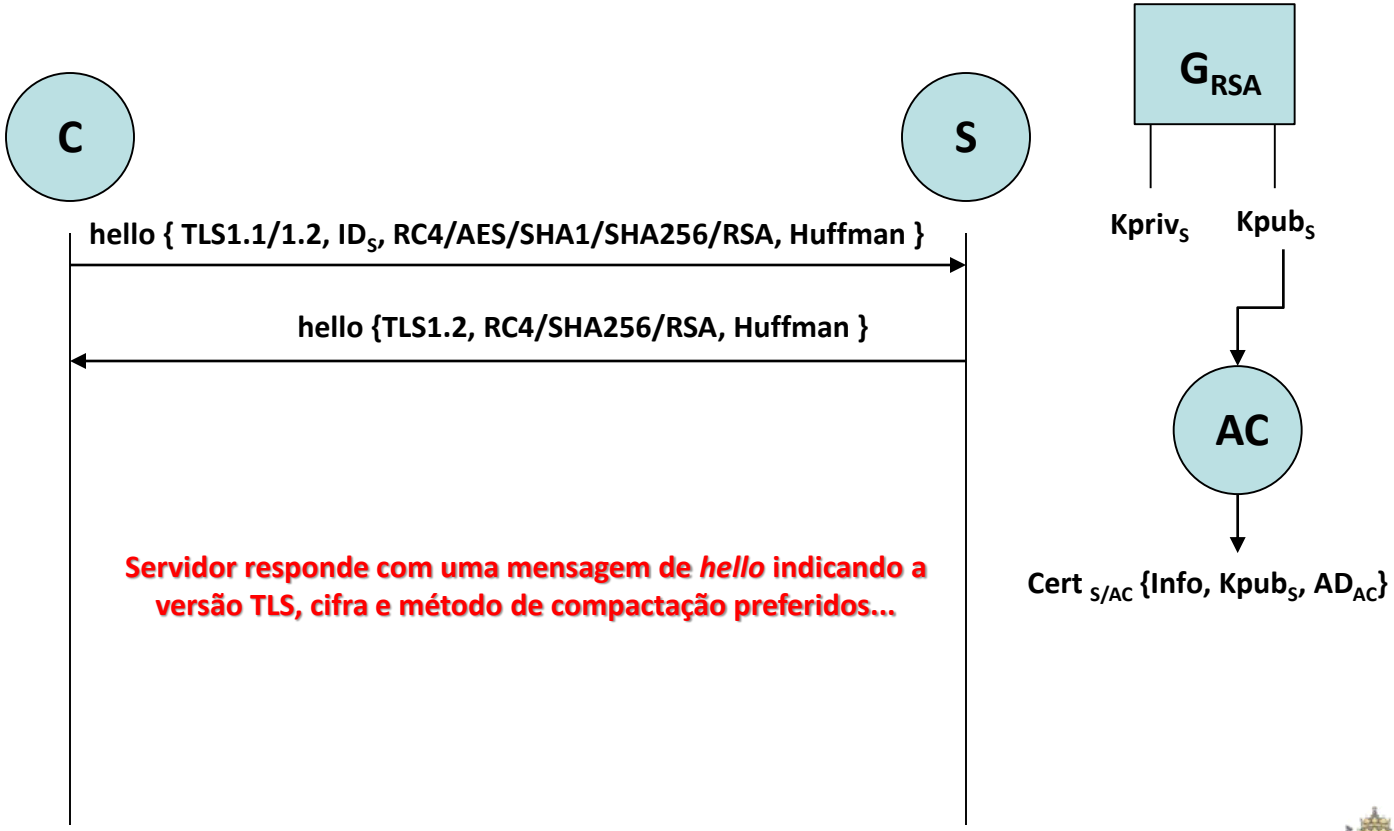
Secure Socket Layer (SSL) e Transport Layer Security (TLS): Operação – Fase Obrigatória



Comunicação Segura

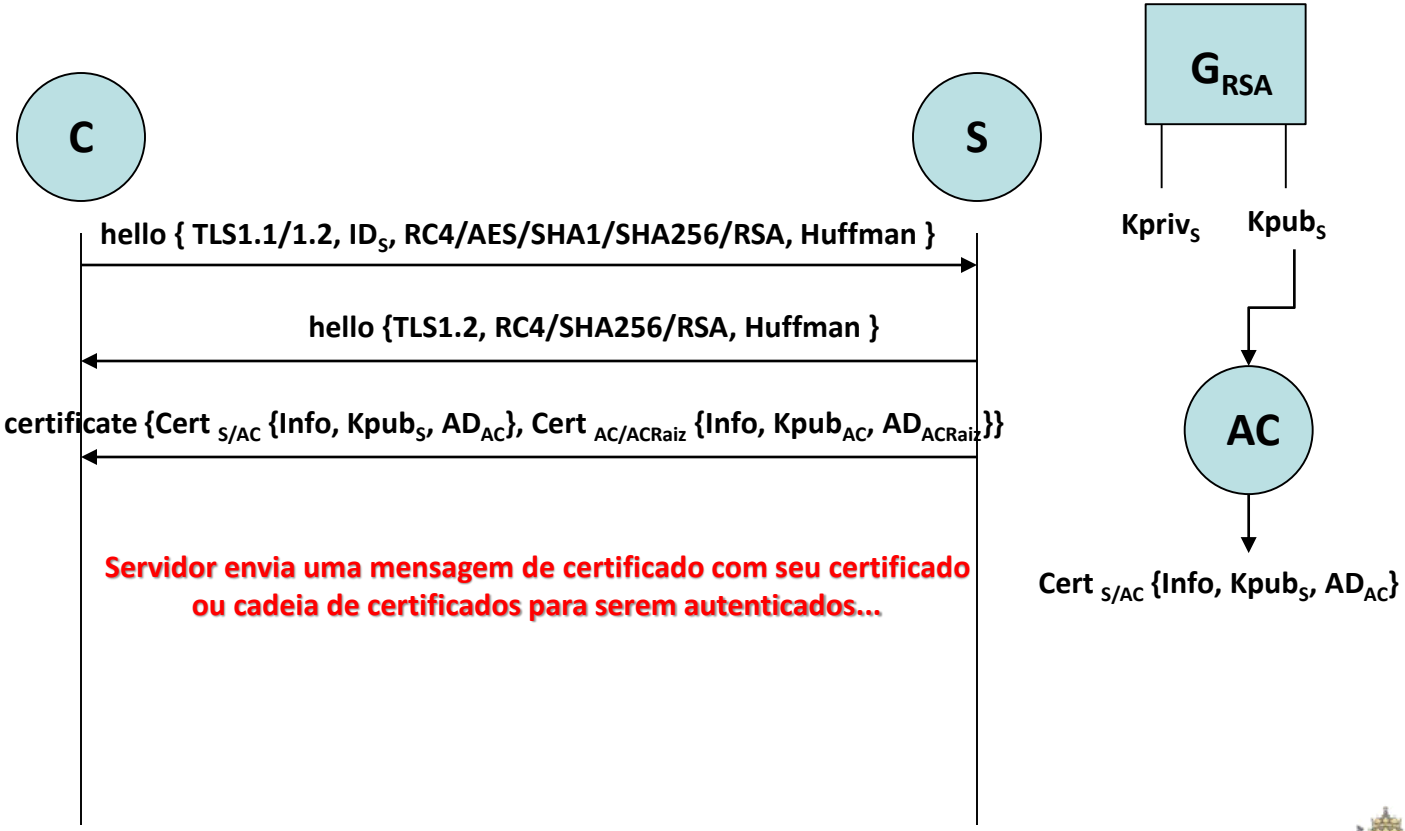
- Segurança da Informação
  Prof. Anderson O. da Silva

Secure Socket Layer (SSL) e Transport Layer Security (TLS): Operação – Fase Obrigatória



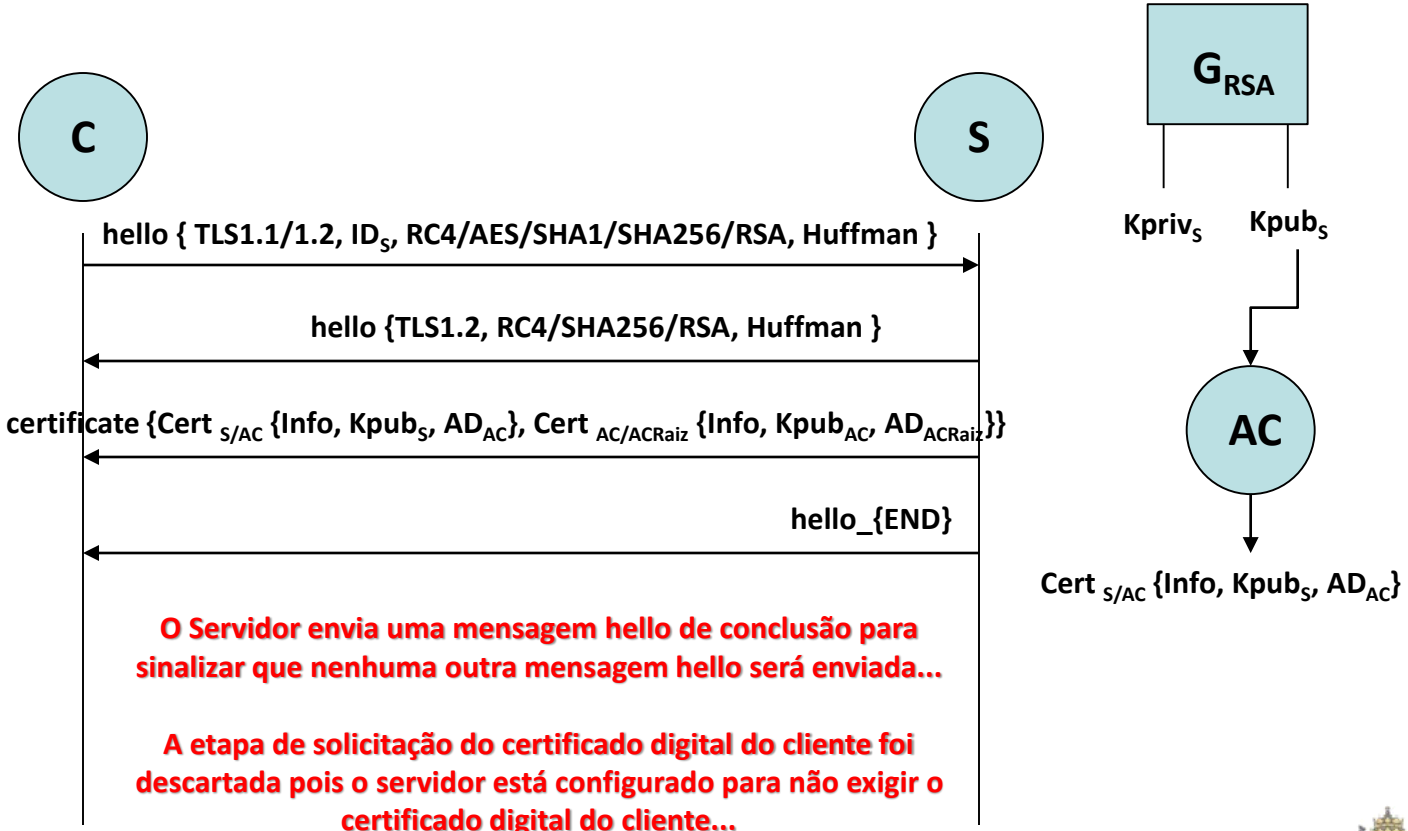
Comunicação Segura

Secure Socket Layer (SSL) e Transport Layer Security (TLS): Operação – Fase Obrigatória



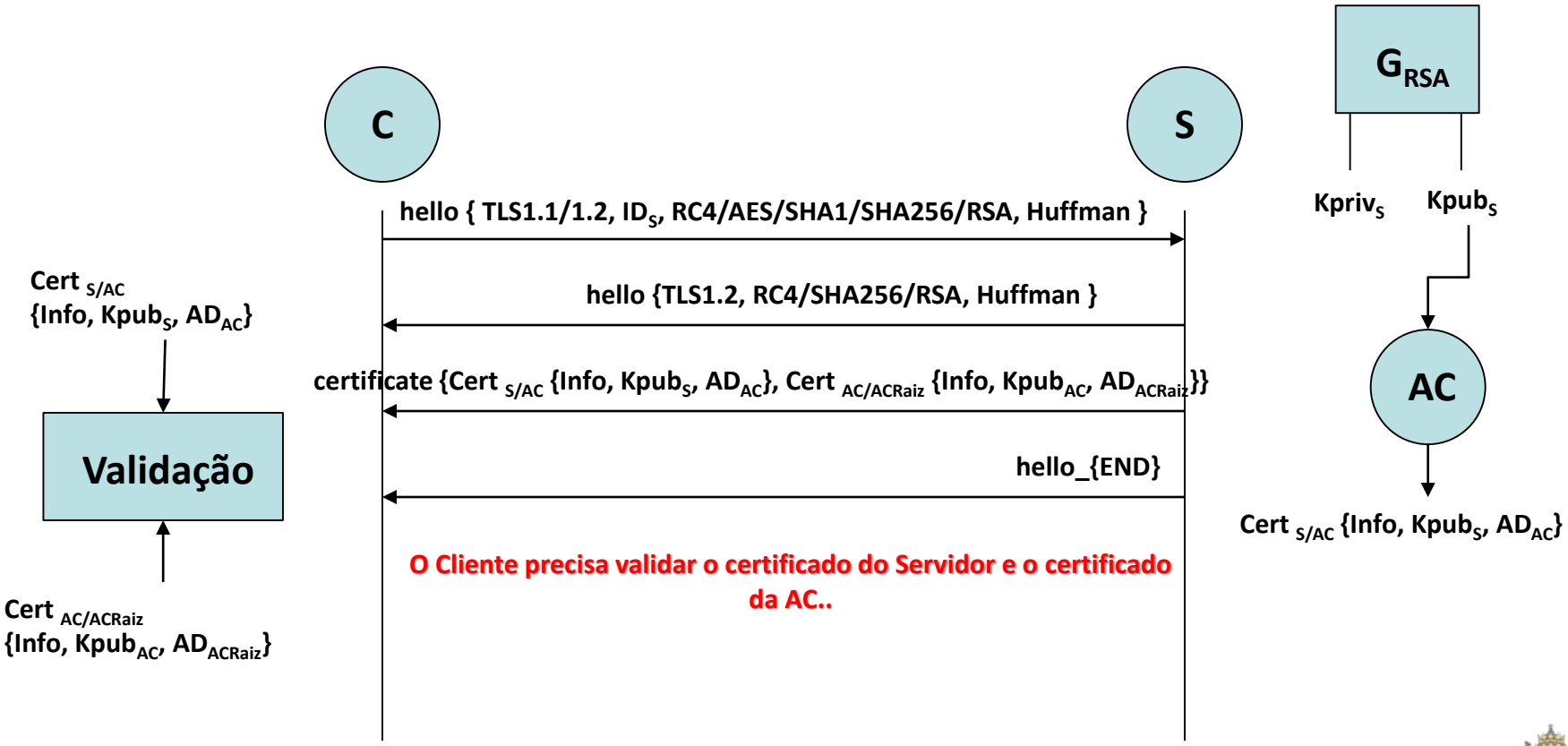
Comunicação Segura

Secure Socket Layer (SSL) e Transport Layer Security (TLS): Operação – Fase Obrigatória



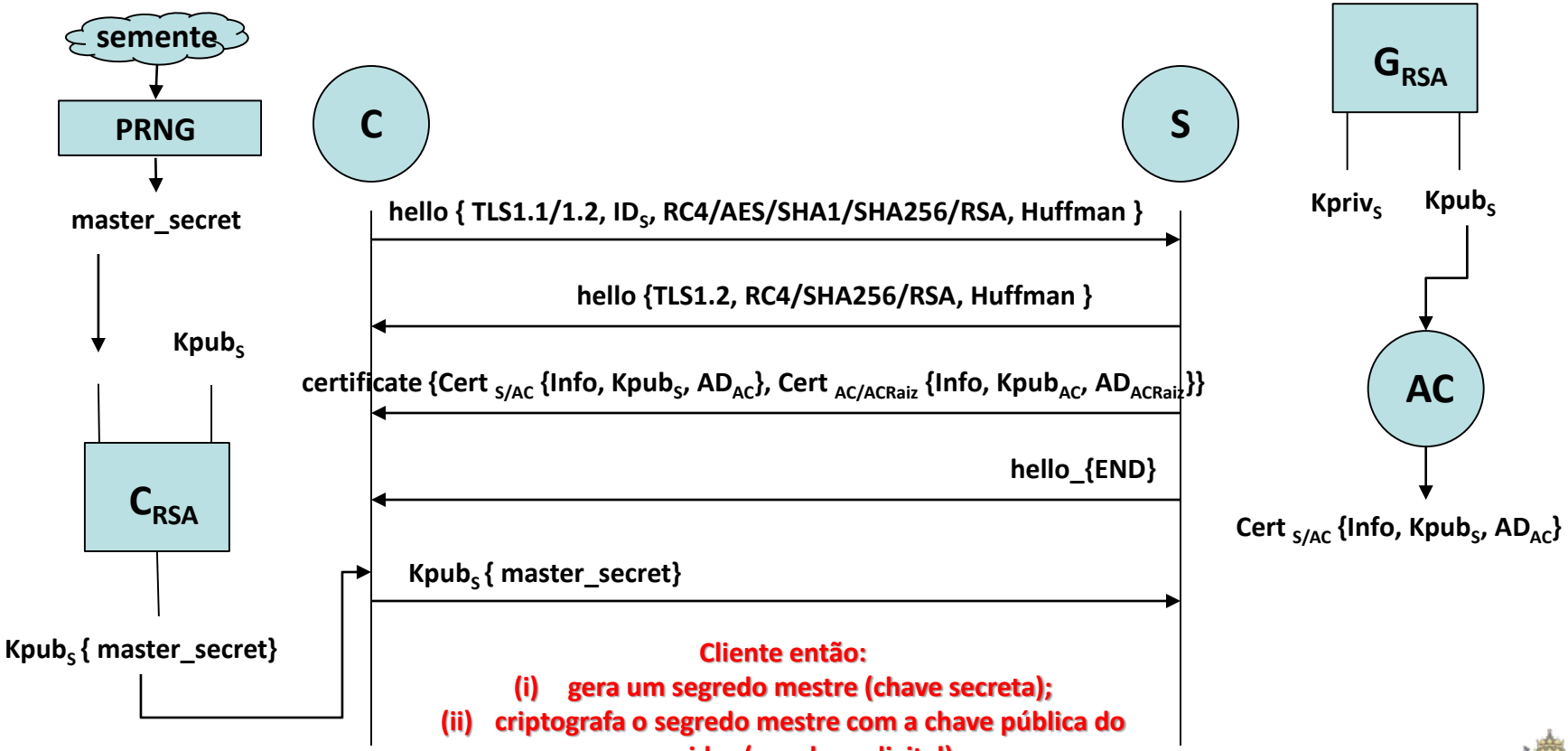
Comunicação Segura

Secure Socket Layer (SSL) e Transport Layer Security (TLS): Operação – Fase Obrigatória



Comunicação Segura

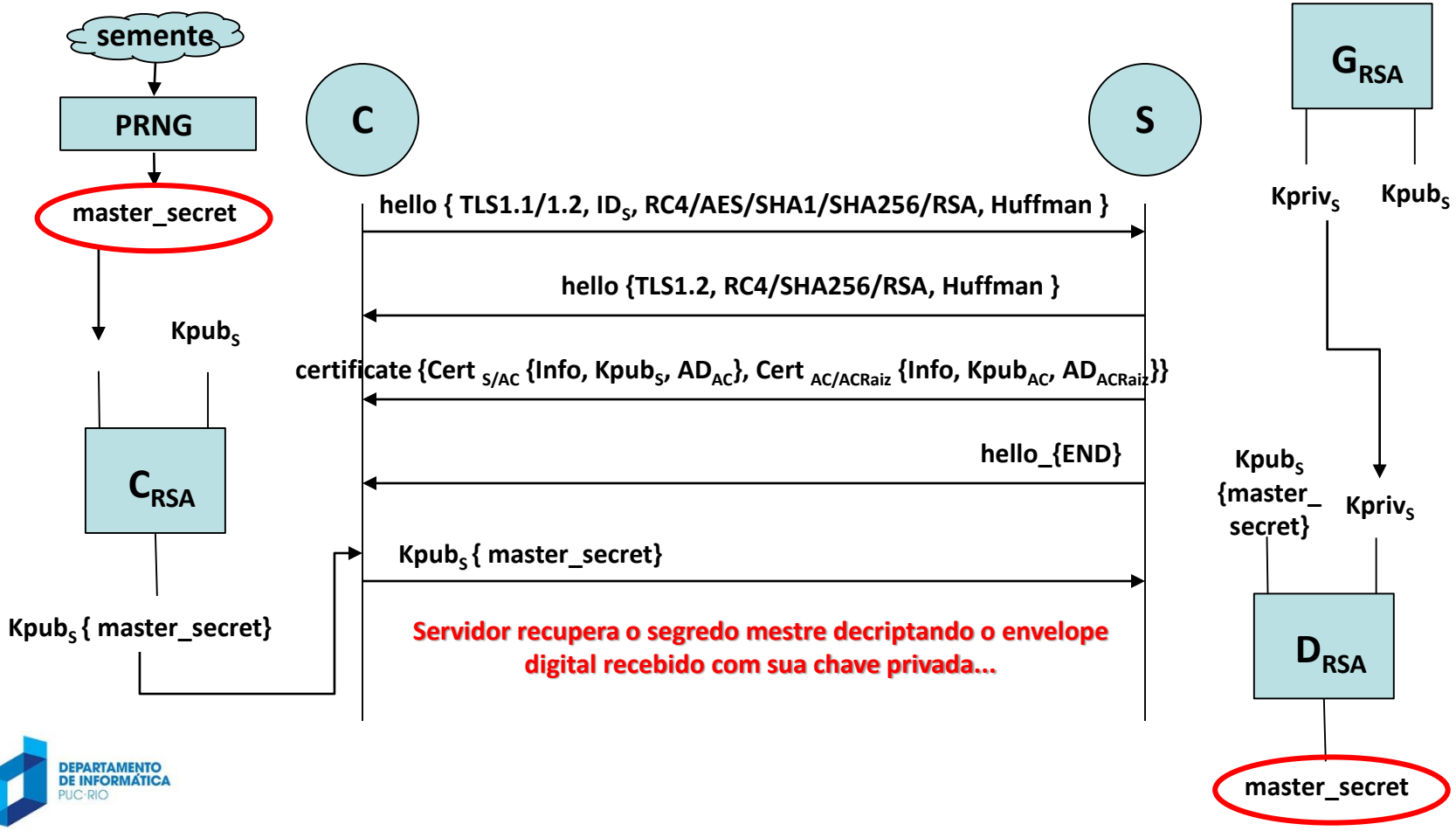
Secure Socket Layer (SSL) e Transport Layer Security (TLS): Operação – Fase Obrigatória



Cliente então:
(i) gera um segredo mestre (chave secreta);
(ii) criptografa o segredo mestre com a chave pública do servidor (envelope digital); e
(iii) envia a informação criptografada para o servidor...

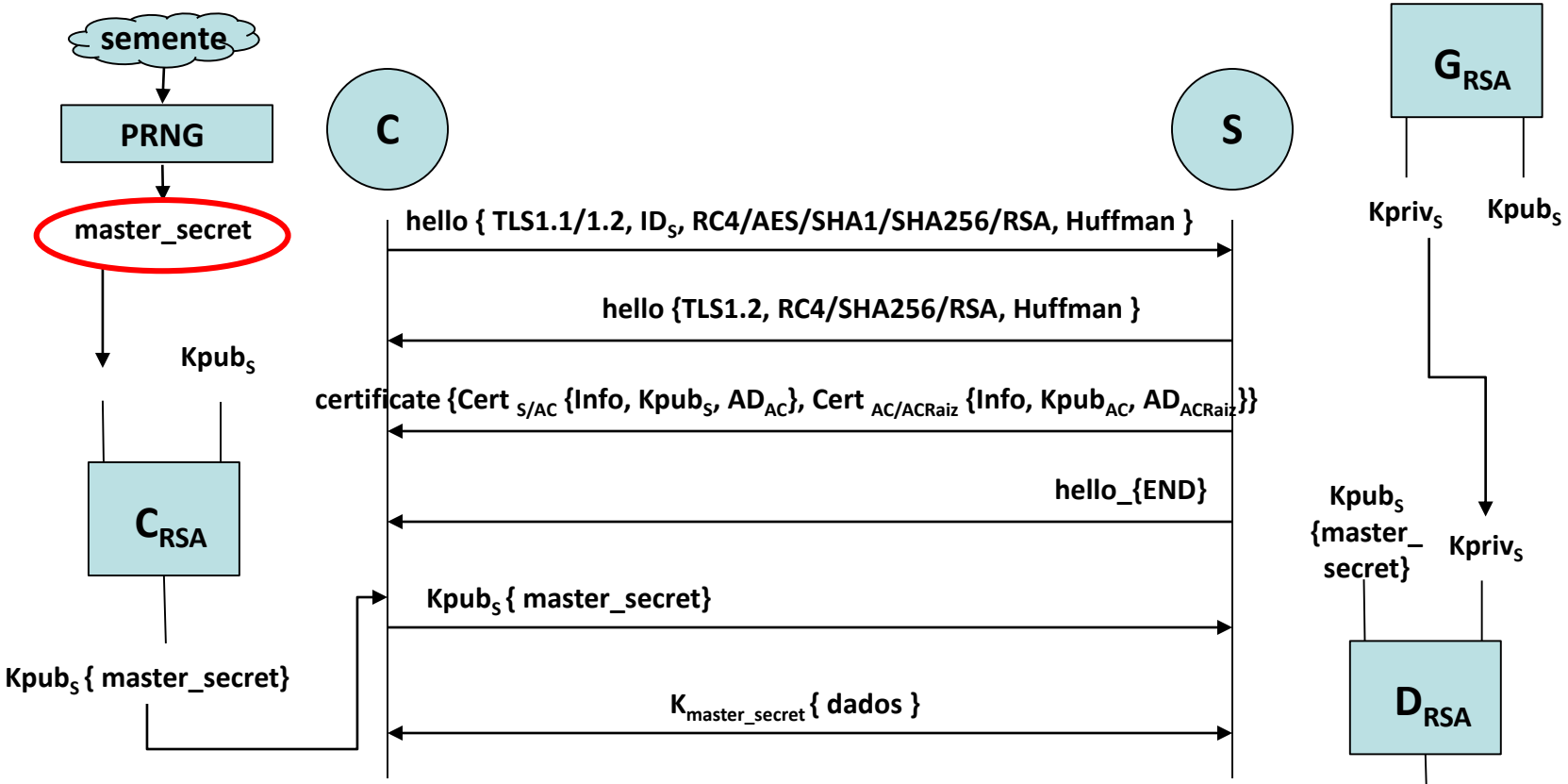
Comunicação Segura

Secure Socket Layer (SSL) e Transport Layer Security (TLS): Operação – Fase Obrigatória



Comunicação Segura

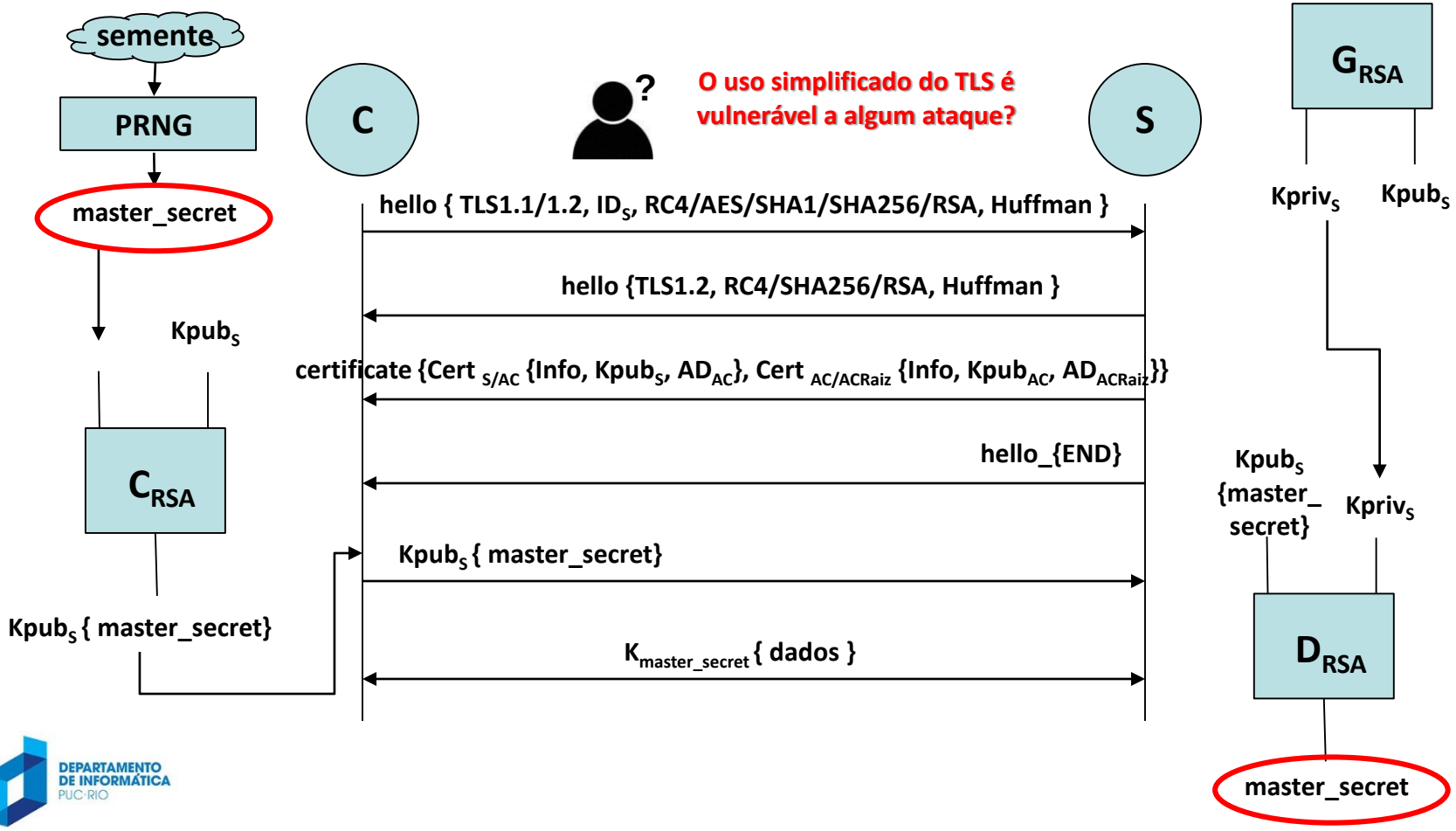
Secure Socket Layer (SSL) e Transport Layer Security (TLS): Operação – Fase Obrigatória



Os dados subsequentes são criptografados e autenticados com a chave simétrica derivada do segredo mestre.

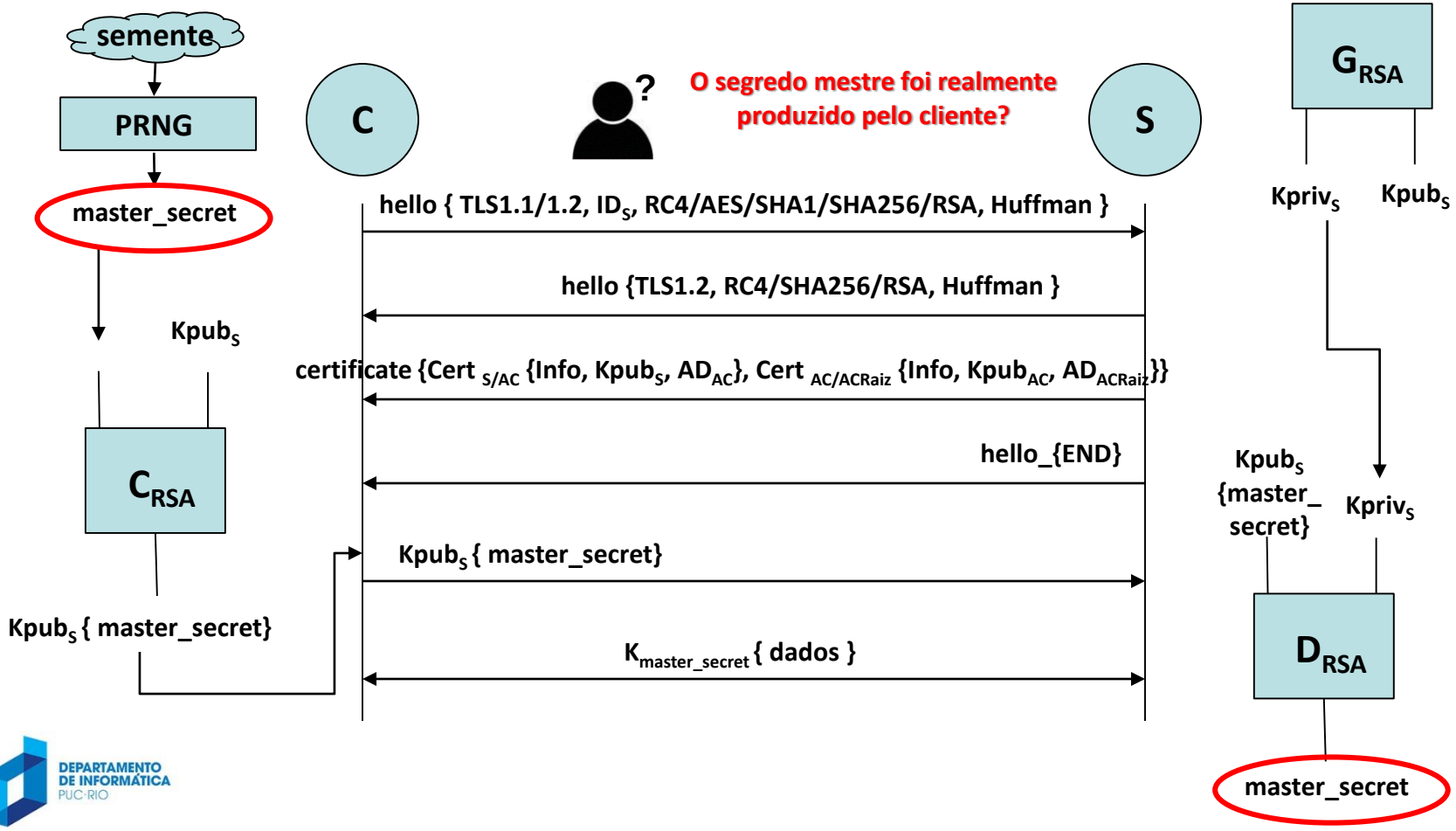
Comunicação Segura

Secure Socket Layer (SSL) e Transport Layer Security (TLS): Operação – Fase Obrigatória



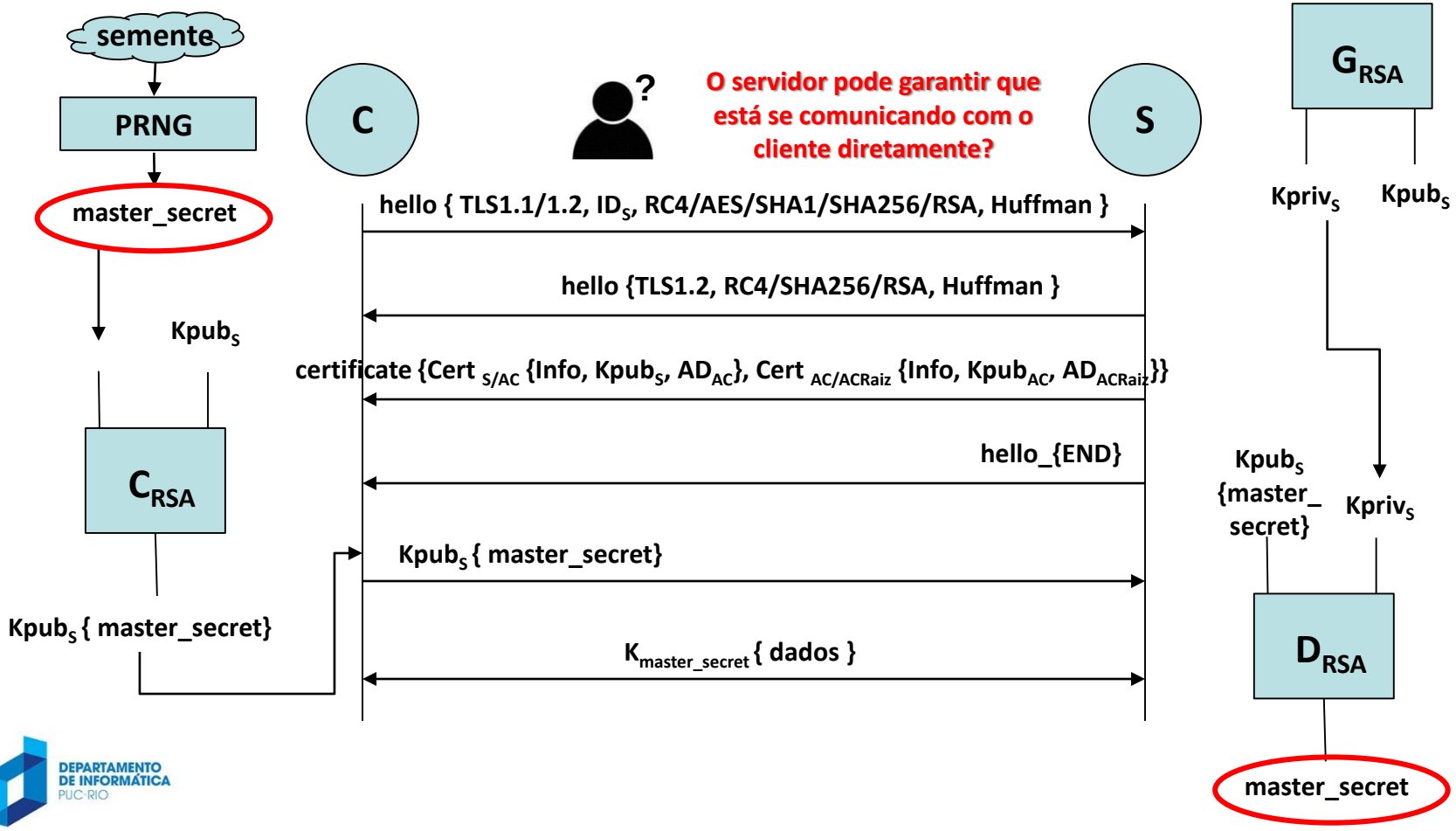
Comunicação Segura

Secure Socket Layer (SSL) e Transport Layer Security (TLS): Operação – Fase Obrigatória



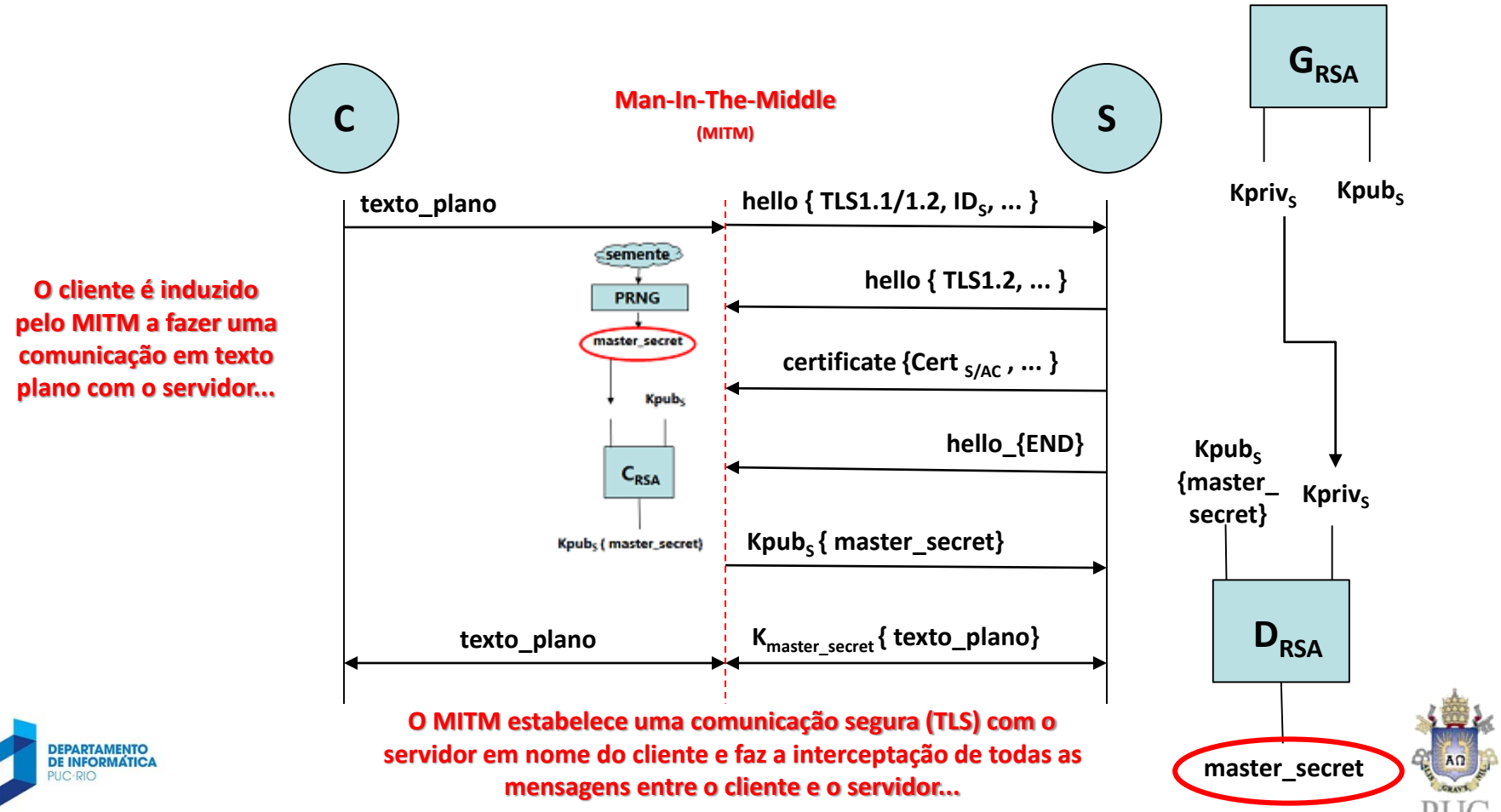
Comunicação Segura

Secure Socket Layer (SSL) e Transport Layer Security (TLS): Operação – Fase Obrigatória



Comunicação Segura

Secure Socket Layer (SSL) e Transport Layer Security (TLS): Operação – Fase Obrigatória

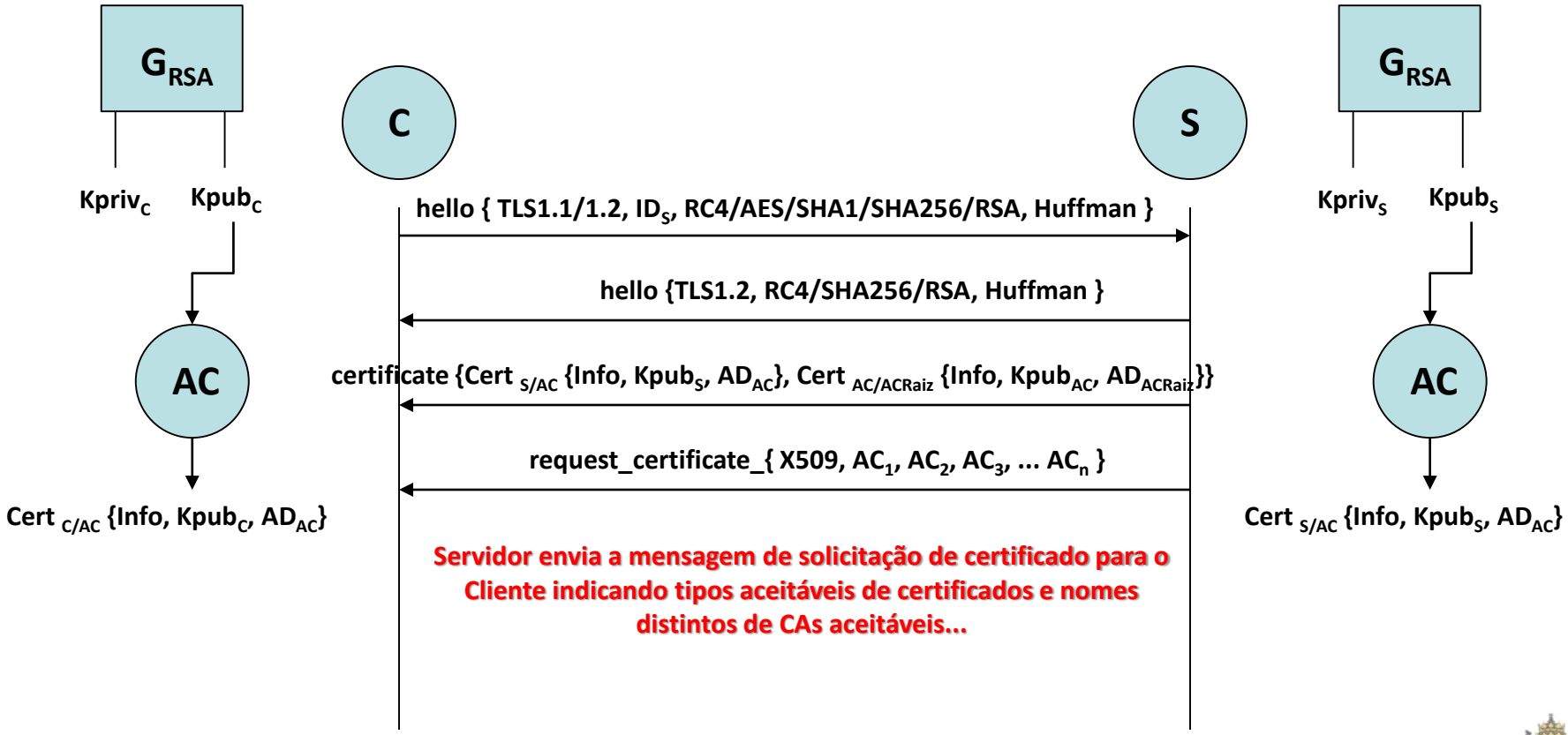


O cliente é induzido pelo MITM a fazer uma comunicação em texto plano com o servidor...

O MITM estabelece uma comunicação segura (TLS) com o servidor em nome do cliente e faz a interceptação de todas as mensagens entre o cliente e o servidor...

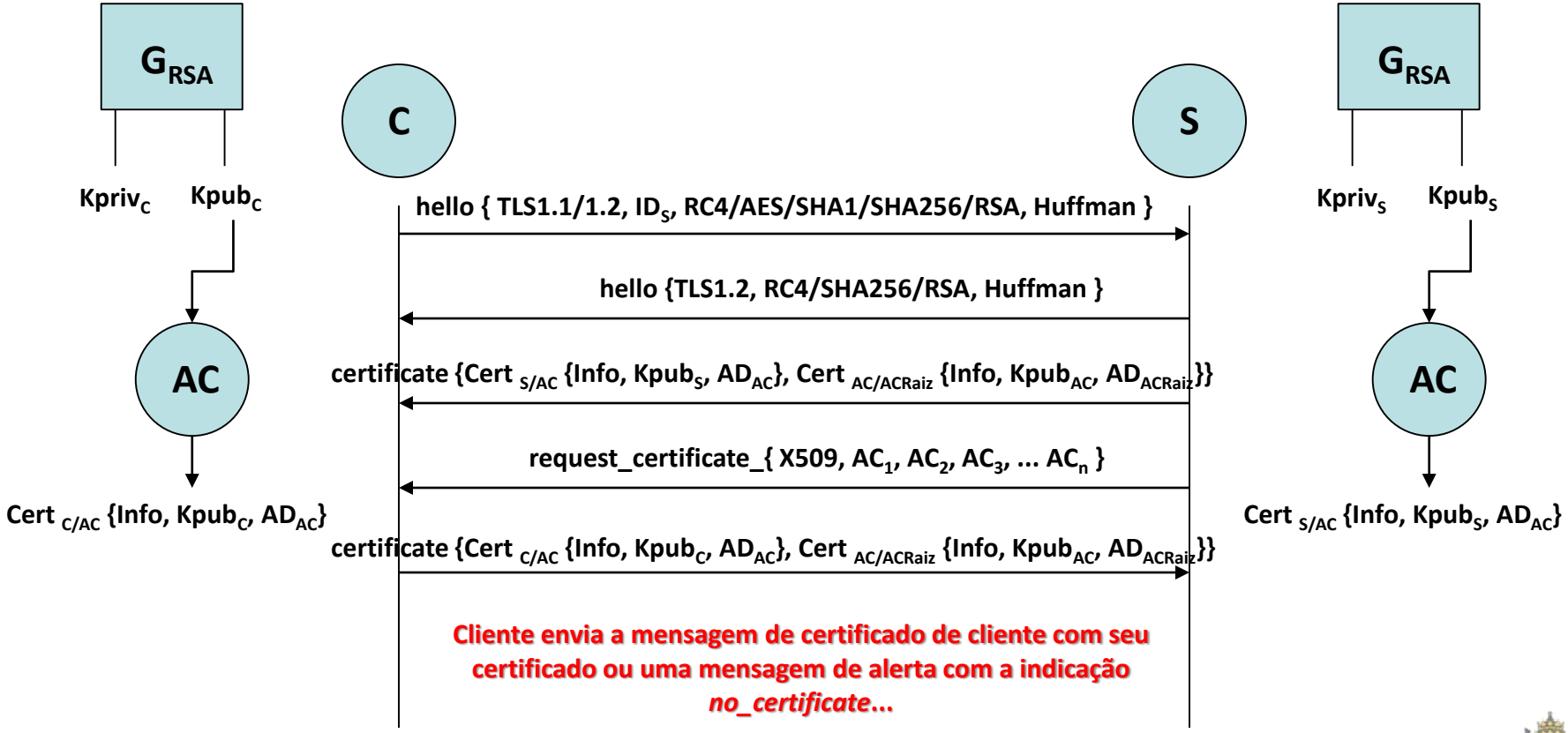
Comunicação Segura

Secure Socket Layer (SSL) e Transport Layer Security (TLS): Operação – Fase Opcional



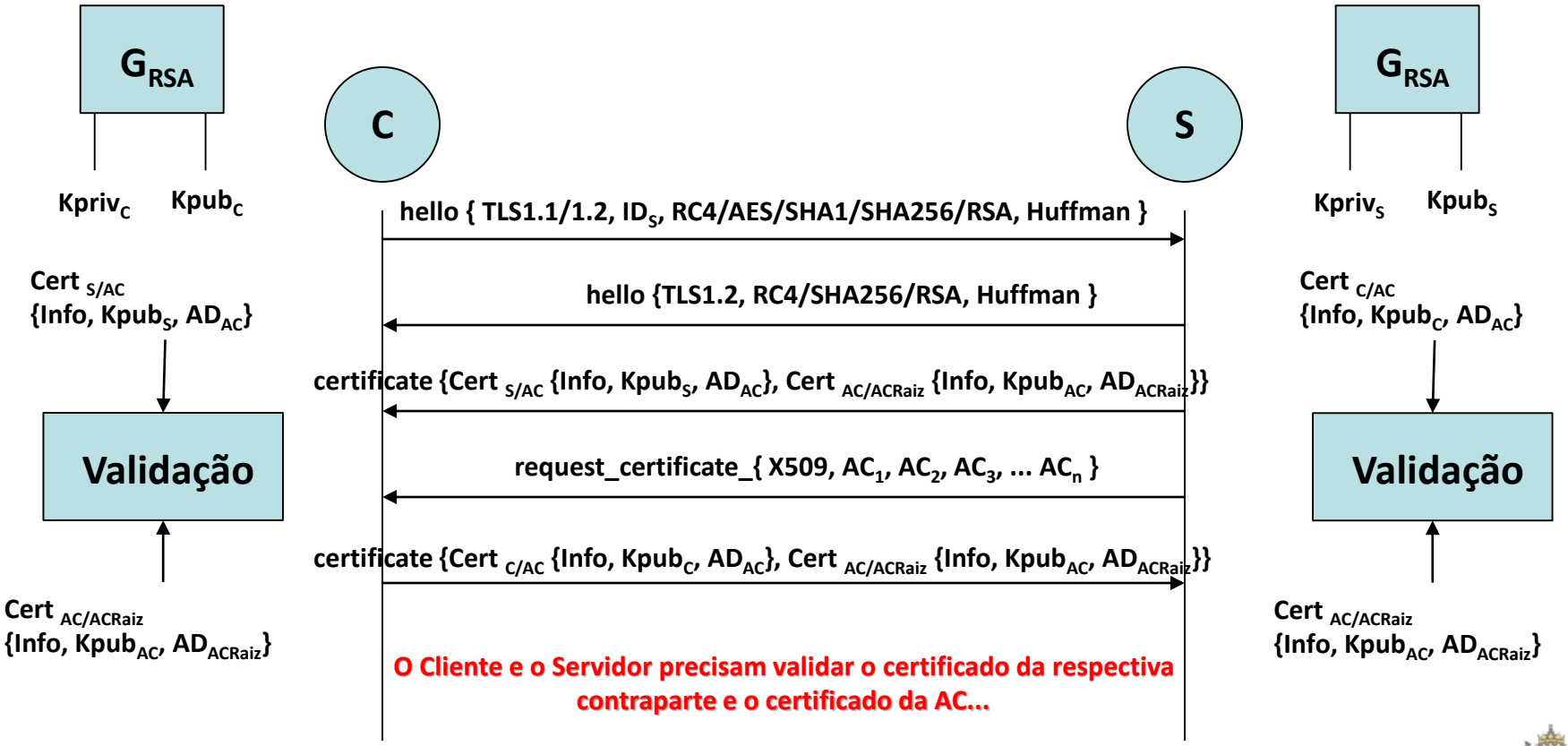
Comunicação Segura

Secure Socket Layer (SSL) e Transport Layer Security (TLS): Operação – Fase Opcional



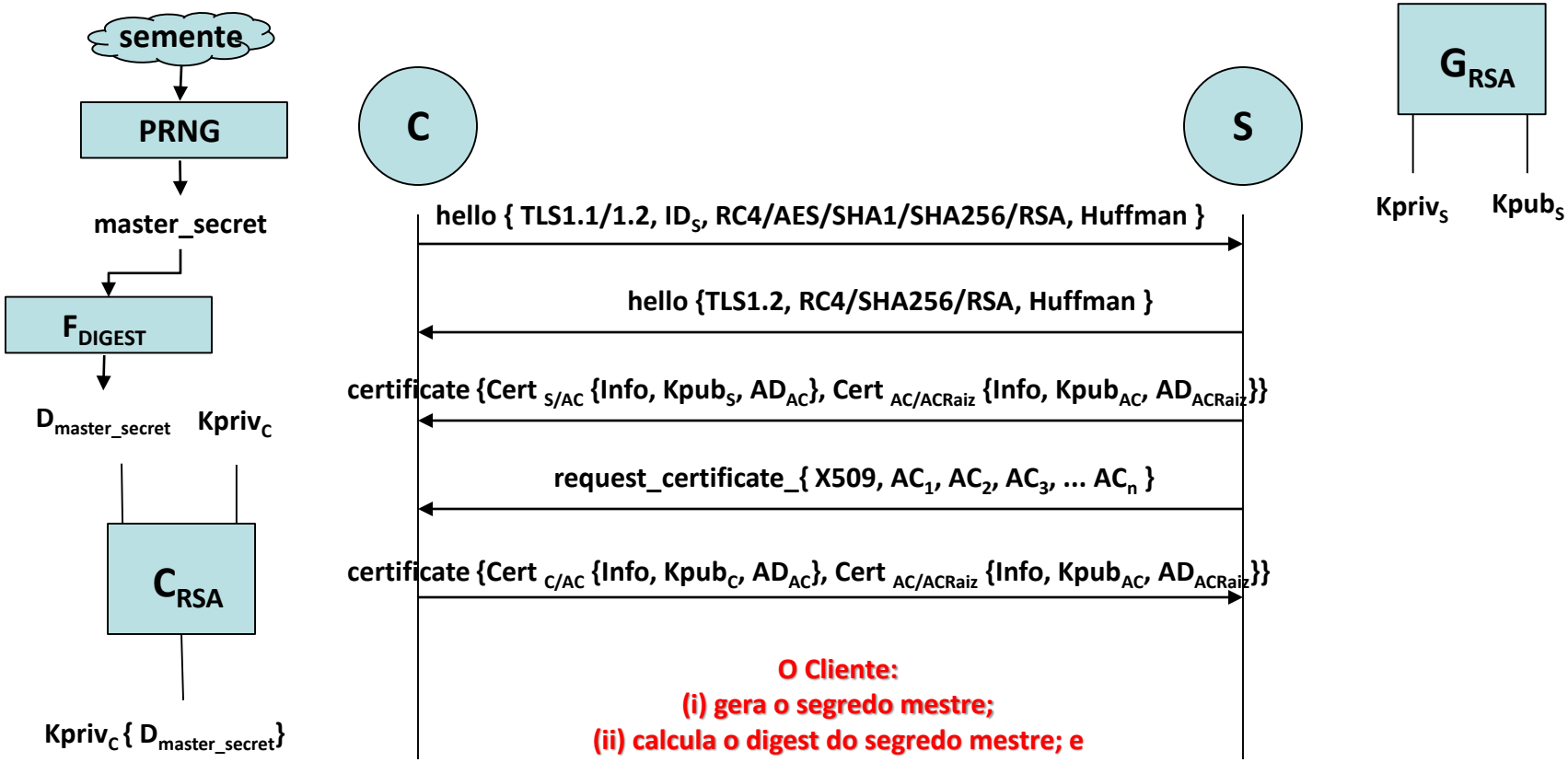
Comunicação Segura

Secure Socket Layer (SSL) e Transport Layer Security (TLS): Operação – Fase Opcional



Comunicação Segura

Secure Socket Layer (SSL) e Transport Layer Security (TLS): Operação – Fase Opcional



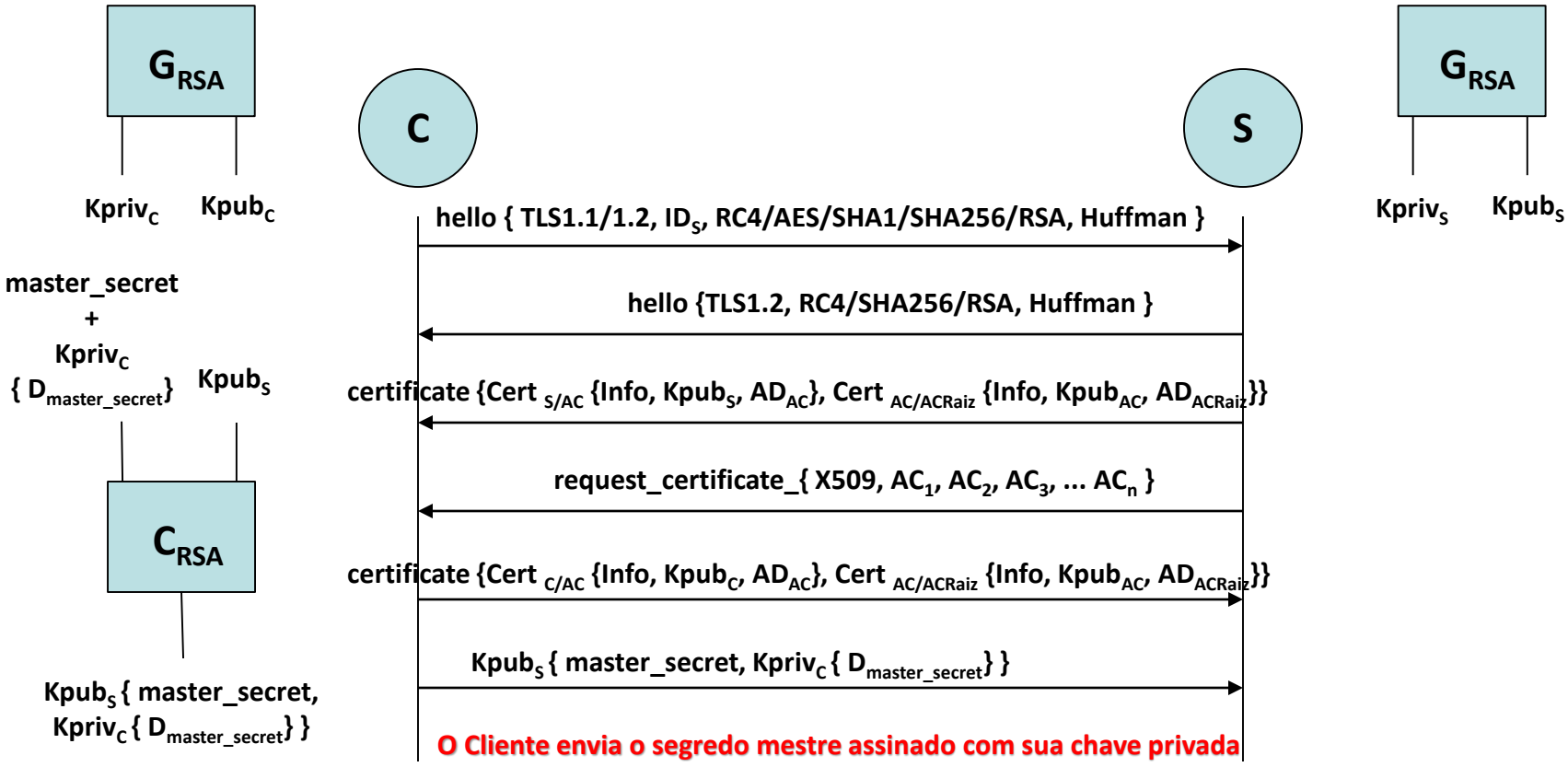
O Cliente:
(i) gera o segredo mestre;
(ii) calcula o digest do segredo mestre; e
(iii) Criptografa o digest com a sua chave privada (assinatura digital)...

DEPARTAMENTO DE INFORMÁTICA PUC-RIO

PUC RIO

Comunicação Segura

Secure Socket Layer (SSL) e Transport Layer Security (TLS): Operação – Fase Opcional



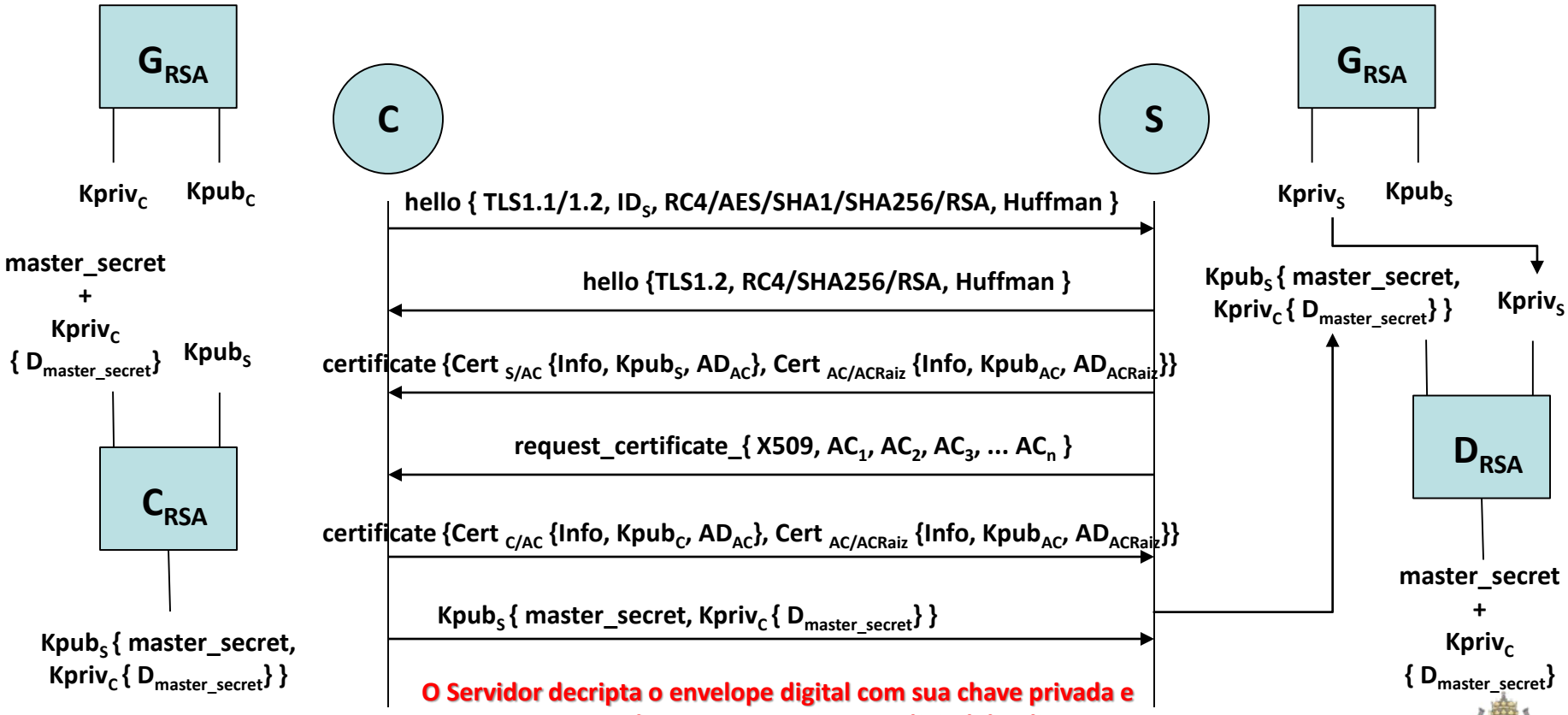
O Cliente envia o segredo mestre assinado com sua chave privada e criptografado com a chave pública do servidor (envelope digital)...

DEPARTAMENTO DE INFORMÁTICA PUC-RIO

PUC RIO

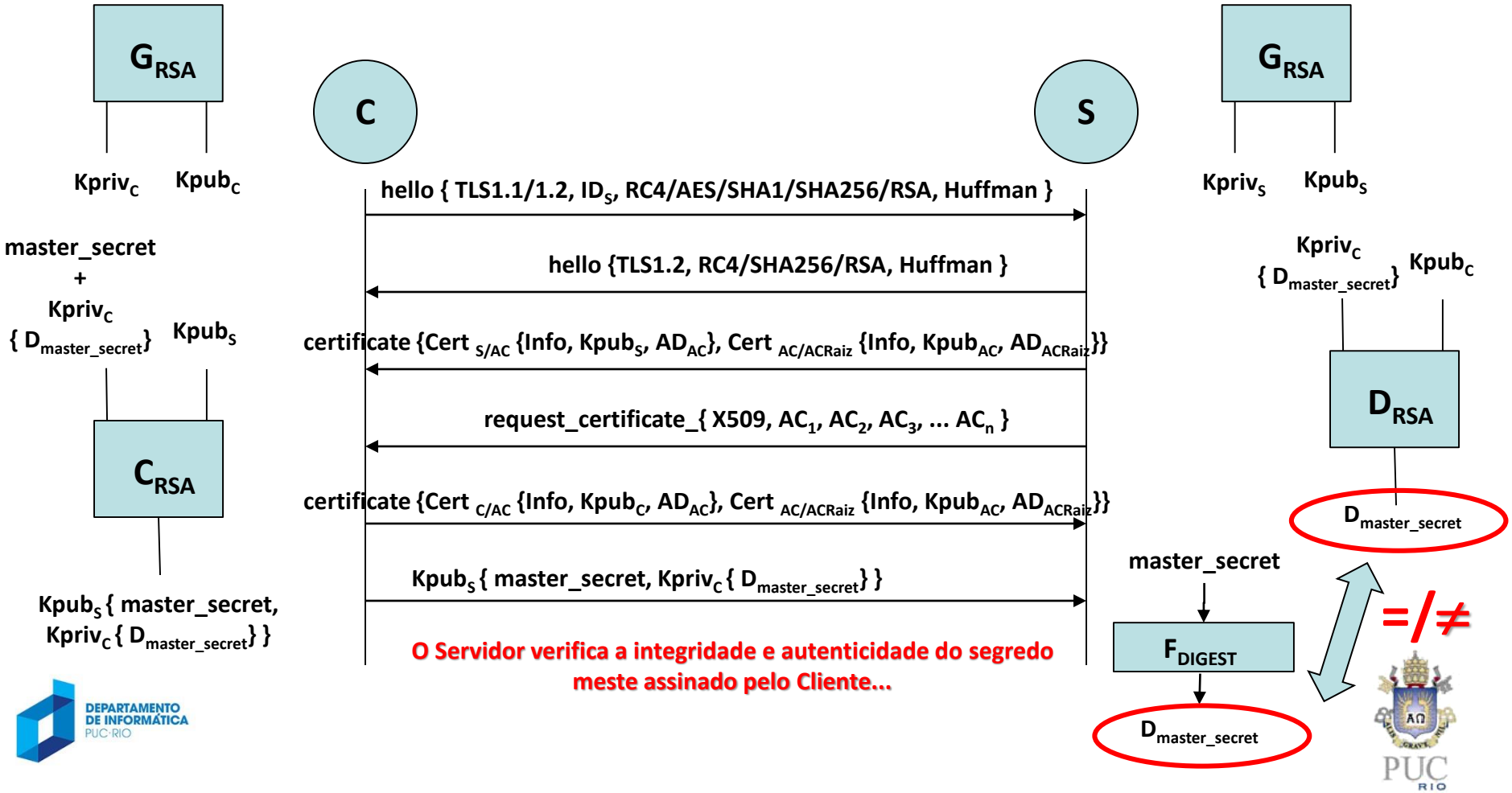
Comunicação Segura

Secure Socket Layer (SSL) e Transport Layer Security (TLS): Operação – Fase Opcional



Comunicação Segura

Secure Socket Layer (SSL) e Transport Layer Security (TLS): Operação – Fase Opcional

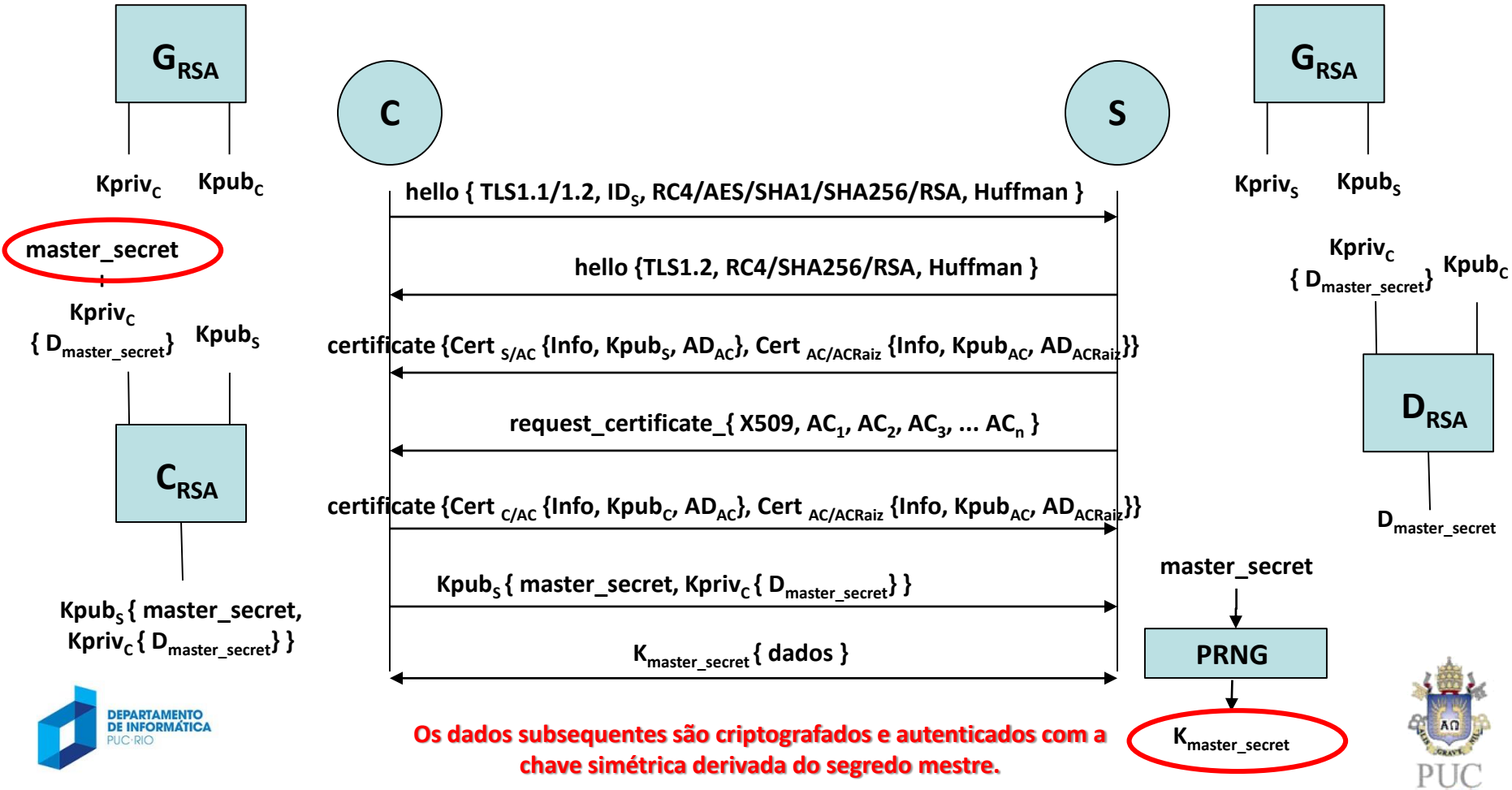


DEPARTAMENTO DE INFORMÁTICA PUC-RIO

PUC RIO

Comunicação Segura

Secure Socket Layer (SSL) e Transport Layer Security (TLS): Operação – Fase Opcional



Os dados subsequentes são criptografados e autenticados com a chave simétrica derivada do segredo mestre.

DEPARTAMENTO DE INFORMÁTICA PUC-RIO

PUC RIO

Comunicação Segura

Secure Socket Layer (SSL) e Transport Layer Security (TLS):

- **Algoritmos suportados:**
  - RSA (durante o processo de handshaking)
  - RC2, RC4, IDEA, AES, DES e triple-DES (após a troca de chaves)
  - MD5, SHA1, SHA256 e SHA512 para message-digest
  - Diffie-Hellman (especificação fortemente desencoraja sua utilização)

- **Certificado mais comum:**
  - Certificados de chave pública X.509

Comunicação Segura

Secure Eletronic Transaction (SET):

- Especificação aberta projetada para assegurar a integridade de transações utilizando cartões de crédito.

- Baseado nos esquemas tradicionais de garantia de integridade, autenticidade e confidencialidade.

- Objetivos:
  - Autenticar as entidades envolvidas nas operações de pagamento;
  - Prover a confidencialidade dos dados para pagamento;
  - Preservar a integridade dos dados para pagamento;
  - Definir os algoritmos e protocolos para estes serviços seguros.

Comunicação Segura

Secure Eletronic Transaction (SET):

- Define vários tipos de transação utilizadas para implementar não apenas o pagamento, mas outras partes do processo como registros e cancelamentos.

- O esquema de *assinatura dual* evita que a Loja visualize as informações de pagamento pessoais do Cliente e garante a autenticidade do pedido de compra feito pelo Cliente.

Comunicação Segura

Secure Eletronic Transaction (SET):

- Define seis tipos de participantes em uma operação de pagamento:
  - Clientes (Cardholder)
    - Interage com as Lojas utilizando um cartão de crédito autorizado e emitido por um Emissor.
  - Lojas (Merchant)
    - Representam pessoas ou organizações que comercializam bens ou serviços a Clientes.
  - Emissor (Issuer)
    - Instituição financeira (banco, por exemplo) que emite o cartão de crédito utilizado pelo Cliente.

Comunicação Segura

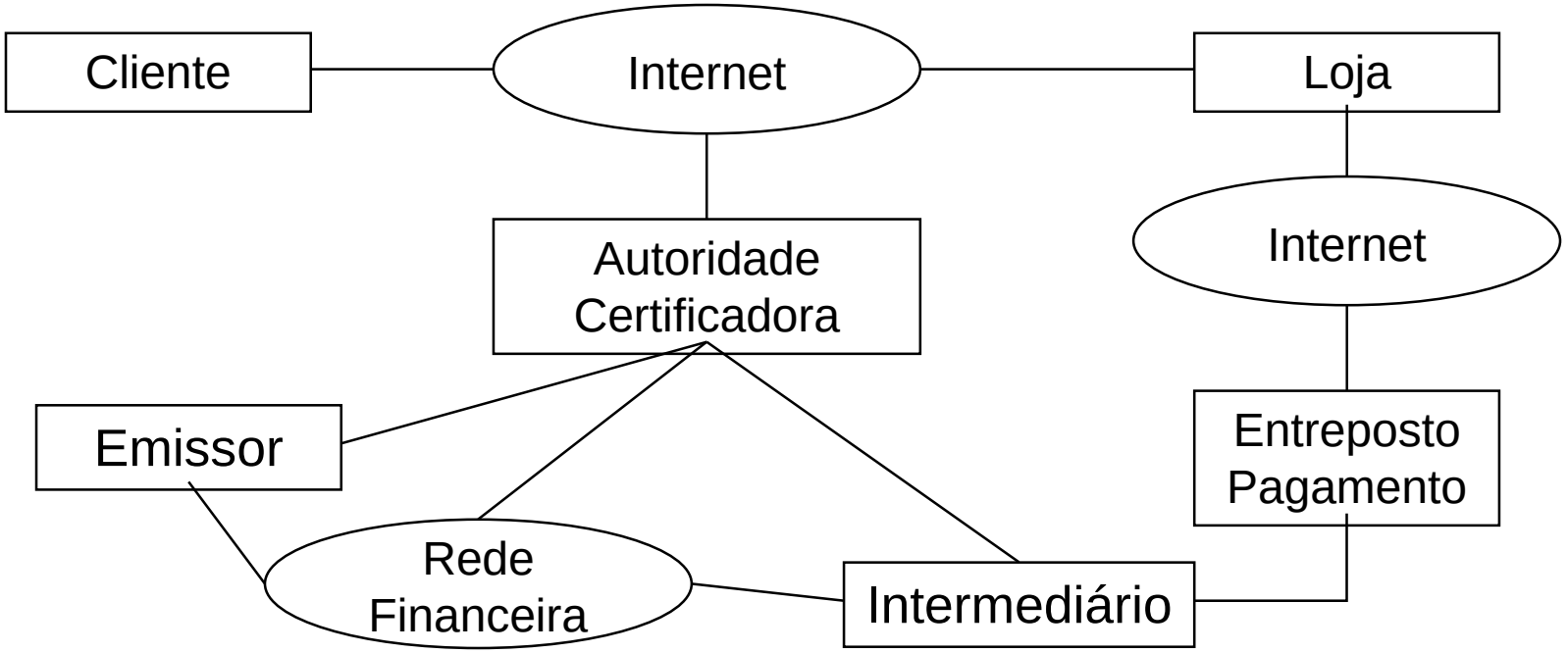
Secure Eletronic Transaction (SET):

- Define seis tipos de participantes em uma operação de pagamento (continuação):
  - Intermediário (Acquire)
    - Instituição financeira onde Lojas se associam com o objetivo de delegar o processo de autorizações de cartões de crédito e respectivos pagamentos, realizando transferência de fundos para as Lojas, sendo reembolsado pelo Emissor através de rede bancária.
  - Entreposto de Pagamento (Payment Gateway)
    - Responsável pela interconexão entre o ambiente SET (Loja) e as redes para transações utilizando cartões de crédito (Intermediário). Geralmente operado pelo próprio Intermediário ou prestador de serviço terceirizado.
  - Autoridade Certificadora
    - Entidade acreditada para a emissão de certificados digitais para Clientes, Lojas e Entreposto de Pagamento.

Comunicação Segura

Secure Eletronic Transaction (SET):

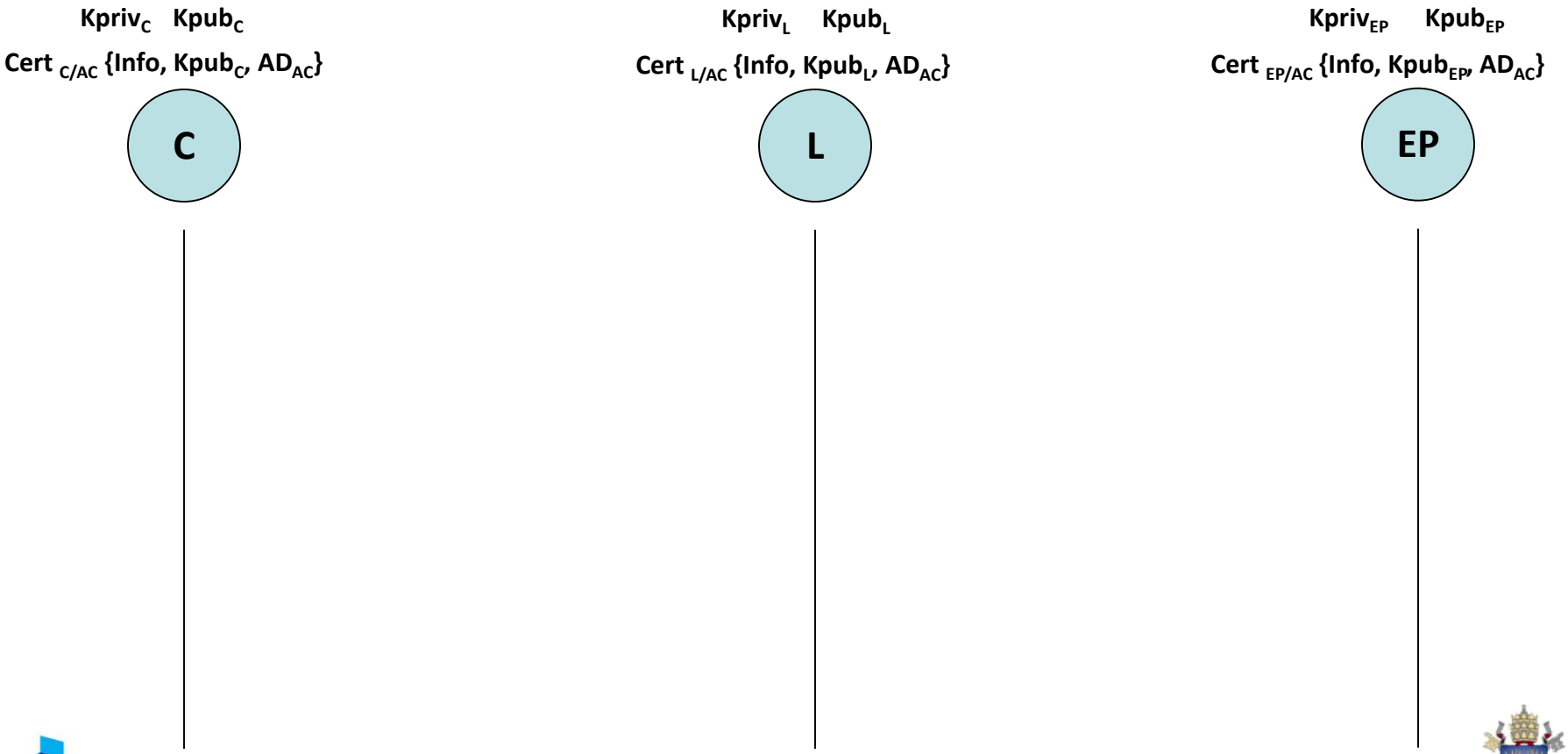
- **Participantes de uma operação de pagamento.**



Comunicação Segura

- Segurança da Informação
  Prof. Anderson O. da Silva

Secure Eletronic Transaction (SET) – Especificação 1.0: Requisição de Pagamento

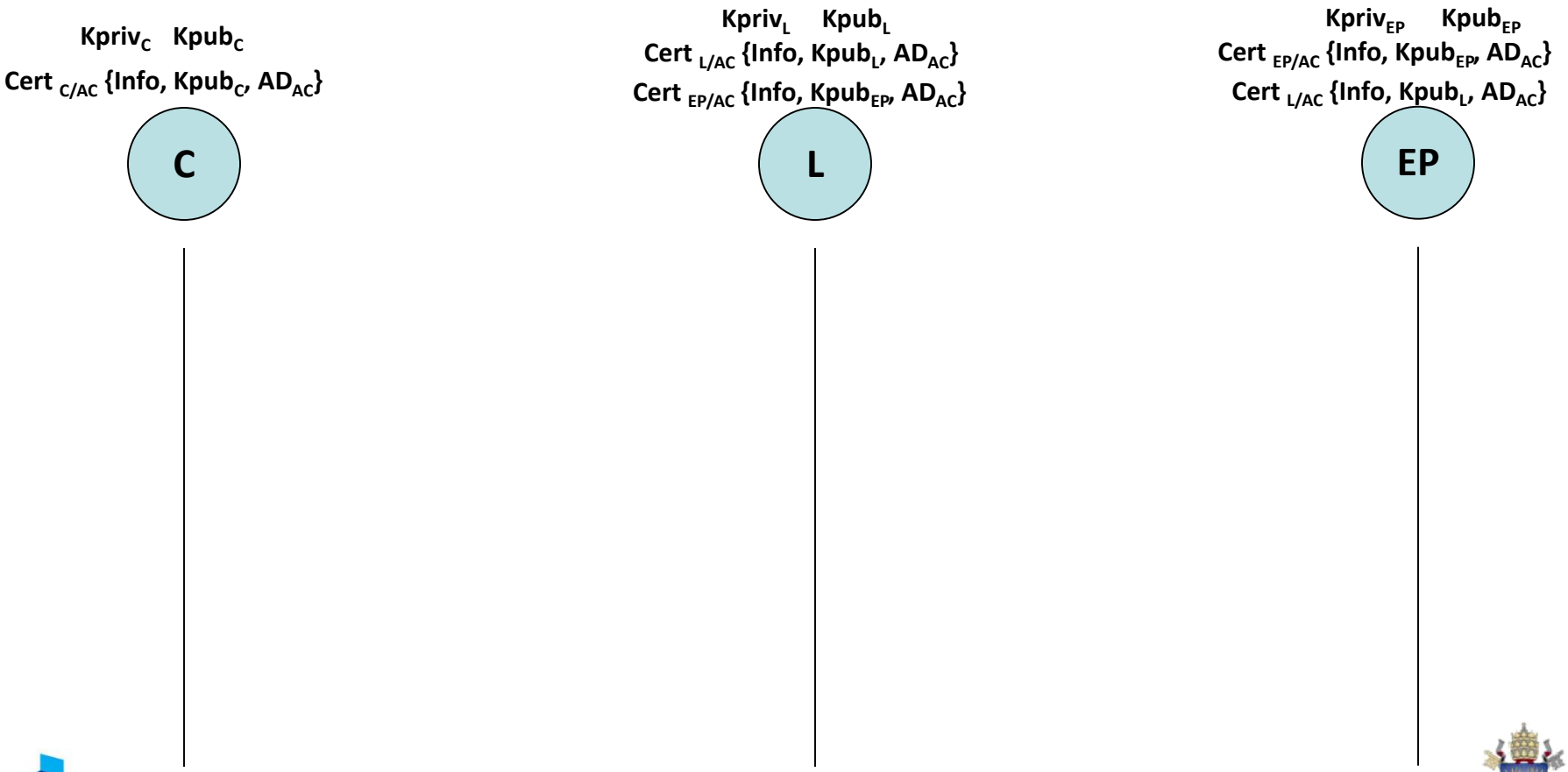


Todas as entidades possuem uma chave privada, uma chave pública e um certificado digital emitido por uma Autoridade Certificadora que todos confiam.

Comunicação Segura

- Segurança da Informação
  Prof. Anderson O. da Silva

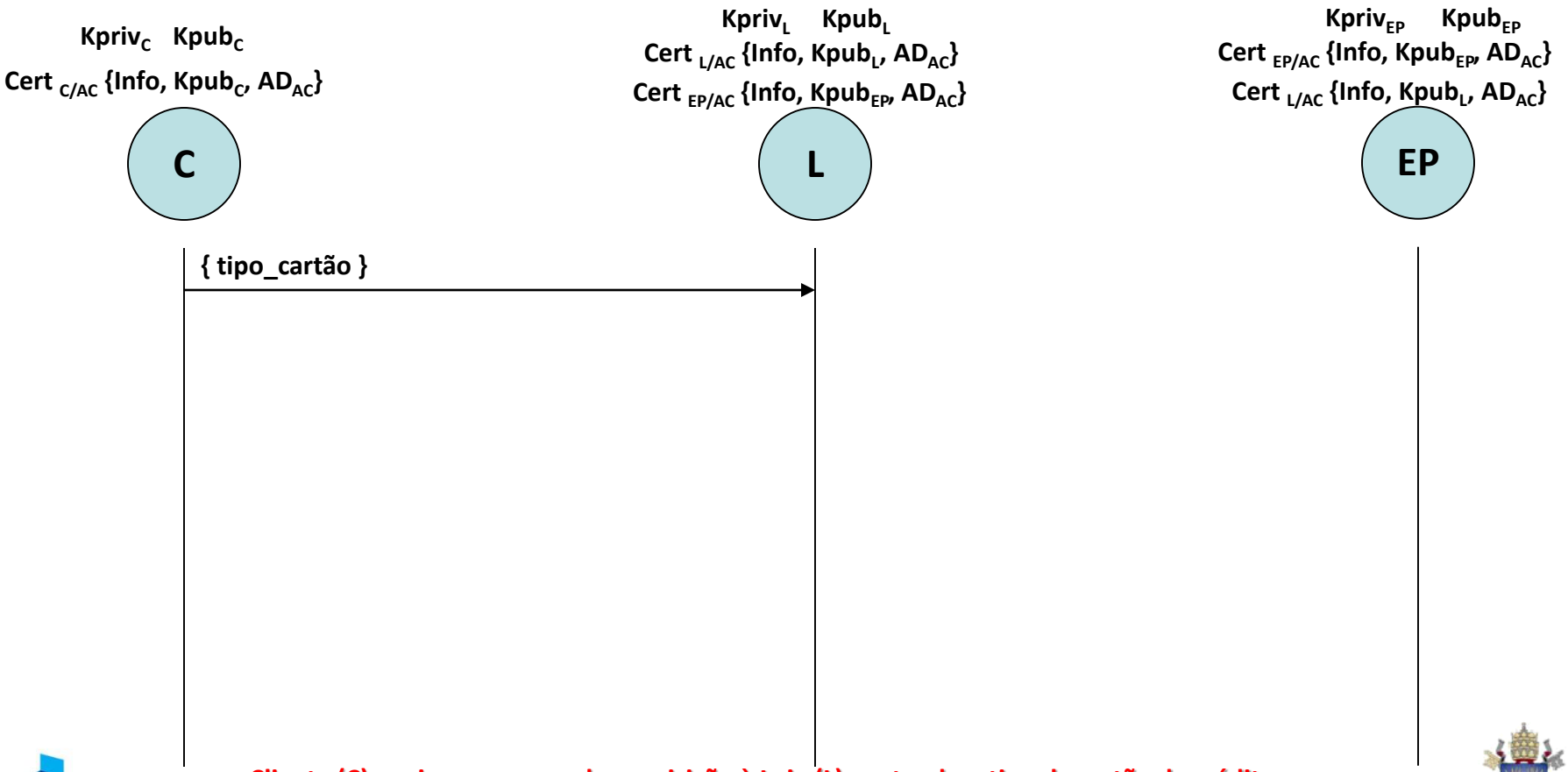
Secure Eletronic Transaction (SET) – Especificação 1.0: Requisição de Pagamento



A Loja (L) possui uma cópia do certificado digital do Entreposto de Pagamento (EP) contratada para realizar o serviço de transferência de fundos online, e vice-versa.

Comunicação Segura

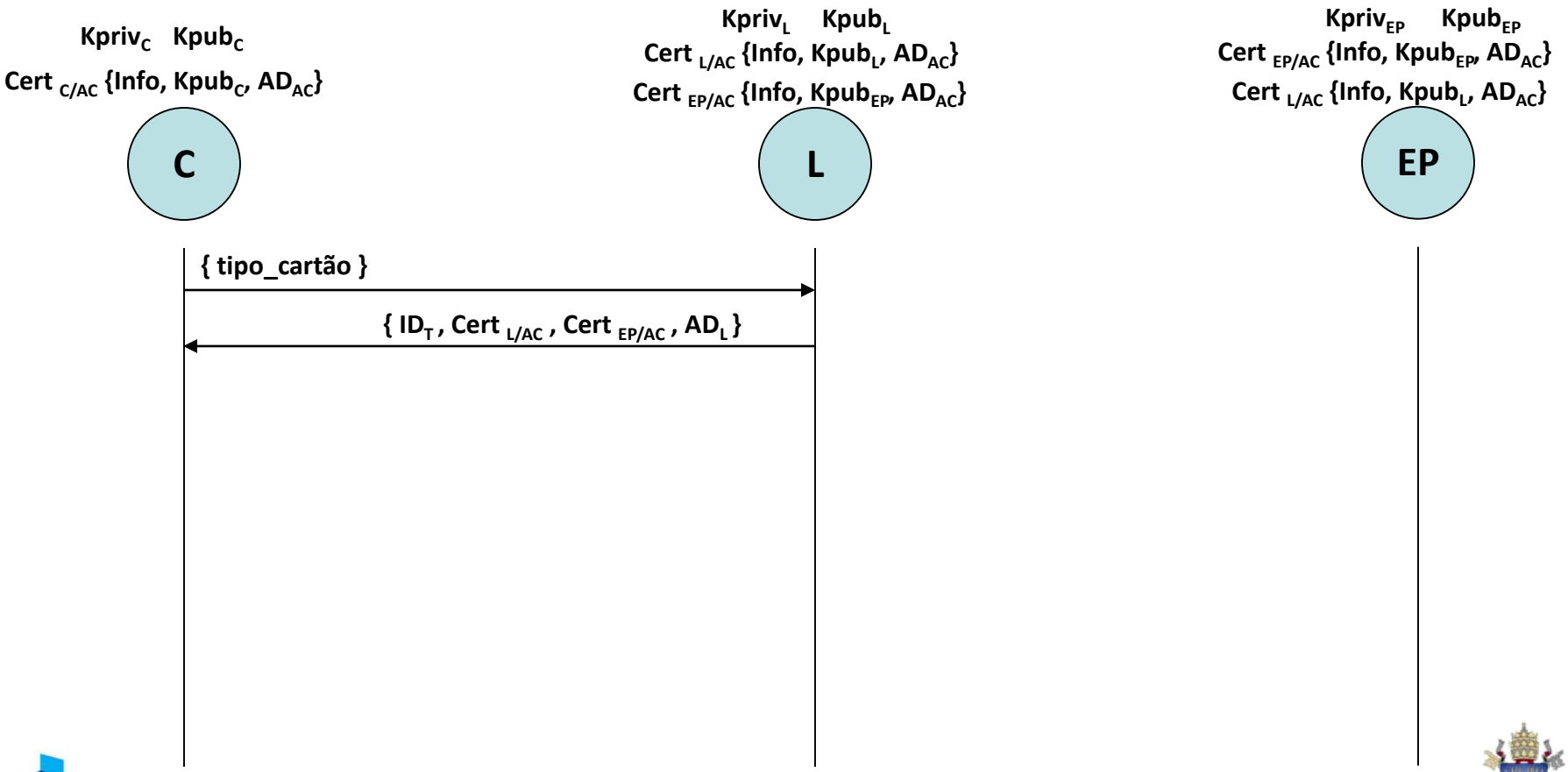
Secure Eletronic Transaction (SET) – Especificação 1.0: Requisição de Pagamento



Cliente (C) envia mensagem de requisição à Loja (L) contendo o tipo de cartão de crédito, com o objetivo de obter cópias dos certificados da Loja e do Entreposto de Pagamento (EP).

Comunicação Segura

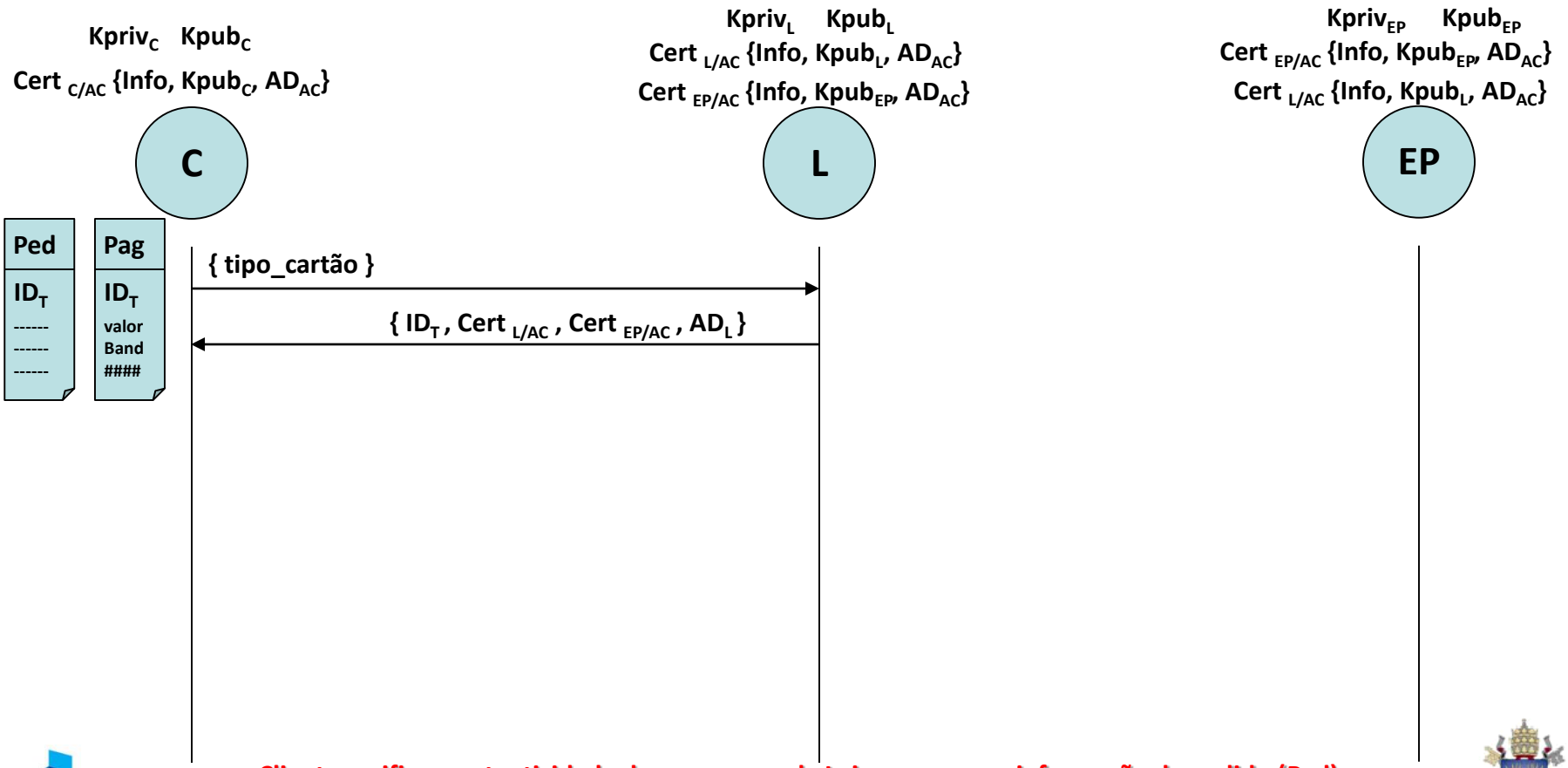
Secure Eletronic Transaction (SET) – Especificação 1.0: Requisição de Pagamento



Loja envia mensagem de resposta assinada (AD$_L$) contendo o identificador da transação (ID$_T$) e os dois certificados (Cert $_{L/AC}$, Cert $_{EP/AC}$).

Comunicação Segura

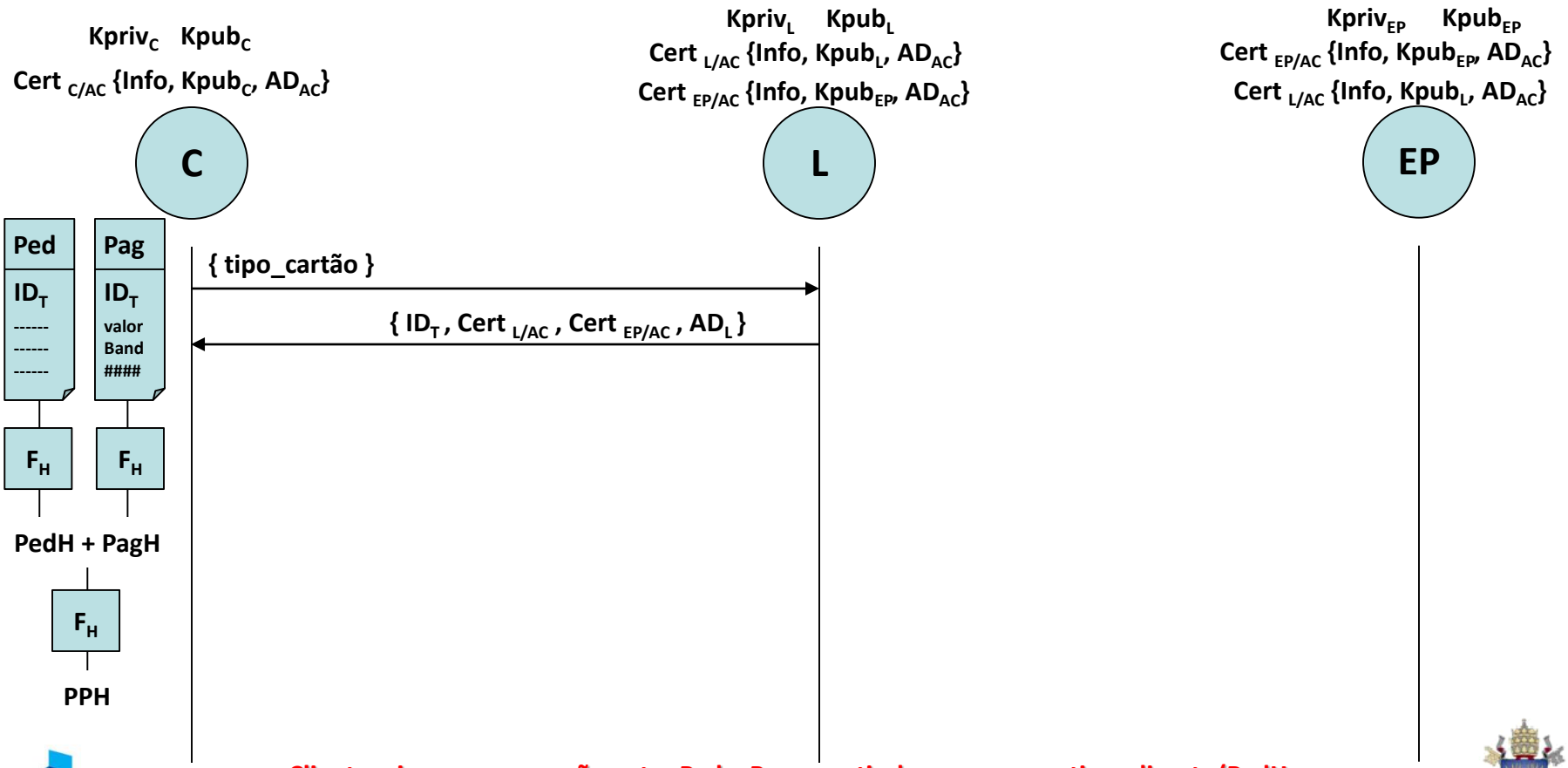
Secure Eletronic Transaction (SET) – Especificação 1.0: Requisição de Pagamento



Cliente verifica a autenticidade da mensagem da Loja e prepara a informação de pedido (Ped) e de pagamento (Pag) utilizando o identificador de transação (ID$_T$) provido pela Loja...

Comunicação Segura

Secure Eletronic Transaction (SET) – Especificação 1.0: Requisição de Pagamento



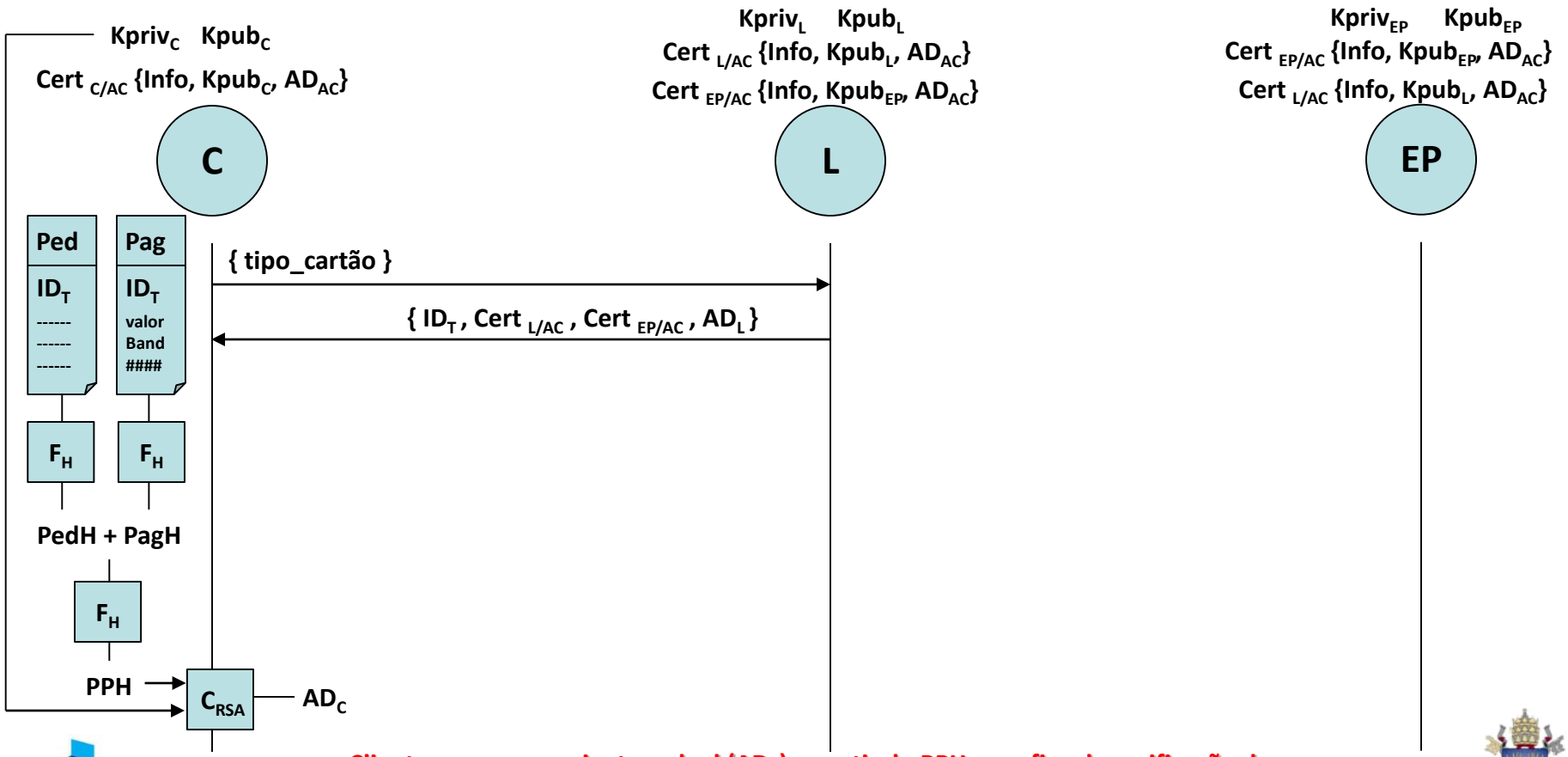
Cliente cria uma amarração entre Ped e Pag a partir dos seus respectivos digests (PedH e PagH). Esses digests são concatenados e outro digest (PPH) é calculado a partir dessa concatenação...

DEPARTAMENTO DE INFORMÁTICA PUC-RIO

PUC RIO

Comunicação Segura

Secure Eletronic Transaction (SET) – Especificação 1.0: Requisição de Pagamento



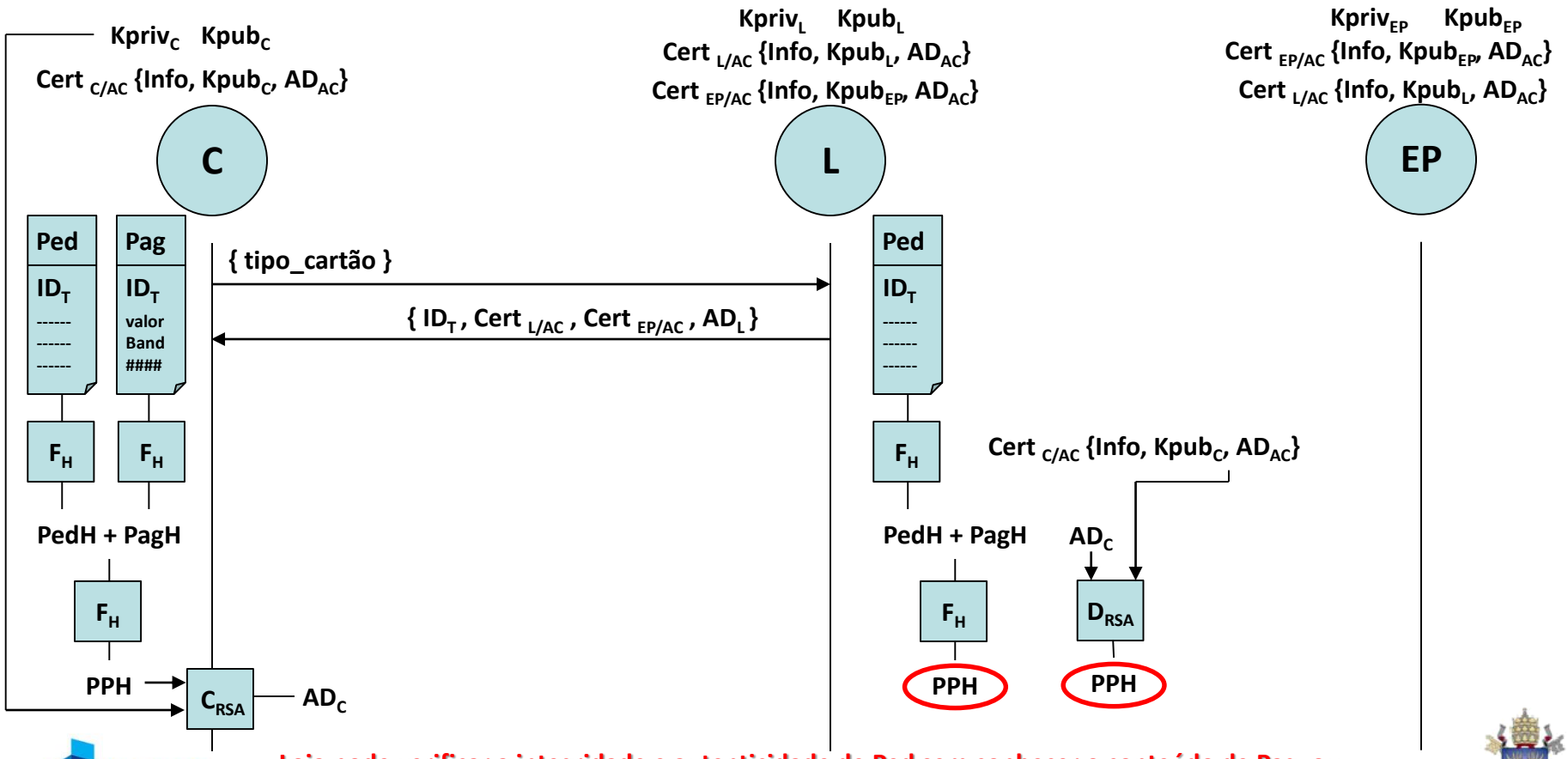
Cliente gera uma assinatura dual (AD$_C$) a partir do PPH para fins de verificação de autenticação, tanto pela Loja quanto pelo cliente, sem revelar o conteúdo de Pag para a Loja...

DEPARTAMENTO DE INFORMÁTICA PUC-RIO

PUC RIO

Comunicação Segura

Secure Eletronic Transaction (SET) – Especificação 1.0: Requisição de Pagamento



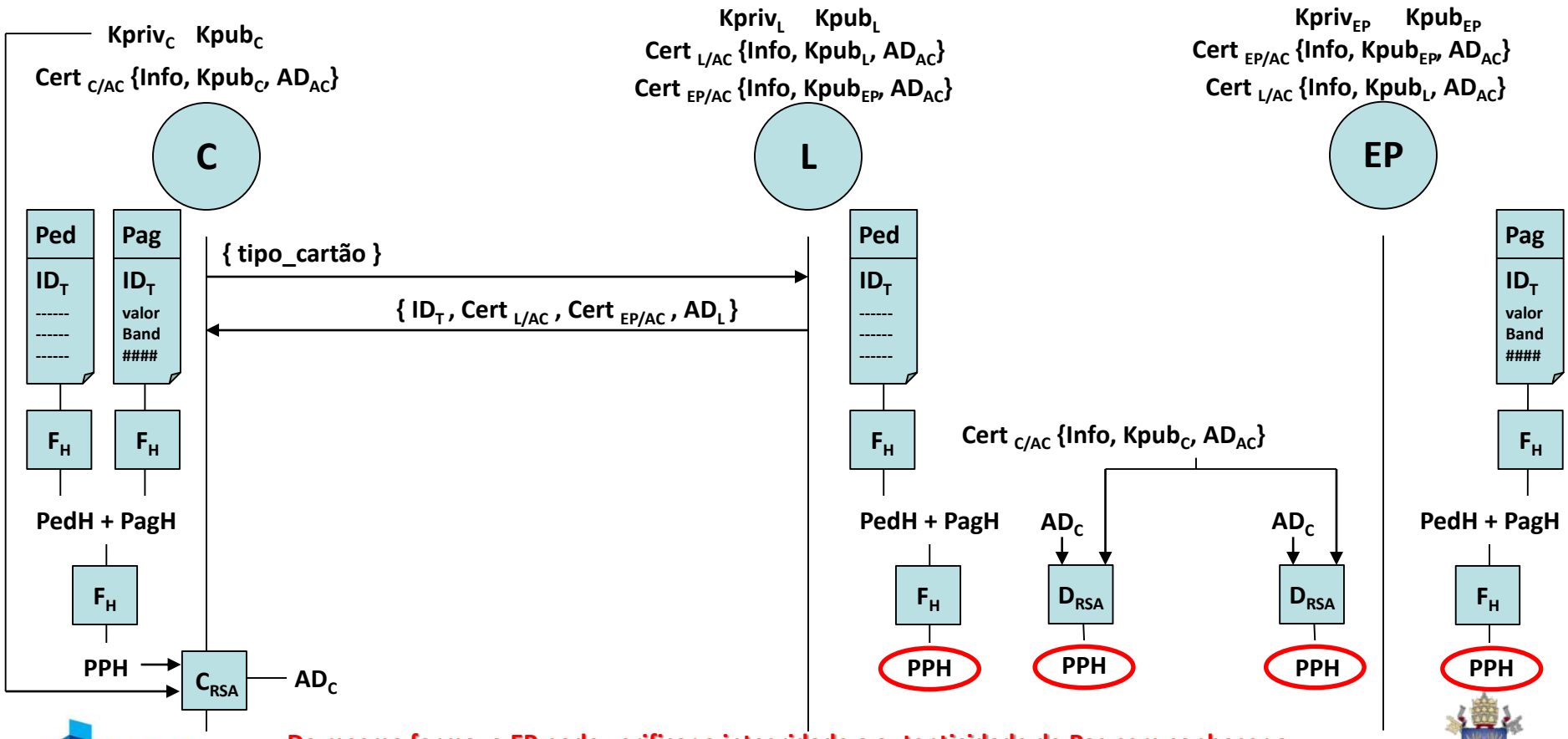
Loja pode verificar a integridade e autenticidade de Ped sem conhecer o conteúdo de Pag, ou seja, para fazer essa validação, a Loja precisa conhecer apenas o PagH, AD$_C$ e Cert $_{C/AC}$, que contém Kpub$_C$...

DEPARTAMENTO DE INFORMÁTICA PUC-RIO

PUC RIO

Comunicação Segura

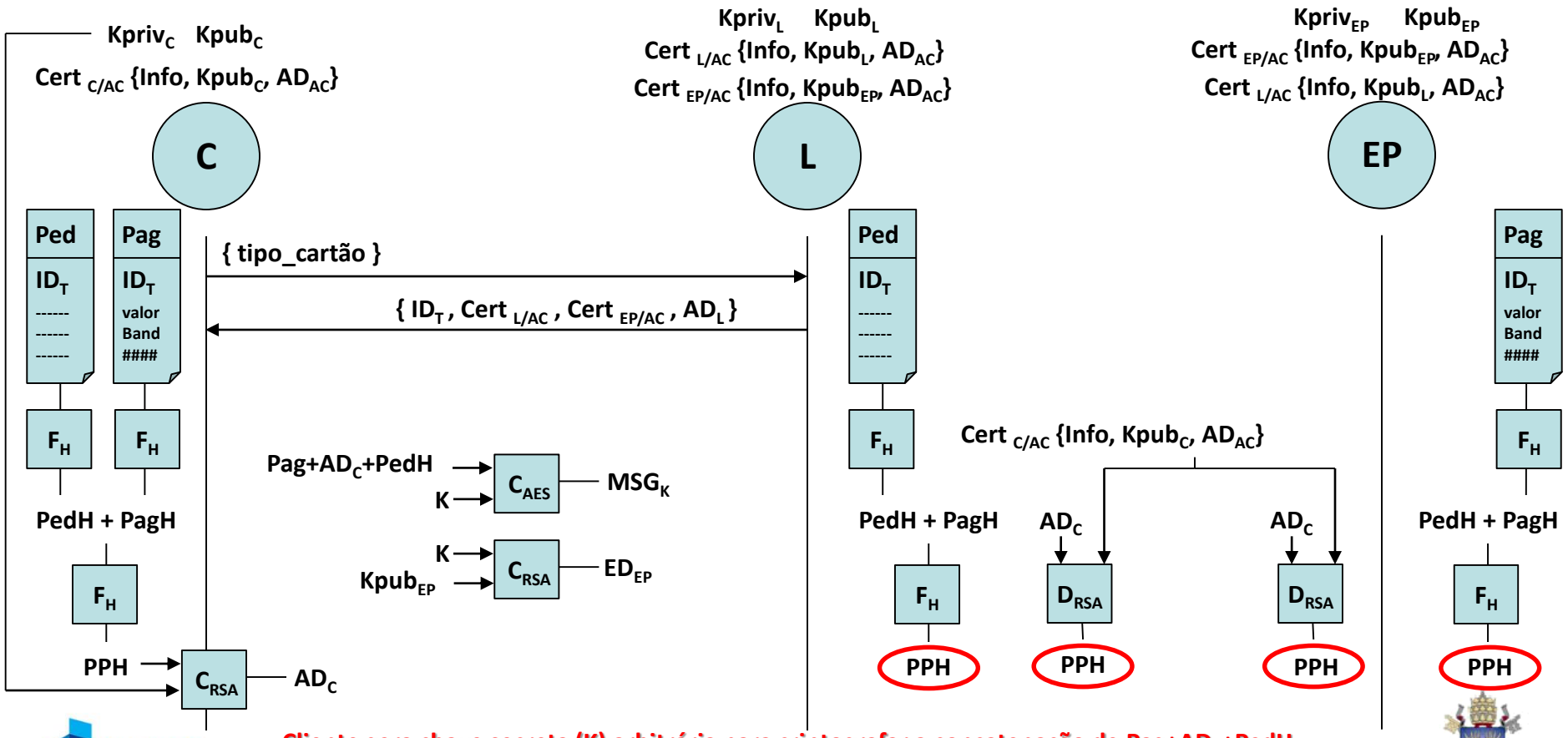
Secure Eletronic Transaction (SET) – Especificação 1.0: Requisição de Pagamento



Da mesma forma, o EP pode verificar a integridade e autenticidade de Pag sem conhecer o conteúdo de Ped, ou seja, para fazer essa validação, o EP precisa conhecer apenas o PedH, AD$_C$ e Cert $_{C/AC}$, que contém Kpub$_C$...

Comunicação Segura

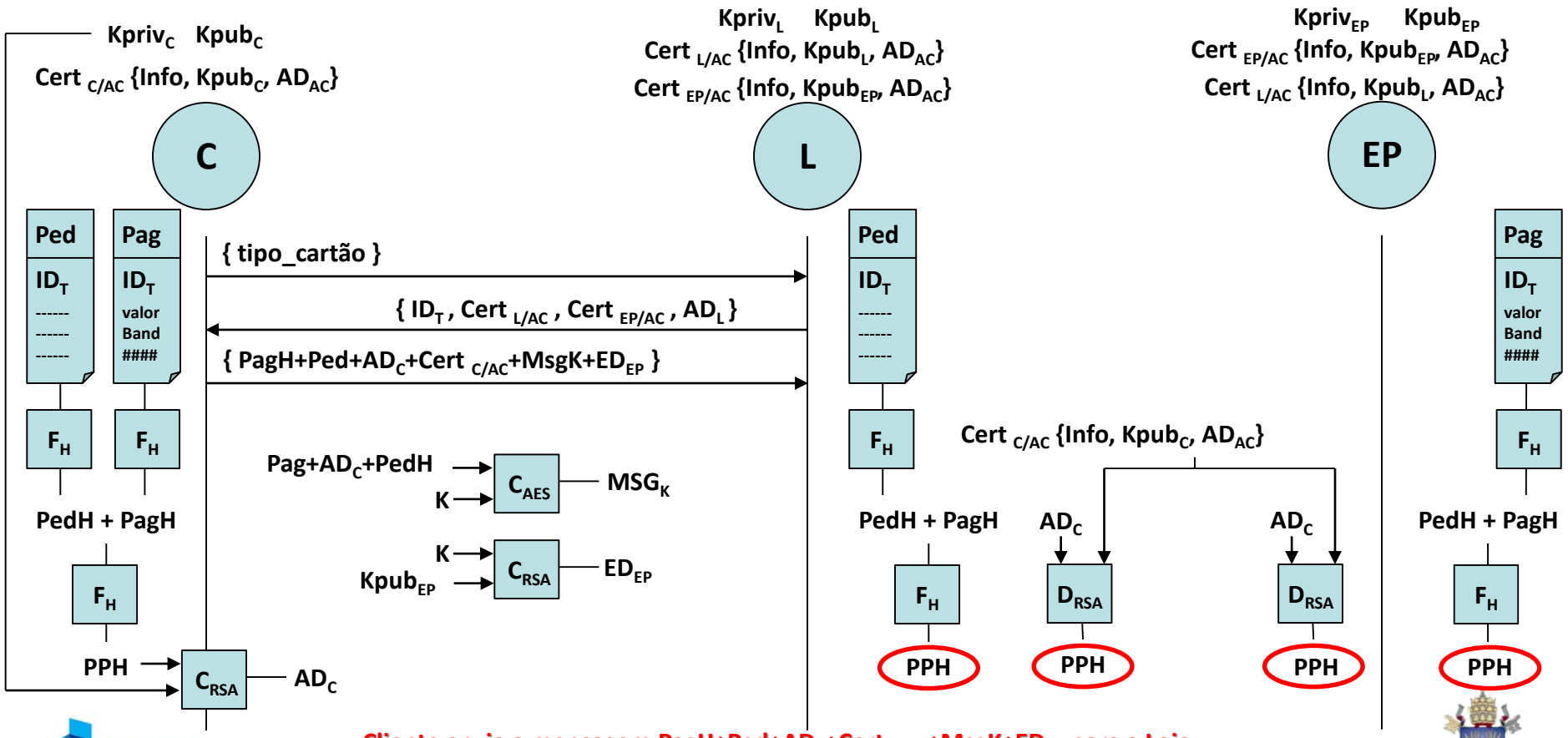
Secure Eletronic Transaction (SET) – Especificação 1.0: Requisição de Pagamento



Cliente gera chave secreta (K) arbitrária para criptografar a concatenação de Pag+AD$_C$+PedH (MsgK). Em seguida, criptografa a chave secreta K com a chave pública do EP gerando o envelope digital (ED)...

Comunicação Segura

Secure Eletronic Transaction (SET) – Especificação 1.0: Requisição de Pagamento



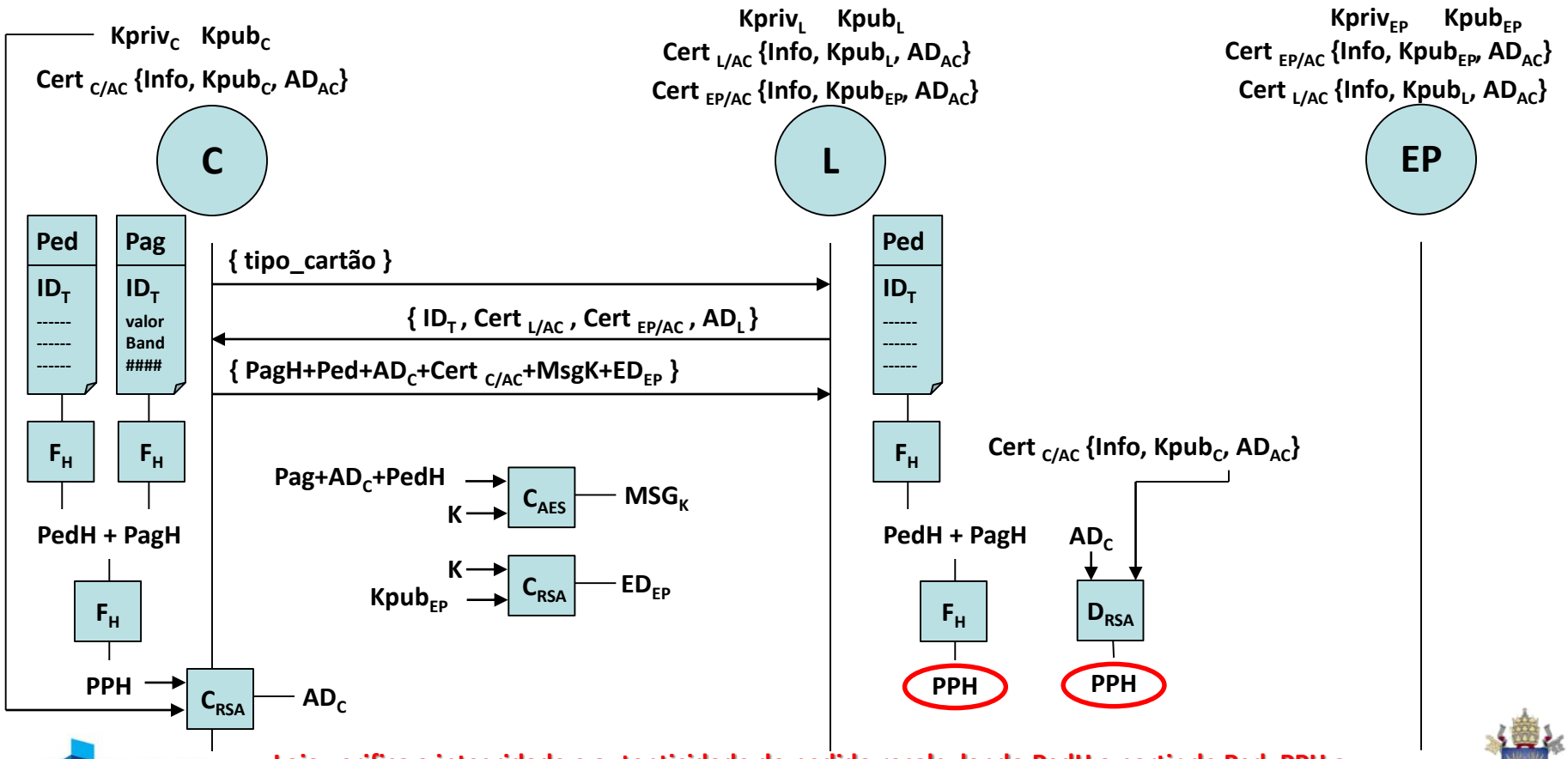
Cliente envia a mensagem PagH+Ped+AD$_C$+Cert $_{C/AC}$+MsgK+ED$_{EP}$ para a Loja...

DEPARTAMENTO DE INFORMÁTICA PUC·RIO

PUC RIO

Comunicação Segura

Secure Eletronic Transaction (SET) – Especificação 1.0: Requisição de Pagamento



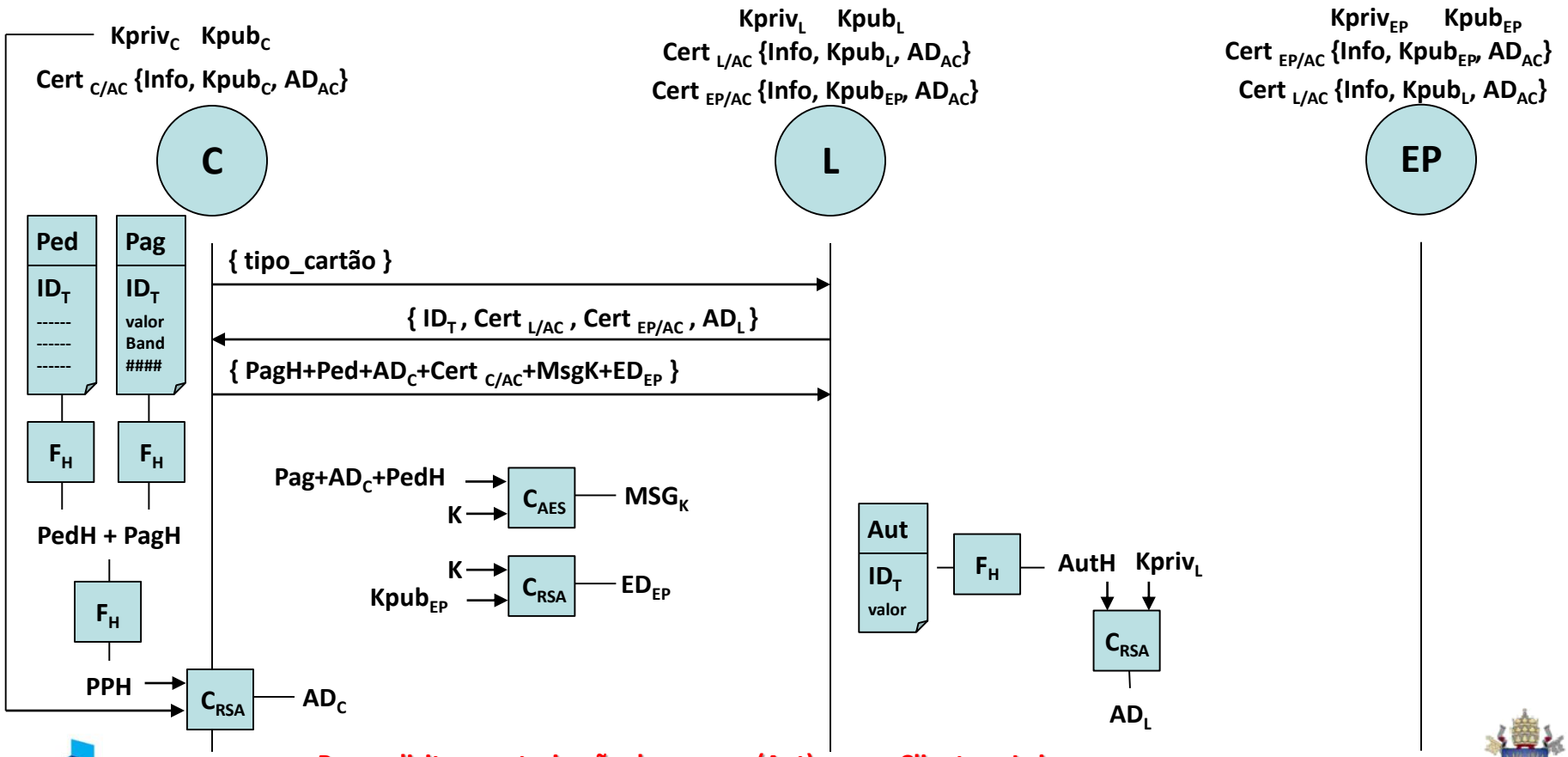
Loja verifica a integridade e autenticidade do pedido recalculando PedH a partir de Ped, PPH a partir de PagH+PedH calculado e comparando PPH com o PPH obtido a partir da decriptação de AD$_C$ com a chave pública do Cliente (Kpub$_C$). ...

DEPARTAMENTO DE INFORMÁTICA PUC-RIO

PUC RIO

Comunicação Segura

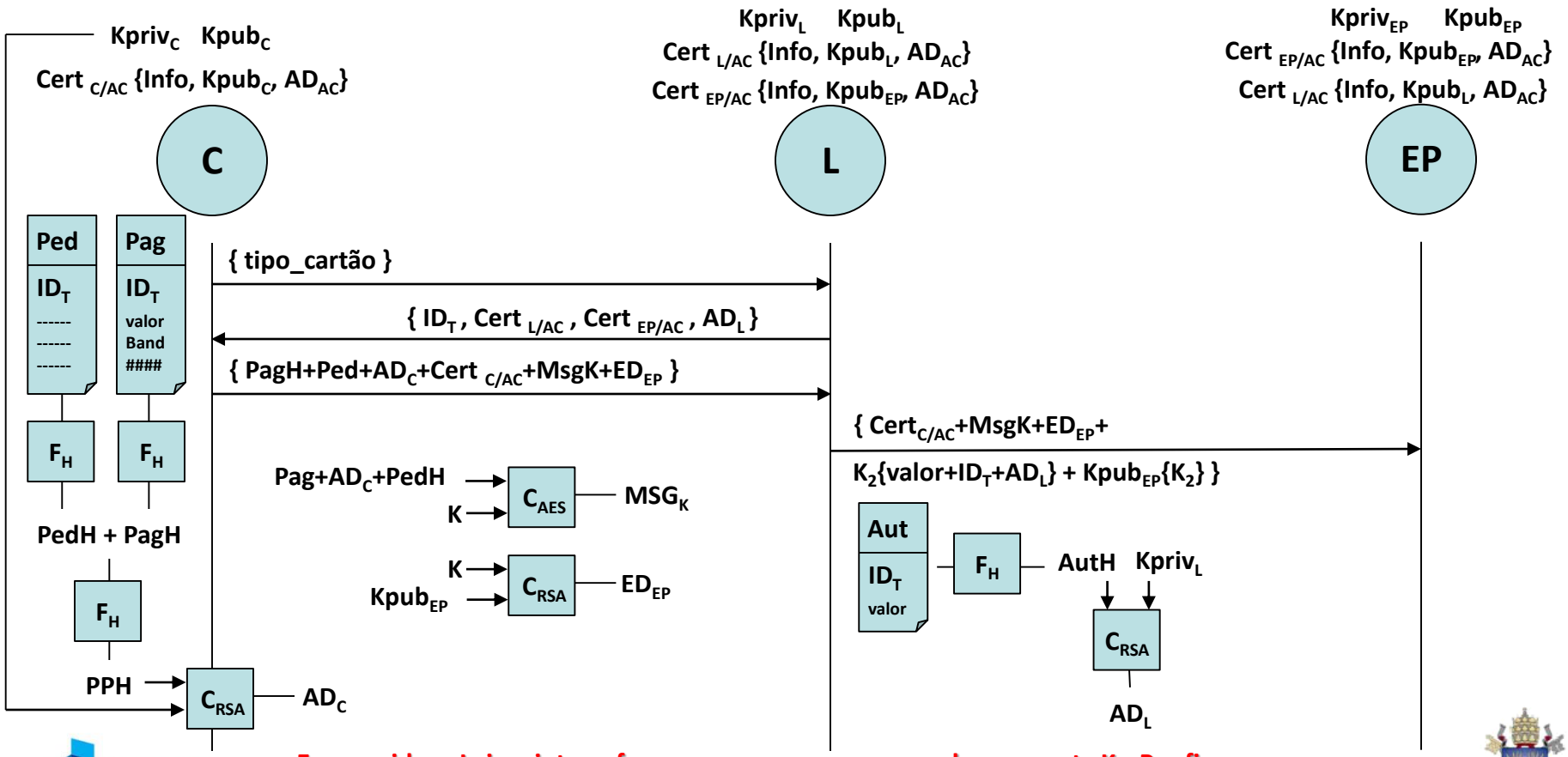
Secure Eletronic Transaction (SET) – Especificação 1.0: Requisição de Pagamento



Para solicitar a autorização de compra (Aut) para o Cliente, a Loja gera uma mensagem assinada com o valor da compra e o identificador de transação...

Comunicação Segura

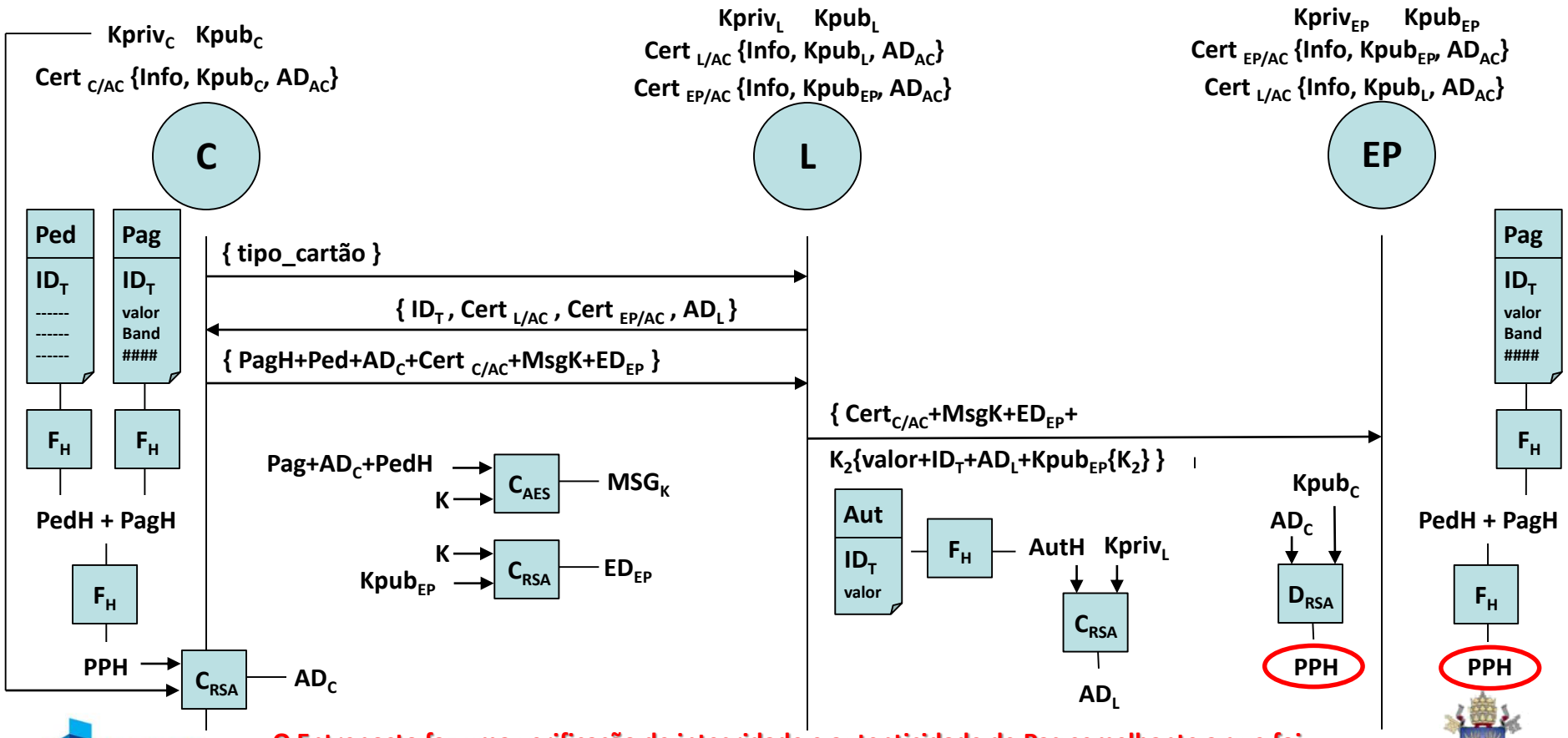
Secure Eletronic Transaction (SET) – Especificação 1.0: Requisição de Pagamento



Em seguida, a Loja criptografa essa mensagem com uma chave secreta K_2. Por fim, repassa para o Entreposto: $Cert_{C/AC}+MsgK+ED_{EP}+K_2\{valor+ID_T+AD_L\}+Kpub_{EP}\{K_2\}$...

Comunicação Segura

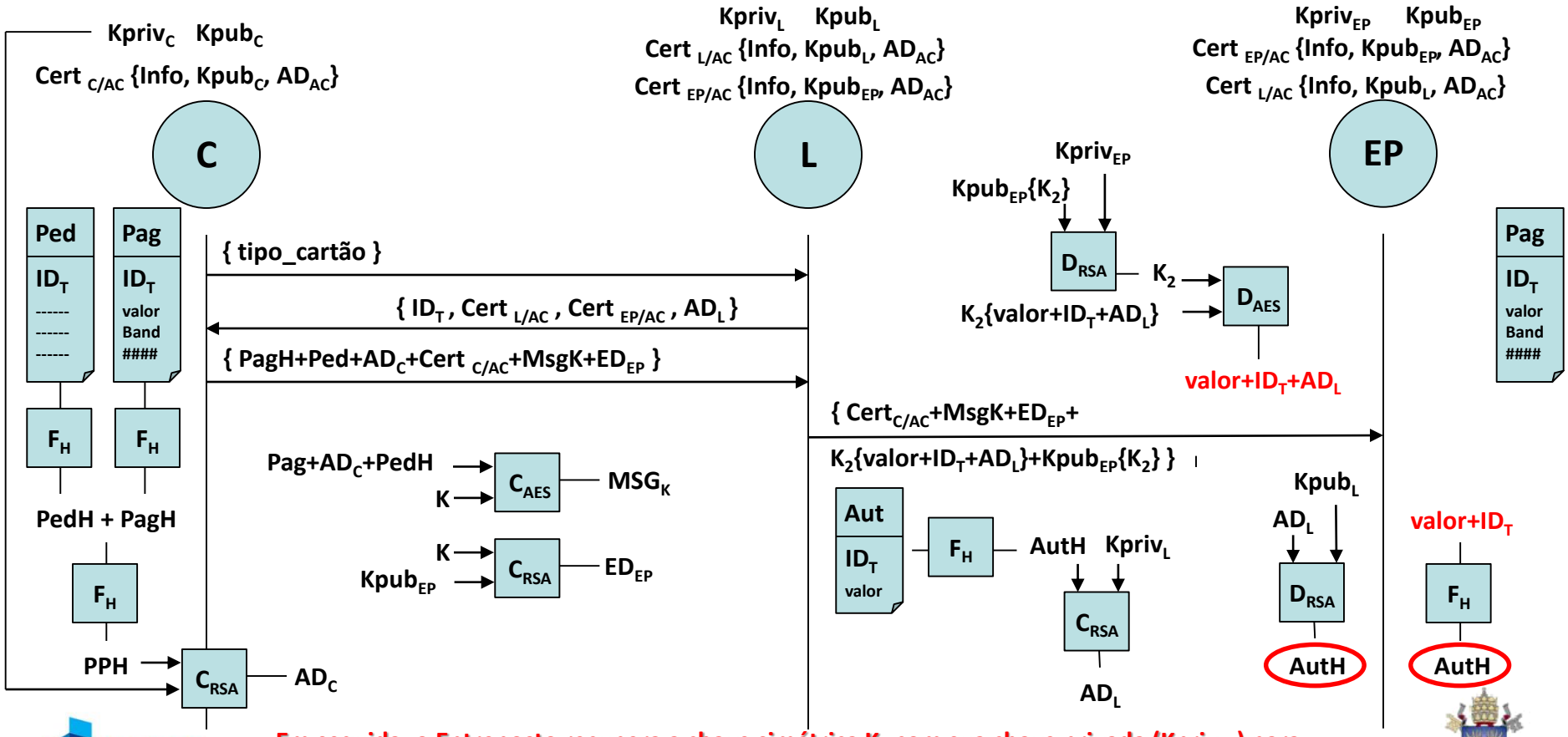
Secure Eletronic Transaction (SET) – Especificação 1.0: Requisição de Pagamento



O Entreposto faz uma verificação de integridade e autenticidade de Pag semelhante a que foi realizada pela Loja...

Comunicação Segura

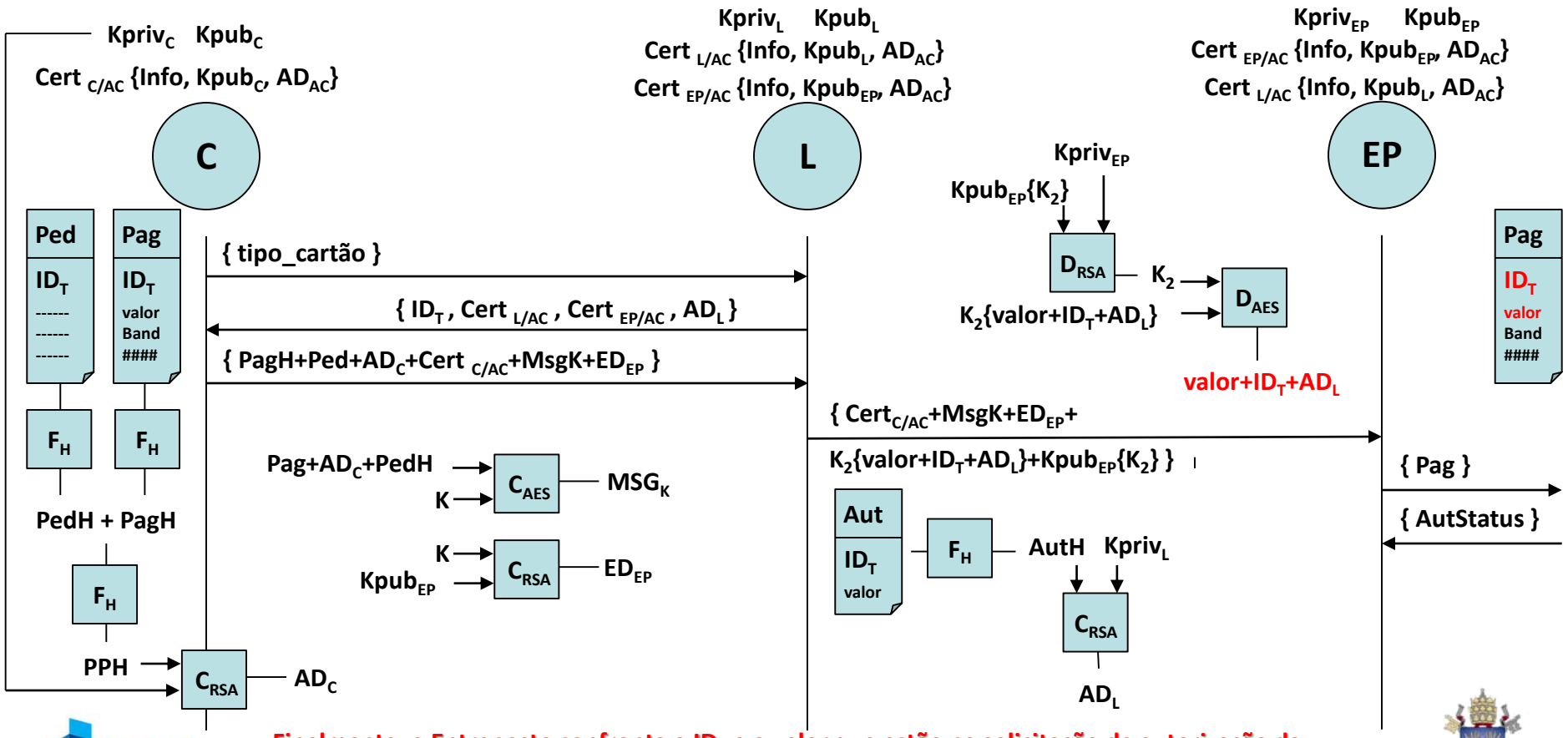
Secure Eletronic Transaction (SET) – Especificação 1.0: Requisição de Pagamento



Em seguida, o Entreposto recupera a chave simétrica K_2 com sua chave privada ($Kpriv_{EP}$) para poder recuperar o ID_T e o valor que estão na solicitação de autorização da Loja...

Comunicação Segura

Secure Eletronic Transaction (SET) – Especificação 1.0: Requisição de Pagamento



Finalmente, o Entreposto confronta o ID$_T$ e o valor que estão na solicitação de autorização da Loja com o o ID$_T$ e o valor que estão em Pag. Se ambos forem iguais, o Entreposto valida o crédito do cliente na rede financeira...